



File No.: EXP202210465

RESOLUTION OF SANCTIONING PROCEDURE
BACKGROUND

.....
4

FIRST:

.....
4

SECOND:

.....
5

THIRD:

.....
5

FOURTH:

.....
5

FIFTH:

.....
6

SIXTH:

.....
16

SEVENTH:

.....
16

EIGHTH:

.....
16

Preliminary. On the initiation of the sanctioning file against Telefónica

.....
16

I. On the facts that motivate the initiation of this sanctioning procedure agreement:

.....
18

II. On the legal grounds

.....
32

NINTH:

.....
58

TENTH:

.....
66

ELEVENTH:

.....
66

Preliminary. On the continuation of this sanctioning file.

.....
66

First. Clarification on the description of proven facts made by the AEPD.

.....
67

Second. On the incident in

***APP.1

and security measures: Telefónica considers technical and organizational measures that are appropriate to ensure adequate security of its customers' personal data, including protection against unauthorized or unlawful processing.

.....
67

Third. Overcoming Telefónica's sphere of responsibility: exceptional circumstances that have made it possible for third parties to surpass the implemented security policies.

.....
69

Fourth. On the preliminary issues raised by the AEPD within the framework of this file.

.....
69

Fifth. On the alleged infringements committed by Telefónica: violation of the principle of legality.

.....
69

Sixth. Telefónica's conduct is not unlawful.

.....
70

Seventh. Absence of culpability.

.....
70

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

2/128

Eighth. Breach of the principle of proportionality.

.....
70

PROVEN FACTS

.....
71

FIRST: First notification of personal data breach

.....
71

SECOND: Second notification of personal data breach

.....

72

THIRD: The following emails are in the file:

.....

73

FOURTH: Chronology and description of the attack:

.....

74

1.- Start date of the attack: September 9, 2022

.....

75

2. Period from September 16 to 20, 2022:

.....

75

3. September 28, 2022.

.....

76

FIFTH: Treatment activities affected by the incident and regarding the application

***APP.1

.....

76

SIXTH: Causes that made the breach possible

.....

77

SEVENTH: Security measures prior to the incident

.....

78

NINTH: Measures following the security incident

.....

79

TENTH: Risk analysis of the application affected by the personal data breach:

.....

80

ELEVENTH: Methodology of the risk analysis

.....

81

TWELFTH: Absence of risk analysis for the rights and freedoms of individuals and Impact Assessment in data protection.

.....

82

THIRTEENTH:

Absence of two-factor authentication

.....

82

FOURTEENTH: Number of affected individuals and type of affected data

.....

82

FIFTEENTH: Communication to the affected individuals

.....

82

LEGAL GROUNDS

.....

83

I Competence

.....

83

II Preliminary issues

.....

83

III On the nature of the data affected by the breach

.....

84

IV Allegations regarding the initiation agreement

.....

87

First. - Preliminary considerations and clarification regarding the description of the facts made by the AEPD in the Initiation Agreement

.....

87

Second. - Regarding the incident in

***APP.1

and the security measures. Telefónica considers that it includes technical and organizational measures that are appropriate to ensure adequate security of personal data, including protection against unauthorized or unlawful processing.

.....

91

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

3/128

Third.- Overcoming the sphere of responsibility of Telefónica:

Exceptional circumstances that have made it possible for third parties to surpass the security policies

implemented.

.....

96

Fourth.- Regarding the preliminary issues raised by the AEPD.

.....

97

Fifth.- Regarding the alleged infringements committed by Telefónica.

Violation of the principle of legality.

.....

107

V Arguments against the proposed resolution

.....

123

Preliminary. On the continuation of the present sanctioning file.

.....

123

First. Clarification on the description of proven facts made by the AEPD.

.....

125

Second. Regarding the incident in ***APP.1 and the security measures: Telefónica considers technical and organizational measures that are appropriate to ensure adequate security of its customers' personal data, including protection against unauthorized or unlawful processing.

.....

125

Third. Overcoming the sphere of responsibility of Telefónica: exceptional circumstances that have made it possible for third parties to surpass the security policies implemented.

.....

128

Fourth. Regarding the preliminary issues raised by the AEPD in the context of this file.

.....

128

Fifth. Regarding the alleged infringements committed by Telefónica: violation of the principle of legality.

.....

128

Sixth. Telefónica's conduct is not unlawful.

.....

133

Seventh. Absence of culpability.

.....

134

Eighth. Violation of the principle of proportionality.

.....

135

VI Integrity and confidentiality

136

VII Qualification of the infringement of Article 5.1.f) of the GDPR

138

VII Sanction for the infringement of Article 5.1.f) of the GDPR

139

IX Article 32 of the GDPR

140

X Qualification of the infringement of Article 32 of the GDPR

146

XI Sanction for the infringement of Article 32 of the GDPR

147

XII Measures

148

RESOLVES

:

148

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

4/128

RESOLUTION OF SANCTIONING PROCEDURE

From the procedure instructed by the Spanish Agency for Data Protection and based on the following

BACKGROUND

FIRST:

On September 26, 2022, the Division of Technological Innovation of the Spanish Agency for Data Protection was notified of a security breach of personal data reported by TELEFONICA DE ESPAÑA SAU with NIF A82018474 (hereinafter, Telefónica) as the data controller.

The received document informs the following:

- Start date of the breach: September 16, 2022.
- Date of detection that the breach affects personal data: September 23, 2022.
- Resolution date: September 20, 2022.
- The data is not encrypted.
- Summary of the incident: "(...)"
- Approximate number of individuals whose personal data is processed, referring exclusively to the

processing regarding which the personal data breach occurred: 6,000,000

- Number of individuals whose data has been affected by the breach: 1,021,253
- Categories of affected data: Contact data, access credentials or identification (username and/or password).
- As a consequence of the incident, confidentiality has been compromised.
- The authorities have not been informed.
- Communication to the affected individuals is pending decision.

SECOND:

As a consequence of the known facts, on September 30, 2022, the Director of the Spanish Agency for Data Protection ordered the General Subdirectorate of Data Inspection (SGID) to carry out the appropriate preliminary investigations in order to determine a possible violation of data protection regulations.

THIRD:

After analyzing the notification of the personal data breach and by virtue of the functions and powers of this Agency referred to in Article 47 of Organic Law 3/2018 as well as Article 58 of Regulation (EU), on September 30, 2022, Telefónica was ordered to communicate the personal data breach to the affected individuals in accordance with Article 34 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), without undue delay, so that, once they are aware of it, they can take the measures they deem appropriate to avoid any risks that may affect them.

Against this Resolution, Telefónica filed a request for reconsideration on October 13, 2022, arguing that a complete forensic analysis was not available and that the data affected by the incident is considered non-identifiable to a third party outside Telefónica, which was dismissed by Resolution of October 20, 2022.

FOURTH:

On October 26, 2022, a new notification of the breach was received, completing the initial notification. This new notification includes the following information:

- The description states: "(...)"
- It is stated that the start date of the breach is September 9, 2022.
- It is stated that the incident was detected on September 20 by a warning from a member of the organization.
- It is stated that the breach was resolved on September 20, 2022.
- It is stated that on September 23, 2022, it was detected that the breach had affected personal data.
- It is indicated that, in total, a total of 1,407,257 individuals have been affected, all of whom reside in Spain.
- It is stated that the breach could have been avoided by adopting additional measures, but it did not occur due to deficiencies in current measures.
- It is stated that the new reactive measures implemented have been "***MEASURE.1" and "***MEASURE.2".
- It is stated that a Risk Analysis and Incident Register are available.
- It is stated that the incident has been reported to the police authorities.
- It is stated that the affected individuals will be informed no later than October 28, 2022.
- There is no data processor affected by the breach.

Along with the notification, the following documentation is provided:

- "Privacy Incident Report Unauthorized Access to ***APP.1"

FIFTH:

The General Subdirectorate of Data Inspection proceeded to carry out preliminary investigative actions to clarify the facts in question, by virtue of the functions assigned to the supervisory authorities in Article 57.1 and the powers granted in Article 58.1 of the GDPR, and in accordance with the provisions of Title VII, Chapter I, Section two, of Organic Law 3/2018, of December 5, on Personal Data Protection and Guarantee of

C/ Jorge Juan, 6

www.aepd.es
28001 – Madrid
sedeagpd.gob.es
6/128

the digital rights (hereinafter, LOPDGDD), being aware of the following aspects:

From the analysis of the document "Privacy Incident Report Unauthorized Access to ***APP.1", provided by Telefónica in the second notification of the breach to this Agency on October 26, 2022, the following relevant information is extracted:

- Unauthorized access was detected in one of the internal applications of Telefónica's employee portal called ***PORTAL.1 (***URL.1). Access to this portal was public from the internet and used an authentication method based on credentials that each employee possesses (username and password).
 - On September 23, 2022, the CSIRT-TE (Telefónica Security Incident Response Team) informed the DPO of Telefónica of a security incident. They indicated that it was on this same day that it was confirmed that the requests made by the attackers had received responses, confirming the impact on personal data; however, it was also stated that at this moment the complete list of affected data associated with the fixed numbers that had been randomly queried by the attacker was unknown. As evidence of this, a screenshot of an internal email sent on September 23, 2022, at 22:17 by the security team (CSIRT) is provided with the following content: "(...)".
 - It is stated that the affected information was as follows: fixed telephone, technical data, and configuration of the Client Equipment (...). All this information was used for customer support and maintenance purposes by Telefónica's technical teams.
 - It is stated that on September 20, 2022, it was actually detected by the team of ... a higher number of requests than usual, which after analysis was found to be made by user ***USUARIO.1 through the portal ***URL.1, (...), proceeding to block the user in the application until it was analyzed what was causing those requests. A screenshot of an email sent by the responsible parties of ... on this same day, September 20, 2022, at 9:05 AM, with the following content is also provided: "(...)".
 - The following is stated verbatim: "(...)"
 - It is stated that on September 21, 2022, a notice was received in the security area (CSIRT) from the user with whom the mass requests had been made, notifying the security incident. During the days of September 21 and 22, 2022, this security team analyzed the case (...) and consulted the affected areas to obtain more information about the case.
 - It is stated that on September 23, 2022, considering the information gathered from the different areas, an urgent meeting was convened by the security team, in which evidence was obtained that it was a real incident, requesting the logs of the affected application for analysis by the security team, (...). It was on this same day that the CSIRT-TE proactively informed the DPD of Telefónica España.
- C/ Jorge Juan, 6

www.aepd.es
28001 – Madrid
sedeagpd.gob.es
7/128

- During the following days, the security team continued the analyses to detect if there had been any further unauthorized access, confirming on September 29, 2022, that there was a second suspicious intrusion with a new compromised user (***USER.2). The password was changed, and the employee was notified. On this day, all users with access to the application ***APP.1 were blocked as a preventive measure.
- It is stated that once the forensic analyses were completed, they concluded that the malicious accesses occurred in three time blocks: from September 9 to 11, from September 16 to 20, and on September 28, (...), all these accesses aimed to obtain data from customer equipment (...). The malicious requests on September 28 were detected by the measures deployed by the security team, (...).
- They claim that information was obtained from 1,612,926 fixed numbers corresponding to 1,407,257 affected individuals.

- Regarding the cause of the incident, Telefónica states: "(...)".
- In the incident report, Telefónica evaluates the risk level of the security breach following the breach guidelines of this Agency. From this analysis, it is concluded:
- It is stated that the categories of affected data are: Fixed telephone associated with the following technical and configuration data of the customer's equipment: (...).
- It is stated that these affected data are not regarded by Telefónica in the same way as by a third party outside the company, since for Telefónica the number is a pseudonymous data, but this data does not allow a third party to identify an individual directly or indirectly in a reasonable manner.
- It is stated that for Telefónica, the fixed telephone number is a pseudonymous data insofar as it cannot be attributed to a data subject without using additional information that Telefónica possesses. However, it is stated that this data does not allow a third party to identify an individual directly or indirectly in a reasonable manner, so Telefónica concludes that no personal data that would reasonably allow a third party to identify an individual directly or indirectly has been affected by the incident.
- Regarding the rest of the leaked data about customer equipment, they state that these are data that do not allow identification, not even when associated with a fixed telephone number:
- The MAC address only identifies a device;
- The Wi-Fi network name (SSID) is not uniquely associated with a fixed number, but can correspond to more than one number;
- The leaked Wi-Fi network passwords (SSID) are listed in the router itself unencrypted, being a common commercial practice.
- The incident report also includes an analysis of the possible consequences for the affected individuals following the AEPD guidelines, concluding a LOW severity level: "Individuals will not be affected or may encounter some very limited and reversible inconveniences that they will overcome without any problem (time to re-enter information, inconveniences,

C/ Jorge Juan, 6
 www.aepd.es
 28001 – Madrid
 sedeagpd.gob.es
 8/128

irritations, etc.," justifying that "the data obtained cannot be considered identifiable data without the application of a disproportionate effort for third parties who have accessed it without authorization, and that among the affected data there is no sensitive information considered as such by the GDPR," and a level of probability of materialization of the consequences LOW or UNLIKELY, considering the following points:

- 1.- The Wifi network, in its default configuration, is end-to-end encrypted.
- 2.- Access to each wifi network could only occur when the intruder is physically within the coverage area of the home (postal address), a piece of information that has not been leaked.
- 3.- For the intruder to be physically in the coverage area of the router installation, it would be necessary for the third party to have the postal address corresponding to the Wifi keys (data that has not been extracted from Telefónica's systems) and 4.- An additional action would be necessary."

-

It is stated that the processing activities affected by the breach are:

(...)

-

Regarding preventive security measures, they state the following:

(...)

-

Regarding reactive mitigation measures, they state the following:

(...)

-

Regarding the detection date, they state:

-

On September 23, 2022, the CSIRT team, after analyzing access logs, confirmed the impact on the list of technical data and configuration of the equipment associated with the fixed telephone numbers of Telefónica customers.

-

Regarding detection means, they state:

-

The API Gateway team detected a higher than usual number of requests made by a user towards consecutive fixed telephone numbers. It was verified with the user that it was not him who was making the accesses.

-

The incident was reported by the user on September 21, 2022, at 09:54, (after being alerted by the team of ...), via email sent to the CSIRT-TE Incident mailbox. At this moment, internal investigations by the security team began.

-

On September 23, 2022, at 22:17, it was confirmed that the requests made by the attacker had received a response, confirming the impact on personal data in the incident.

-

They state that the breach started on September 9, 2022, and not on September 16, 2022, as specified in the initial breach notification.

Taking into account all the previous information obtained from the documented breach report, on November 2, 2022, a new information request was made to Telefónica marked by the following line of investigation:

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

9/128

-

To verify the communication made to the affected parties.

-

To obtain a copy of the risk analyses of the processing activities affected by the security breach.

-

To verify the email of the incident reported by the employee to the CSIRT security team, as well as the verification of the communication made to the DPO.

-

To obtain details about the use cases of the affected application (**APP.1).

-

To obtain the technical description of the APIs consumed in the attack in order to verify the scope of affected data.

-

To obtain logs in which the malicious requests made to the APIs were detected, in order to verify the scope of affected data.

On November 28, 2022, a response was received by this Agency to the information request. From the analysis of this response, the following is extracted:

-

Regarding the verification of communication to the affected parties:

-

They state that the means used predominantly has been email and in some other cases postal mail when the email data was not available.

-

They state that 89,244 postal letters have been sent and this fact is verified by providing a certificate from Correos with a registration date of October 31, 2022.

-
They state that 1,313,395 emails have been sent, providing details of the dates on which the emails were sent, which are between October 27, 2022, and November 2, 2022.

-
They state that it was necessary to carry out the communication in phases and on the previously indicated dates in order to ensure and guarantee adequate attention to possible requests for information from customers, having been necessary to reinforce the number of people attending the telephone channel and provide them with appropriate training so that they could respond to customer information requests and queries. They state that another reason for carrying out the communication in phases was to be able to properly assist the affected customers and avoid the collapse of the different management channels enabled for the password change suggested in the communication content (due to possible excessive demand).

-
They state that the affected users were customers of both Telefónica Movistar and Telefónica O2.

-
They verify the following content of the communication for Telefónica Movistar customers:
(...)

-
They verify the following content of the communication for Telefónica O2 customers:
(...)

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
10/128

- In relation to our request for the risk analyses for the treatments affected by the breach, a document is attached from which the following analysis is extracted:

- This document states: “(...)”.

- The document is unsigned, dated November 24, 2021, and it states: “AA.RR. conducted in the following time period: July-October 2021.”

- In the section regarding the object of the analysis, it states: “(...)”.

- In relation to the methodology, it states: “(...)”.

- A list of security controls implemented on the affected assets is attached.

- The following list of threats is analyzed, and a level of residual risk is concluded by assigning each one a level of probability and impact:

(...)

- In relation to our request for proof of the email that the affected user sent to the security team of Telefónica (CSIRT-TE) notifying the incident, a screenshot is provided, from which the following analysis is extracted:

- The user states in the email that they became aware of the incident after being notified via email on September 20, 2022.

- The incident email is addressed to the security team (CSIRT-TE) and is dated September 21, 2022, at 9:54.

- The full text of the email is as follows: “(...)”

- In relation to our request for proof of the communication of the incident that was directed from the security team (CSIRT-TE) to the DPD, a screenshot of the email sent with the following content is provided:

- “(...)”

- In relation to the request for information about the different use cases of the applications affected by the breach, they respond as follows:

- The web portal ***PORTAL.1 allows access to different internal systems, including the one affected by the incident, the application ***APP.1, through which the team that handles technical incidents for clients can consult the necessary information for diagnosing and addressing faults in connectivity

equipment.

- They provide various screenshots showing both the use cases of the application ***APP.1 through its graphical interface and the queries launched by the attackers, which were automated through a script, confirming that the attackers did not use the graphical interface of the application but rather utilized automated direct queries that attacked its functionality without using the menu options, and employed a sweep of random phone numbers to obtain data about the equipment installed at the client if this number matched that of any Telefónica client.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

11/128

- In relation to our request for a technical description of the APIs that the attackers consumed when launching the automated queries, they provide a document with all the technical details of these, with no additional relevant information obtained for the present investigation.

- In response to the request for proof of some log records through which they detected the attack, they provide a screenshot with records detected on September 16, 2022; from their analysis, the type of data that the attackers could access is confirmed, which matches the data indicated in the breach notification, confirming that in each automatic request launched by the attackers, a random phone number was included, and if this number matched that of any Telefónica client, the following data was obtained as a result of the query:

(...)

SIXTH:

According to the report collected from the AXESOR tool, the entity TELEFONICA DE ESPAÑA SAU is a large company with a turnover of (...).

SEVENTH:

On September 26, 2023, the Director of the Spanish Agency for Data Protection agreed to initiate sanctioning proceedings against the respondent for the alleged infringement of Articles 5.1.f) and 32 of the GDPR, classified, respectively, in Articles 83.4 and 83.5 of the GDPR.

EIGHTH:

The aforementioned initiation agreement was notified in accordance with the rules established in Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP); Telefónica submitted a written statement of allegations in which, in summary, it stated the following:

Preliminary. On the initiation of the sanctioning file against Telefónica

Telefónica indicates that it has complied with the provisions of the applicable regulations regarding the management of the incident in the internal system of Telefónica ***APP.1, which is the subject of this initiation agreement, and that it has collaborated with the Agency at all times, providing all the information required by the regulations and that has been requested.

Telefónica indicates that, despite the above, it seems that the Agency does not take into account that this is a specific incident and seems to erroneously conclude that the above implies that Telefónica does not have adequate security measures in general. In this regard, and concerning the content of the initiation agreement, Telefónica conveys that the AEPD has not analyzed at any time the methodology or the protocols of action of Telefónica regarding the implementation of security measures in the processing of personal data. In other words, it seems that the C/ Jorge Juan, 6

www.aepd.es
28001 – Madrid
sedeagpd.gob.es

12/128

existence of an incident to process a kind of "general cause" in relation to the insufficiency of adequate security measures.

Telefónica emphasizes that there is total and absolute lack of responsibility on its part regarding the

alleged infringements, as the consummation of this type of crime necessarily requires prior acquisition of the data of the interested party, in this case through a very sophisticated technique aimed mostly at the personal mobile numbers of employees. This indicates that the attacker already had this information beforehand and that Telefónica could not detect the attack carried out on the personal devices of the employees. Subsequently, the data obtained regarding personal credentials were used by professional attackers to illegally access an internal system of Telefónica.

Telefónica points out that the fraudsters who carry out this type of activity are not just isolated individuals or more or less organized groups, but that, following appropriate police investigations, it has been determined that they are cybercriminals perfectly prepared and with sufficient resources to engage in these undesirable practices.

Telefónica argues that it is yet another victim of the criminal acts committed by third parties, which the National Police itself has considered to represent "a serious risk to National Security." In this regard, Telefónica collaborates in the police investigations initiated by the Civil Guard ("***EXPEDIENTE.1"), whose purpose is both to detect those responsible for the events and to determine their scope and connections with other similar activities.

Telefónica indicates that, currently, as a victim of the activities investigated by the Civil Guard, it is formally constituted as a private prosecution in the Proceedings (...). Thus, the Investigating Court (...) considered, (...), that the criminal activities that affected Telefónica are connected with the activities that affected the "Judicial Neutral Point (PNJ)" (the telecommunications network that connects judicial bodies with other state institutions).

Telefónica states that all of this demonstrates that the criminal activities that impacted Telefónica also affected other entities and institutions of the State, evidencing the complexity and sophistication of the attack executed by individuals especially prepared for these criminal activities.

I. Regarding the facts that motivate the initiation of this sanctioning procedure:

First. Clarification regarding the description of facts made by the AEPD in the initiation agreement

Telefónica points out that there are a series of errors in the description of the facts made by the AEPD in relation to the security incident in ***APP.1, which it clarifies below. Therefore, Telefónica indicates that, as stated in the "Privacy Incident Report Unauthorized Access to ***APP.1" (hereinafter Incident Report or Report), which it submitted along with the complete communication of the Incident, the facts took place on the following dates:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

13/128

- On 20/09/2022: it was actually when the team from ... (application that manages requests to systems) detected a higher than usual number of requests to ***APP.1. (...) and it was proceeded to block it, until analyzing what was happening, and to restore its corporate credentials. As stated in the Report, and in the complete notification of the Incident, in the initial communication submitted to the AEPD, it was reported that the date on which this Incident began was 16/09/2022. However, once the final forensic report was concluded, this aspect was corrected upon confirming that it was actually 20/09/2022.

That is to say, it was on that same day, 20/09/2022, when the Incident was detected and containment measures were taken (...). When analyzing data from previous days to determine when the accesses had begun, it was found that they started on 16/09/2022, but this was not the detection date.

- On 21/09/2022: the incident response team of Telefónica (CSIRT-TE) received a notice of what at that moment was not known whether it could be a security incident or a simple incident caused by some system that had an automation with that user, circumstances that have occurred on other occasions.

That is to say, the CSIRT-TE was informed without undue delay, and when certain measures had already been adopted by ..., not 5 days later. From that same day, the case began to be analyzed with the data provided by the user and the affected areas were consulted to obtain more information.

- On 23/09/2022: taking into account the information gathered from the different areas, a security

urgent meeting was convened to address the possible incident. In that meeting, evidence was obtained that it was indeed a real incident. As the Agency knows, it was on that same day when the CSIRT-TE proactively informed the DPO of Telefónica España. Telefónica indicates that it subsequently complied with the provisions of data protection regulations and on 26 September 2022 submitted the initial form to notify the existence of a security incident.

Based on the above, Telefónica concludes the following:

- It is not true that the containment measures were taken 4 days later, as on the same day that the massive queries were detected (20 September), the user from which the queries had been made was blocked.
- It is not true that the massive requests did not cease until the employee changed their credentials, as the user, as previously indicated, was blocked at the same moment of detection.
- It is also not true that massive queries significantly higher than usual were being detected and that Telefónica did not act. After the detection of the massive queries on 20 September, the security teams took action.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
14/128

acted with the utmost urgency and on the same day of detection the user was blocked.

What is true, and what may have confused the Agency, is that after conducting the investigation it was detected that on September 16, massive queries had also been made. These queries were, in any case, prior to the detection of the incident (which was on September 20).

Telefónica recalls that ***APP.1 allows the team of people who handle technical incidents for customers to consult the necessary information for diagnosing and addressing faults in connectivity equipment (router, TV decoder, Wi-Fi amplifier, etc.).

Telefónica points out that, however, in this case, unauthorized access did not occur to the entire system, but rather only to certain configuration data of some connectivity equipment provided by Telefónica. That is to say, (...):

In summary, Telefónica believes it is important for the AEPD to clearly understand the sequence of events and the sophistication of the attack carried out, which did not simply consist of obtaining credentials (through a sophisticated fraud technique aimed at personal numbers of employees, as will be detailed later) and accessing a system to consult all the information desired, but rather the attacker previously knew the personal numbers of the employees to whom the SMS were sent and also understood the operation (...).

(...)

Second. Regarding the incident in ***APP.1 and security measures: Telefónica considers technical and organizational measures that are appropriate to ensure adequate security of its customers' personal data, including protection against unauthorized or unlawful processing.

(...)

Telefónica indicates that, subsequently, and to the extent that the attacker had to understand the operation (...).

Telefónica disagrees with the AEPD's conclusion that Telefónica's security measures were not adequate to ensure the confidentiality of the personal data it processes, based solely on one outcome (the existence of a targeted attack that caused the security incident).

Telefónica believes that, from the information provided in the context of this Incident, it has been more than demonstrated that the security measures implemented by Telefónica regarding the processing of personal data of its customers are appropriate and reasonable to ensure adequate security. However, the actions carried out by Telefónica and the measures implemented cannot be analyzed without considering the continuous innovation of fraud techniques and the sophistication of attackers when perpetrating and evolving their techniques (as will also be detailed in the following allegation).

C/ Jorge Juan, 6
www.aepd.es

Furthermore, Telefónica points out that the Agency has not analyzed at any time the methodology or the action protocols that Telefónica has regarding the implementation of security measures in personal data processing. That is to say, it has only relied on what happened in a specific incident to process a kind of "general cause" and argue the alleged insufficiency of security measures, establishing a clear obligation of result and demanding infallibility of measures that are completely nonsensical.

Specifically, Telefónica points out that the AEPD seems to reproach in the Initiation Agreement that Telefónica (...)

Telefónica indicates that, in this regard, it is important to make it clear that both the Telefónica Group and Telefónica de España are fully aware and concerned about ensuring security and compliance with regulations in the processing of data they carry out. An example of the above is the existence of different policies and manuals that they have in this area.

(...)

Telefónica indicates that the approach to risk management at Telefónica, as described in this Manual, is based on defining and applying a security risk analysis process that allows identifying, analyzing, and evaluating the various security risks to achieve objectives, reduce undesirable situations, and achieve continuous improvement of the security level.

(...)

In this international standard, a catalog of threats is defined, and for each of them, the probability of materialization and the level of degradation (potential damage that a threat can cause to a specific asset) in each security dimension is detailed. Additionally, this standard also includes a catalog of controls in each security dimension, the level of mitigation of the probability and/or degradation for each threat, and the type of asset to which the control objective applies.

Specifically, Telefónica's security risk analysis methodology is based on the following steps:

(...). The above demonstrates that Telefónica, aware of the need to evolve its security measures, has numerous initiatives to do so.

(...)

Next, Telefónica includes a summary of the main measures it has to comply with the obligations set forth in data protection regulations. The existence of these measures also justifies why it was concluded in this case that the materialization of the risk of accessing the system with valid credentials could only occur under exceptional circumstances:

2.1. Telefónica has certificates that attest to the management of security, in accordance with the regulations.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

16/128

Telefónica states that, in its commitment to comply with applicable regulations and to provide the highest security and quality to its services, it holds various certificates that attest to the proper management of information security.

For example:

(...)

Telefónica concludes that the certificates it holds demonstrate its effective management of information security.

2.2 Employee Awareness Measures

Telefónica considers employee awareness regarding information security to be fundamental, as employees are an additional source for detecting potential incidents and one of the links that need to be protected (against phishing, smishing techniques, etc.). Within this awareness-raising effort, led by Telefónica's information security area, the following actions are carried out, for example:

- Continuous training, through security tips and briefings, cybersecurity courses, specific workshops such as “Fishing for Phishing,” etc.
- Periodic awareness campaigns specifically addressing Phishing/Smishing/Qrishing2 to all employees to provide training on this type of attack.
- Awareness related to this type of attack, through webinars and participatory workshops.
- Training on the procedures to follow in case of receiving notifications from dubious sources, including how to communicate with Telefónica's incident response and management teams.
- Information and news through Telefónica's internal communication channels.

Furthermore, Telefónica indicates that, in order to measure the level of employee awareness and determine if additional measures need to be implemented, annual surveys are conducted. Phishing simulation campaigns are also carried out, sending emails or SMS to all employees with current themes and simulating what could be a malicious campaign.

In the event that employees fail the simulation, they are notified and additional reinforcement measures are applied.

Telefónica provides images of “screenshots” of emails regarding this matter.

In summary, Telefónica concludes that it is a company very aware that security is a matter for all employees and not just for certain areas of the company.

2.3 Access Control Measures

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

17/128

(...)

2.4 Measures for the control of web domains and emails that may include malicious content

(...)

2.5 Measures for the protection of devices provided to employees

(...)

Telefónica concludes that all of the above only serves to demonstrate that it has appropriate measures in place to ensure the confidentiality of the personal data it processes.

2.6 Information that the ***APP.1 system stores and associated risks for the rights and freedoms of individuals

Telefónica indicates that the security measures applied to ***APP.1 were also adequate considering the category of data stored in the system and the possible risks that could exist for the rights and freedoms of the data subjects.

(...)

It is evident that these are not sensitive data, nor data whose loss of control could imply serious consequences for the data subjects, since:

(...)

In any case, and regarding risk assessment, if a third party wanted to exploit the mentioned information, it must be taken into account that:

(...)

Telefónica concludes that the above demonstrates that the security measures of ***APP.1 were also appropriate to ensure security, considering the category of data stored and the assessment of possible risks to the rights and freedoms of the data subjects.

2.7 Continuous Review and Update of Technical and Organizational Measures

Telefónica indicates that it acts with total diligence when reviewing and updating the technical and organizational measures implemented when necessary and/or convenient to maximize the security of the processing of personal data of its clients, as well as the respect and compliance with the guiding principles governing data protection regulations and, in particular, the General Data Protection Regulation.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
18/128

Telefónica states that a security risk analysis of the information systems supporting data processing is conducted to determine whether the level of risks is adequate. If not, risk treatment plans are initiated to achieve this.

Telefónica warns that to fairly and objectively assess the adequacy of the review and update process of the security measures adopted by the entity, it is necessary to determine the moment a new risk arises. That is, it is not possible to analyze the actions taken by Telefónica without considering that the rise of this type of fraud is notably recent and the characteristics of the fraud committed in this specific case.

Telefónica asserts that in the face of such attacks aimed at committing a crime by a third party, the company makes numerous daily efforts to protect its customers:

(...)

From the above, Telefónica concludes that it has established technical and organizational measures that are adequate and that are continuously reviewed and updated to ensure appropriate security of its customers' personal data, including protection against unauthorized or unlawful processing.

In summary, Telefónica believes that the account contained in this second allegation demonstrates that it has acted at all times with the utmost respect for the obligations imposed by national and European regulations on data protection, and that this evidences that it could not be considered to be in the presence of the alleged infringements indicated by the AEPD in its initiation agreement.

Third. Overcoming Telefónica's sphere of responsibility: exceptional circumstances that have made it possible for third parties to overcome the established security policies.

Telefónica indicates that in this case, the attackers accessed ***APP.1 with legitimate credentials obtained through a very sophisticated smishing campaign directed at the personal numbers of employees. That is to say, Telefónica points out that it is one of the most advanced tools available to cybercriminals to impersonate a third party and commit a crime.

Telefónica notes that the attacker previously knew the personal phone numbers of the employees (which could have been obtained from any attack on another institution). This caused it to be impossible for Telefónica to detect that the employees were receiving such SMS messages as they were sent to private devices. Consequently, it could not establish proactive measures to stop the attack at an earlier stage.

Telefónica clarifies that when the attack is directed at corporate numbers or email accounts, Telefónica has means to detect it through the different

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
19/128

security measures that have been implemented, and which have been detailed in the previous allegation (such as the monitoring of web domains to detect pages that may include fraudulent content). Once detected, the necessary measures are adopted, credentials that may be implicated are reset, and employees are immediately informed. Telefónica provides images of alerts that it has sent to its employees when a smishing campaign has been detected, through internal communication channels.

Unfortunately, Telefónica recalls that both it and other companies and public institutions must increasingly face third parties whose intention is to commit such crimes. These third parties are always one step ahead and continuously improve their techniques with this objective, taking advantage of the possibilities offered by the use of technology and social engineering.

As a demonstration of the aforementioned, Telefónica points to the constant news that appears in the media and the recommendations and analyses from various organizations, which increasingly

frequently highlight this issue. Telefónica provides several examples of this published on different websites, including that of the AEPD itself.

In summary, Telefónica indicates that impersonators make use of the aforementioned social engineering techniques or the carelessness of users themselves when sharing information on the Internet or allowing others to access it, to obtain the data they need and then approach companies to carry out this type of attack.

Telefónica reminds that the characteristics of the attack and the cybercriminals that caused this Incident must be taken into account. At this time, several attackers have been arrested, and there is an ongoing police investigation into their practices within the framework of the so-called “***INVESTIGACIÓN.1” and “***INVESTIGACIÓN.2”.

Telefónica points out that this evidences the constant evolution and sophistication of the techniques used by fraudsters and the difficult position that different companies and institutions face when they become targets of such crimes. In this situation, Telefónica can only establish appropriate technical and organizational measures based on the variable probabilities and severity risks for the rights and freedoms of individuals as they occur, without being required to ensure that such measures prevent any type of future risk.

In conclusion, Telefónica understands that it is essential for the AEPD to take into account the continuous innovation of fraud techniques and the sophistication of impersonators when perpetrating and evolving such techniques. It is evident that in this case, the attack suffered was executed by advanced actors, as part of a targeted attack. These attackers were characterized by acquiring deep and detailed knowledge of the operations and networks of the attacked organizations. We are not talking about an opportunistic attacker, but rather a well-designed operation that was based on prior knowledge of the company, likely acquired through non-informatic means beforehand.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

20/128

As a result, Telefónica becomes yet another victim of this type of criminals. Therefore, as we have already communicated, this party is cooperating in the police investigations initiated by the Civil Guard (“***EXPEDIENTE.1”), which aim to both detect those responsible for the events and determine their scope and connections with other similar activities.

Currently, Telefónica specifies that (as a victim of the activities investigated by the Civil Guard) it is appearing as a private prosecution (...).

According to Telefónica, all of the above demonstrates that the criminal activities that impacted Telefónica also affected other entities and institutions of the State, evidencing the complexity and sophistication of the attack carried out by individuals specially trained for these criminal activities.

II. On the Legal Grounds

First. On the preliminary issues raised by the AEPD

Telefónica recalls that in the second section of the legal grounds of the Initiation Agreement (related to “preliminary issues”), the AEPD states that “in the case at hand, the security breach suffered has affected personal data processed by Telefónica in its capacity as data controller, as it determines the purposes and means regarding those processes, pursuant to Article 4.7 of the GDPR.”

In line with the above, Telefónica notes that in the third section of the legal grounds, it assesses “the nature of the data affected by the breach” and concludes that “with the current wording of the GDPR, it is automatically inferred that the fixed telephone number is a piece of personal data concerning the holder of the line—it is an identifier—that is sufficient to make them identifiable.”

Regarding the nature of the data affected by the incident, Telefónica argues that the attackers who made the unauthorized queries entered fixed telephone numbers that they already knew randomly. That is to say, the attackers already had the numbers beforehand. Therefore, despite what was indicated by the AEPD in the Initiation Agreement, Telefónica believes that the following considerations should be taken into account in this procedure to assess whether these data can

indeed be considered personal data for third parties unrelated to Telefónica:

- Regarding the fixed number, not associated with any other personal data

Telefónica recalls that on September 26, 2022, it proceeded to notify the Incident from which this File derives, in accordance with the provisions of data protection regulations. Once the analysis was carried out, it was confirmed that unauthorized queries had been made by entering fixed telephone numbers randomly (numbers that the attackers already knew).

To analyze the nature of this data, Telefónica indicates that, on the one hand, it must start from the concept of pseudonymization provided for in Regulation (EU) 2016/679.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

21/128

of the European Parliament and of the Council of April 27, 2016, regarding the protection of individuals with regard to the processing of personal data and the free movement of such data, and repealing Directive 95/46/EC (hereinafter, General Data Protection Regulation or GDPR), which defines it as: “the processing of personal data in such a way that the data can no longer be attributed to a data subject without the use of additional information, provided that such additional information is kept separate and is subject to technical and organizational measures to ensure that personal data is not attributed to an identified or identifiable natural person.”

Finally, Telefónica adds that pseudonymization and encryption are considered by Article 32 of the GDPR as part of the appropriate technical and organizational measures to ensure a level of security appropriate to the risk that the data controller may apply. In this case, it is a security measure applied in the system to which the attacker had access.

In short, Telefónica insists that for this entity (electronic communications service provider), a fixed telephone number is a pseudonymous data, insofar as it cannot be attributed to a data subject without the use of additional information, but that, when combined with such additional information held by Telefónica, allows for the identification of its customers. This is the reason why Telefónica proceeded to make the initial communication of the detailed Incident.

Notwithstanding the above, Telefónica understands that it is important for the Agency to consider whether the data affected as a result of the security Incident would actually allow any third party to identify the natural person directly or indirectly. To this end, we must start from Recital 26 and the definition in Article 4 of the GDPR, which defines personal data as: “any information relating to an identified or identifiable natural person (‘the data subject’); an identifiable natural person is one who can be identified, directly or indirectly, in particular by reference to an identifier, such as a name, an identification number, location data, an online identifier, or one or more specific elements of the physical, physiological, genetic, mental, economic, cultural, or social identity of that natural person.”

Considering the above, Telefónica does not agree that the fixed telephone number allows a third party to reasonably identify an individual directly or indirectly, since:

- The fixed telephone number was entered by a third party completely randomly, without even knowing whether that number belonged to Telefónica. In any case, it is information that the attackers already had.
- A fixed telephone number corresponds to a household, which may be composed of multiple people, and does not allow for the identification of a natural person by itself.
- Such fixed numbers can be consulted in other organizations, such as the National Commission on Markets and Competition (hereinafter,

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

22/128

CNMC), which transfers information about the operator to which the numbering belongs through the following link

<https://numeracionyoperadores.cnmc.es/portabilidad/fija> without such consultation being considered a processing of personal data.

- The fixed telephone number has not been obtained directly from Telefónica's systems, nor have other data been obtained that, associated with that number, allow for the identification of a natural person. In the event that the entered number corresponds to Telefónica, the obtained data has only been technical data of some connectivity equipment provided by TDE and installed at the customer's home (router, television decoder, wifi amplifier, etc.), without being associated with other data that would allow for the identification of the customers, as will be detailed in the following section.

Telefónica recalls that regarding whether the telephone number may constitute personal data, the AEPD and the National Court have ruled on several occasions, including the following:

- The Legal Report 0285/2006, stating that "from the perspective of personal data protection, the telephone number will constitute personal data when it is assigned to the specific holder of the same, or is associated with additional identifying data such as the address, and this is stored with the calling number, in accordance with the definition of personal data included in Article 3.a) of the Organic Law, which encompasses 'any information concerning identified or identifiable natural persons.'

- In the same vein, the Judgment of the National Court, Administrative Litigation Chamber, of September 17, 2008, Administrative Litigation Appeal 353/2007 (even in relation to mobile numbers that usually belong to a single natural person and not to a household, as previously noted regarding fixed numbers) states that: "In this case, the Spanish Agency for Data Protection has not reasoned, and much less has it proven, that through the mobile phone number the holder has been identified or that such identification could be possible from the said number, so that the said telephone number, devoid of other circumstances that identify or could allow for the identification of the holder, prevents it from fitting into the legal definition of personal data. Therefore, the appeal should be upheld and the contested resolution annulled with the effects derived from such annulment."

Telefónica indicates that this criterion has been ratified by the National Court in a judgment of March 8, 2002. As cited therein, "for there to be personal data (as opposed to dissociated data), it is not essential for there to be a full match between the data and a specific person, but it is sufficient that such identification can be made without disproportionate efforts," and "to determine whether a person is identifiable, the entirety of the circumstances must be considered."

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

23/128

means that can be reasonably used by the data controller or by any other person to identify said person."

- The Resolution for the Archiving of Proceedings, dated October 20, 2008, from the Spanish Agency for Data Protection. File No.: E/00357/2008 establishes that "the concept of personal data, according to the definition of the LOPD, requires the concurrence of a double element: on the one hand, the existence of information or data and, on the other, that such data can be linked to an identified or identifiable natural person," and recalls the Judgment of the National Court dated 09/17/2008, which we have already mentioned, and concludes that "applying the aforementioned jurisprudential doctrine to the present case, it results that the published phone numbers cannot be considered personal data since they were not associated with any data that identified their holders or made them identifiable."

- Finally, the Judgment of the Supreme Court, Third Chamber, Administrative Litigation, Section 3, Judgment 815/2020 of June 18, 2020, Rec. 1074/2019 establishes that "the recording of the voice associated with other data such as the phone number or its availability to other persons who can identify to whom it belongs must be considered a personal data subject to the regulations on the protection of the automated processing of the same."

Conversely, Telefónica understands that, according to what the Supreme Court itself indicated, it can be concluded that to the extent that said phone number is not associated with any other data that allows identifying the customers, it cannot be considered personal data.

In relation to the above, it is also important to note that at the European level it has been concluded

that a data can only be considered personal when the third party “has legal means that allow them to identify the interested person thanks to the additional information that the Internet access provider of that person has.” This has been established by the following judgments:

- Judgment of the Court of Justice (Second Chamber) of the European Union dated October 19, 2016 (Case C-582/14) which establishes that: “Article 2, letter a), of Directive 95/46/EC of the European Parliament and of the Council, of October 24, 1995, on the protection of individuals with regard to the processing of personal data and on the free movement of such data, must be interpreted as meaning that a dynamic Internet protocol address registered by an online media service provider when a person consults a website that this provider makes publicly accessible constitutes a personal data, in the sense of the aforementioned provision, when this provider has legal means that allow them to identify the interested person thanks to the additional information that the Internet access provider of that person has.”

- In the same vein, the Judgment of the General Court (Eighth Chamber extended) of the European Union dated April 26, 2023 (Case T-557/20) that

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

24/128

states the following: “Therefore, since the SEPD did not investigate whether Deloitte had legal and feasible means in practice to access the additional information necessary to re-identify the authors of the comments, the SEPD could not conclude that the information transmitted to Deloitte constituted information about an ‘identifiable natural person’ within the meaning of Article 3, point 1, of Regulation 2018/1725.”

Telefónica understands that, in any case, a piece of data could only be considered personal data for a third party when that party had legal means that allowed them to identify the interested person thanks to the additional information that the third party had about that person.

Telefónica concludes that, for all the above reasons, as a consequence of the Incident, it cannot be considered that any data has been affected that would allow any person other than Telefónica to reasonably identify a natural person directly or indirectly (and much less with legal means).

- Regarding connectivity equipment data

Telefónica recalls that, among the technical and configuration data of the customer's connectivity equipment that could be consulted by randomly entering fixed numbers, there were, for example:

- (...)

Telefónica claims that this data does not allow for the identification of customers, not even when associated with a fixed telephone number. For example, the MAC only identifies a device; the name of the Wi-Fi network is not uniquely associated with a fixed number but can correspond to more than one number; and the Wi-Fi passwords are stored in the router itself unencrypted, which is a common commercial practice.

Telefónica understands that to the extent that personal data is any information relating to identified or identifiable natural persons, and in this case, the identity of a natural person could not be determined solely with the data obtained by entering the telephone number, it must be noted that the data that has been affected cannot be considered personal data for the third parties who accessed it without authorization.

Telefónica concludes that it must be taken into account that:

- The fixed telephone number is not associated with any other data that would allow for the identification of customers;

- The data obtained by entering that number, and the number itself, cannot be considered personal data for the third parties who accessed them without authorization. The identity of a natural person could not be determined solely with such configuration data from some devices (router, TV decoder, Wi-Fi amplifier, etc.) such as MAC, manufacturer details of the device, connection port configuration, or

C/ Jorge Juan, 6

www.aepd.es
28001 – Madrid
sedeagpd.gob.es
25/128

Wi-Fi network names and their password. We insist that these are data that were not associated with other data that would allow for the identification of customers, and even less so in a legal manner.

Second. Regarding the alleged infringements committed by Telefónica: violation of the principle of legality.

Telefónica claims the absence of legality, based on the following arguments: which will be elaborated in more detail throughout this section:

2.1 Regarding Telefónica's conduct: in no case could it be considered subsumable under any of the provisions that this agency considers violated.

Telefónica recalls that for a conduct to be reproachable, it must be typical, unlawful, and culpable. This principle of legality is provided for in Article 27 of Law 40/2015, of October 1, on the Legal Regime of the Public Sector (hereinafter, Law 40/2015) and implies not only the subjection of the sanctioning procedure to the dictates of the laws that describe offenses and impose sanctions but also its strict subjection.

In Telefónica's opinion, this principle is being violated as the conduct carried out by Telefónica is not subsumable under any of the provisions whose infringement is attributed. To clarify the above, let us recall the articles that the AEPD considers violated: Article 5.1 f) of the GDPR and Article 32 of the GDPR:

Telefónica indicates that none of the mentioned assumptions occur in this case, as, in general, it has appropriate technical and organizational measures regarding the processing of personal data in its systems, as has been proven in the facts of this document.

Telefónica states that these technical and organizational measures are appropriate and guarantee a level of security that is adequate to the risk, taking into account the state of the art, the costs of implementation, and the nature, scope, context, and purposes of the processing, as well as variable probabilities and severity risks for the rights and freedoms of natural persons, since:

The implemented technical and organizational measures are the result of a

✓

meticulous and continuous study process that encompasses multiple disciplines and areas of knowledge (legal advice, security, fraud prevention).

This process complies with all guarantees and with the utmost respect and observance of the guiding principles related to the processing of personal data and the security measures contemplated in Articles 5.1 f) and 32 of the GDPR.

Additionally, Telefónica has security policies and operational manuals for security risk assessment that detail a methodology based on international standards. From this documentation, it can be concluded that this party has established technical and organizational measures that are appropriate and that, in fact, have been applied in this specific case. All of this,

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

26/128

since it has been proven that Telefónica analyzed the systems affected by the Incident and had a risk analysis that assessed the measures applied to ensure adequate security of its customers' personal data, including protection against unauthorized or unlawful processing.

It has also been proven that these measures are reviewed and updated when necessary to ensure the security of the processing of customers' personal data and compliance with the requirements set forth in the GDPR.

Specifically, and in relation to the risk assessment of this specific case, let us recall that:

- The system ***APP.1 stores information that is only used for customer support and maintenance purposes by Telefónica's technical teams.
- Regarding the data compromised by the incident, the attackers only had access to technical and configuration data of the connectivity equipment, associated with a fixed telephone number that the attacker already possessed (MAC address of the router, VLANs associated with services, device manufacturer and firmware, SSIDs (Wi-Fi Network name), encryption standard, passwords for wireless networks, and addressing ranges of the internal network).

For Telefónica, a fixed telephone number is a pseudonymous data, to the extent that it cannot be attributed to a data subject without using additional information, but when combined with that additional information that this party possesses, it allows for the identification of its customers.

In this sense, it is important to remember that pseudonymization and encryption are considered by Article 32 of the GDPR as part of the appropriate technical and organizational measures to ensure a level of security adequate to the risk that the data controller may apply. In this case, it is a security measure applied in the system to which the attacker had access.

Third parties unrelated to Telefónica could not determine the identity of a natural person solely with the data obtained by entering the telephone number (and even less so in a legal manner).

Considering the above, it is evident that no other data that would allow for a direct identification of the data subjects were affected, such as names and surnames, postal addresses, billing data and bank account details, call details, or any other type of sensitive information that Telefónica possesses or could be found in the aforementioned system.

- Regarding the sensitive nature of these data, in this case, there were no vulnerable groups or minors affected that needed to be taken into consideration.

C/ Jorge Juan, 6
 www.aepd.es
 28001 – Madrid
 sedeagpd.gob.es
 27/128

Furthermore, and despite the fact that Telefónica is an operator of electronic communications services, no traffic data or data subject to the confidentiality of communications were affected.

- There is no evidence that any type of additional exploitation of the mentioned data has occurred.
- Notwithstanding the above, an assessment has been made at all times regarding what would happen if the third parties who accessed the detailed information wanted to exploit the data for the commission of a crime, and it has been concluded that it was and is unlikely that there would be consequences for the interested parties, taking into account the details of what happened and the information obtained (this analysis was included in the Incident Report, which the Agency already has, and we will refer to it again when addressing the principle of proportionality).

Considering the balancing exercise mentioned in the previous paragraphs, Telefónica concludes that it has appropriate security measures that guarantee a level of security that is adequate to the risk (in particular, to prevent unauthorized access or use of customers' personal data) and that Telefónica conducted an adequate risk analysis in this case.

Telefónica states that the causes that led to the Incident cannot be attributed under any circumstances to a lack of foresight and control nor, therefore, to a breach of the obligations established in the data protection regulations. On the contrary, certain acts by third parties have occurred, which we have already referenced in the facts and will detail again when addressing Telefónica's lack of culpability. Telefónica argues that the regulation does not require infallibility of security measures, but rather that they be appropriate. Infallibility, which seems to be demanded of Telefónica, is based solely on the outcome produced in this case and thus assumes the existence of an obligation of results and objective liability (on which we will elaborate in more detail later) as sufficient justification to consider that there are two infringements, which are very serious and serious, respectively.

Telefónica points out that even the Article 29 Data Protection Working Party, in the "Guidelines on the notification of personal data breaches in accordance with Regulation 2016/679," acknowledges that, although security measures are implemented, risks may still exist, stating that: "(...) a key element of

any data security policy is to be able, as far as possible, to prevent a breach and, when one occurs despite everything, to react quickly.”

For its part, Telefónica recalls that the CIPL (Centre for Information Policy Leadership), in its comments on the guidelines for the notification of personal data breaches from the Article 29 Working Party (“Comments by the Centre for Information Policy Leadership On the Article 29 Working Party’s ‘Guidelines on personal data breach notification under Regulation 2016/679’ Adopted on 3 October 2017”) illustrates well the difference between risk mitigation and infallibility.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
28/128

indicating that it cannot be an obligation for organizations to guarantee the absolute security of data processing activities (“It cannot be an obligation for organisations to guarantee absolute security of data processing activities”).

Telefónica points out that, in the same vein, the Judgment of the Provincial Court of Valladolid (Section 1) No. 74/2010 of March 10 (AC 2010\368), regarding the alleged breach of security measures by a bank, states that:

“In any operating system, even in the traditional one, there are risks and what is decisive for attributing responsibilities will be whether sufficient guarantees were in place, without being able to reach the opposite conclusion merely because security systems have subsequently been improved, which logically should be modernized and perfected in light of new fraudulent practices that render previous ones ineffective.”

Telefónica emphasizes that it is essential to highlight that the Supreme Court establishes that the obligation of companies to adopt the necessary measures to guarantee the security of personal data cannot be considered an obligation of result (Judgment 543/2022 of the Supreme Court of February 15, 2022):

“The obligation to adopt the necessary measures to guarantee the security of personal data cannot be considered an obligation of result, which implies that if a leak of personal data to a third party occurs, there is liability regardless of the measures adopted and the activity carried out by the data controller or processor.

In obligations of result, there is a commitment to achieve a specific objective, ensuring the achievement or proposed result, in this case, guaranteeing the security of personal data and the non-existence of leaks or security breaches. In obligations of means, the commitment undertaken is to adopt the technical and organizational means, as well as to deploy diligent activity in their implementation and use, aimed at achieving the expected result with means that can reasonably be classified as suitable and sufficient for its attainment; therefore, they are referred to as “diligence obligations” or “behavioral obligations.”

The difference lies in the responsibility in each case, as while in the obligation of result one is liable for a harmful result due to the failure of the security system, regardless of its cause and the diligence used. In the obligation of means, it is sufficient to establish technically adequate measures and to implement and use them with reasonable diligence.

In these latter cases, the sufficiency of the security measures that the responsible party must establish must be related to the state of technology at each moment and the level of protection required concerning the personal data processed, but a result is not guaranteed (...)

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
29/128

We have already reasoned that the obligation imposed on the data controller and the data processor regarding the adoption of necessary measures to ensure the security of personal data is not an obligation of result but of means, without the infallibility of the adopted measures being required. It is

only necessary to adopt and implement technical and organizational measures that, in accordance with the state of technology and in relation to the nature of the processing carried out and the personal data in question, reasonably allow for the prevention of alteration, loss, unauthorized processing, or access.

In short, Telefónica concludes that what has been stated only evidences that the fact that security measures cannot be infallible in any case does not mean that they are not adequate. Thus, the legality or illegality of a security measure (i.e., its adequacy) is determined by its contribution to reducing the probability of the occurrence of the incident, not in ensuring a result. All of the above confirms the lack of typicity of the legally reproached conduct.

2.2 On the drafting of the applicable regulations: indeterminate legal concepts that contribute to increasing legal uncertainty and Telefónica's defenselessness

Telefónica emphasizes that the principle of typicity also implies the requirement that the norm clearly and precisely typifies which behaviors the legal system qualifies as infractions and what specific sanctions are provided for such offenses. The Judgment of the Supreme Court of June 26, 2001 (RJ 2001, 5740), which recalls the doctrine of the Constitutional Court in this regard, states that:

“The doctrine of the Constitutional Court and the jurisprudence of this Chamber have seen in the principle of legality a double guarantee: one of a material nature and absolute scope, referring both to the strictly penal and administrative sphere, which reflects the importance of legal certainty in these fields that limit rights and which implies the imperative need for normative predetermination of infringing behaviors and the corresponding sanctions, that is to say, the existence of legal precepts (“lex previa”) that allow predicting with sufficient certainty (“lex certa”) those infringing behaviors and knowing what to expect regarding the associated liability and the eventual sanction; another, of a formal nature, related to the requirement that there exists a norm of sufficient rank that is identified with the legal rank (see STC 61/1990, of March 29 (RTC 1990, 61) [RTC 1990, 61]).”

Therefore, Telefónica points out that another requirement linked to the principle of typicity is the importance of the regulatory norm not making vague, open, or excessively broad formulations of the offenses and sanctions, which lack sufficient determination, since “it would allow the sanctioning body to act with excessive arbitrariness and not with the prudent and reasonable approach that would allow for proper normative specification” (STC 61/1990, of March 29).

In light of the above, Telefónica argues, in relation to the articles of the GDPR that are considered violated in the present sanctioning procedure, the ambiguity and...

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
30/128

indeterminacy of the concepts included in said provisions, such as: “adequate security,” “appropriate technical and organizational measures,” or “level of security appropriate to the risk.” These concepts are not defined in the data protection regulations, and this Administration, in its application and interpretation, acts arbitrarily by imposing on Telefónica an objective liability, focusing solely on the outcome produced in a specific Incident and without considering that infallibility of the measures adopted cannot be required (as detailed in point 2.1 of this section).

Telefónica recalls that it is Article 9.3 of the Spanish Constitution that states: “The Constitution guarantees the principle of legality, the normative hierarchy, the publicity of the norms, the non-retroactivity of unfavorable or restrictive sanctioning norms of individual rights, legal certainty, responsibility, and the prohibition of arbitrariness of public powers.”

As noted in the Constitutional Court ruling STC 104/2009, of May 4 (RTC 2009, 104), “the material guarantee implies that the punitive norm allows predicting with a sufficient degree of certainty the behaviors that constitute an infringement and the type and degree of sanction that may be imposed on those who commit it, which entails that it is constitutionally unacceptable to admit formulations that are so open due to their breadth, vagueness, or indefiniteness, that their effectiveness depends on a practically free and arbitrary decision of the interpreter and judge.”

Regarding infringements and administrative sanctions, and with respect to the enforcers of sanctioning administrative law, the Constitutional Court Judgment No. 145/2013 of July 11 (Plenary) (RTC 2013\145) indicates that when these indeterminate concepts exist, they are obliged to “adhere not only to the standard of prohibition of arbitrariness, manifest error, or manifest unreasonableness derived from Article 24 of the Constitution, but to a stricter standard of reasonableness, which is decisive in cases where the boundary that demarcates the sanctioning norm is blurred due to its abstract nature or due to the vagueness and versatility of the language itself (STC 297/2005, of November 21 [RTC 2005, 297], FJ 8, and the Judgments cited therein).”

In conclusion, Telefónica asserts that the AEPD is creating a situation of legal uncertainty and hindering Telefónica's defense, potentially violating certain principles that are constitutionally guaranteed (Articles 24, 25, and 9.3 of the Spanish Constitution).

2.3 Subsidiarily: on the interpretation and application of the regulations carried out by the AEPD. Error in the classification and qualification of the infringement and consequent determination of the sanction
Firstly, Telefónica considers that the assessment of the two infringements (of Article 5.1 f) and 32 of the GDPR) also evidences an error in the classification and qualification of the facts made by the AEPD and in the consequent determination of the sanction, as it is evident that both provisions regulate the security of personal data, with the first provision doing so in a more generic manner than the second, as can be appreciated below:

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
31/128

Article 5.1 f) GDPR: “1. Personal data shall be: (...) f) processed in such a way as to ensure an appropriate level of security of personal data (...). Article 32 of the GDPR: “(...) the controller and the processor shall implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk (...)”

Telefónica understands that Article 5 of the GDPR outlines the principles that generally govern the processing of personal data. In light of this generality, its subsection f) refers to the need for “an adequate level of security.” In this regard, it could not be considered applicable to this case the Article 5.1 f) of the GDPR, whose wording is so generic that the Administration could argue that any breach of the Regulation can be subsumed as an infringement thereof. Beyond the above, let us remember that in no case can infallibility of security measures be demanded, nor that they serve to achieve a specific result. That is to say, the mere occurrence of a security incident cannot lead the AEPD to the conclusion that the aforementioned principle of the GDPR is violated.

For its part, Telefónica points out that Article 32 of the GDPR (“security of processing”) contains a more specific reference to the “appropriate technical and organizational measures to ensure a level of security appropriate to the risk” that the AEPD considers violated. Therefore, it is Article 32 of the GDPR that truly refers to the “appropriate technical and organizational measures to ensure a level of security appropriate to the risk.” Furthermore, this provision is included in Section 2 of Chapter IV of the GDPR, which with a greater degree of specificity contains the provisions relating to the “Security of personal data.”

Additionally, Telefónica notes that, for its part, the LOPDGDD in its Article 73 f), unlike Article 72.1 a), provides as a serious infringement “f) The failure to adopt those technical and organizational measures that are appropriate to ensure a level of security appropriate to the risk of processing, in the terms required by Article 32.1 of Regulation (EU) 2016/679.”

Telefónica therefore concludes that, in the event that the existence of an infringement is considered, in no case could Telefónica's conduct be classified as very serious. The contrary would imply an evident error in the qualification of the facts that have occurred in this case. This error in the qualification of the facts also triggers the consequent error in the grading of the proposed sanctions, as they are constantly reiterated and duplicated.

Telefónica argues that this shows a clear reiteration in the intention to aggravate the two alleged infringements with the same grounds. To the extent that it could in no case be considered that

Telefónica's conduct is very serious, for infringement of Article 5.1 f), the aggravating factors applied to that provision could not be taken into account either.

In conclusion, Telefónica argues that no charges can be brought against it, as its conduct cannot be subsumed under any of the provisions that the AEPD considers violated. Beyond the above, it is even more evident that in no case...

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
32/128

Such conduct could be classified as very serious, since if the Agency understands that the technical and security measures are not adequate, it should adhere to what is indicated in this section.

Third. Telefónica's conduct is not unlawful

Telefónica rejects the unlawfulness of its conduct based on the arguments summarized below, which have been reflected in the facts of this document:

- Telefónica has technical and organizational measures designed to ensure adequate security of its customers' personal data, including protection against unauthorized or unlawful processing. For example, it has:

- (...)

- Telefónica has multiple mechanisms to detect unauthorized access to personal data, which are constantly adapted. For example:

- (...)

In any case, Telefónica reminds that the regulation does not require the infallibility of such measures, but rather that they contribute to reducing risk.

Fourth. Absence of culpability

Telefónica understands that the requirement of culpability is also not present in its actions, that is, there is no subjective element of fault required for the imposition of administrative sanctions.

Telefónica points out that its attitude reveals an unequivocal will to act in accordance with the law, with no intention whatsoever to infringe the regulation and with a will to comply in any case. It is a reiterated doctrine that considers that the principles inspiring criminal law are applicable to administrative sanctioning law, indicating that one of the main components of the administrative infringement is the element of culpability, which presupposes that the action or omission must be attributable to its author due to malice, recklessness, negligence, or inexcusable ignorance. That is to say, it is necessary to ascertain the culpable intervention by Telefónica, which has not occurred. As long as there is no culpable conduct, no sanction can be imposed. This is referred to in Article 28 of Law 40/2015, which states that "Only individuals and legal entities, as well as, when a law recognizes their capacity to act, groups of affected parties, unions and entities without legal personality, and independent or autonomous estates, that are responsible for the same due to intent or fault, may be sanctioned for acts constituting an administrative infringement."

Telefónica points out that this Law has replaced "simple non-compliance" with "fault," which implies the recognition that simple non-compliance could not effectively be understood as the admission of objective responsibility in administrative sanctioning law. The majority jurisprudence of our Supreme Court (starting from its rulings of January 24 and 25 and May 9, 1983) and the doctrine of the Constitutional Court (after its STC 76/1990) highlighted that the principle of culpability, even without explicit recognition in the Constitution, is inferred from the principles of legality and prohibition of excess (Article 25.1 CE) or from the inherent requirements of a Rule of Law, and requires the existence of intent or fault.

In this sense, for example, the ruling of the Supreme Court of December 16, 2015, states that:

"Specifically, regarding culpability, this Court has declared that, indeed, the Spanish Constitution undoubtedly enshrines the principle of culpability as a basic structural principle of Criminal Law and has added that, however, the constitutional enshrinement of this principle does not imply in any way that the Constitution has converted a certain way of understanding it into a norm (STC 150/1991). This principle of culpability also governs in matters of administrative infringements, since to the extent that

the sanction of such infringement is one of the manifestations of the State's *ius puniendi*, a regime of objective responsibility or without fault is inadmissible in our legal system (STC 76/1990)."

Telefónica points out that the lack of culpability in the examined case is manifested in that:

- Telefónica's conduct was carried out with all the required professional diligence, that it acted in good faith, and that, for that reason, it cannot be attributed a culpable action. That is to say, Telefónica's attitude, as has been demonstrated in this document, reveals an unequivocal will to act in accordance with the law without any intention to infringe the regulation and with a will to comply in any case (developed further in point 4.1).
- The actions that have caused the consequences outlined in the Initiation Agreement are in no case attributable to Telefónica (developed further in point 4.2).

4.1 The diligent and good faith actions of Telefónica

Telefónica understands that everything presented in this document fully demonstrates the rigor and diligence with which it has acted, let us remember that:

- Telefónica has acted with all the diligence required when implementing technical and organizational measures (according to the state of the art, the costs of application, and the nature, scope, context, and purposes of the processing, the probability and severity of risks) that are appropriate to ensure adequate security.

Furthermore, Telefónica constantly works on improving the measures it has in place with the aim of preventing any type of fraud, in training, and in adapting security protocols within the organization. Let us remember that the details of the measures with which...

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

34/128

The Telefónica account has been detailed in the second allegation of the facts of this document.

In relation to these measures, as has already been conveyed, it must be clear that the regulation does not require infallibility but rather that they be appropriate (as already indicated in the first allegation of these Grounds). However, we insist that the Agency only focuses on the result produced, without taking into account the circumstances completely unrelated to Telefónica that have occurred, consequently demanding objective liability.

- Telefónica has acted at all times in good faith and proactively.
- Telefónica also acted with total diligence in managing the Incident, which it proceeded to communicate to the interested parties, clearly indicating the measures they should take to change their password and resolving all doubts that arose subsequently. From the communication, and in just 10 days, approximately 1,700 emails were sent from the DPO mailbox of Telefónica. Additionally, customer service operations were adapted so that the interested parties could be provided with the information they needed regarding the Incident.

From all the above, Telefónica emphasizes its good faith and professional diligence, as it not only had no intention or desire to breach its obligations at any time, but acted in full belief of its compliance and was fully convinced of the effectiveness of the security measures established to reduce the risk involved, helping the interested parties to mitigate any minimal risk that might exist. All of this is supported by the consideration of the threat of (...). Our High Court has also addressed good faith on numerous occasions, as it did in the Supreme Court Judgment of December 17, 1988, which stated: "it is not fair to sanction one who acts in good faith, proceeding to annul the sanction when the conduct of the accused was due to a certain belief excluding culpability."

4.2 Exceptional circumstances and those unrelated to Telefónica. Intentional actions of third parties to commit a crime

Telefónica concludes that the causes that have led to the situation described in the Initiation Agreement cannot be attributed under any circumstances to a lack of foresight and control on the part of Telefónica nor, therefore, to a breach of the obligations established in the regulations on data protection. On the contrary, these causes stem from certain actions of third parties unrelated to the sphere of action and responsibility of Telefónica.

Telefónica notes that all of the above evidences the absence of culpability and that the AEPD seems to be focusing solely on the result, considering that there is an infringement due to the fact of “suffering a cyber attack (...)”. Practices for which Telefónica is not responsible in any case. As the Agency itself indicates, it is a “cyber attack.”

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
35/128

Telefónica recalls the provisions of Article 27 of the Penal Code (hereinafter, CP), whereby those responsible for the commission of a crime are the “authors and accomplices,” with authors being defined as “those who carry out the act by themselves, jointly, or through another whom they use as an instrument” (Article 28 CP). It is clear that these authors are third parties, who have nothing to do with Telefónica.

Telefónica understands that it can only be concluded that we are dealing with actions of third parties with the intent to cause harm through the commission of criminal conduct. Telefónica has acted at all times in good faith and with due diligence since the decision to overcome the harm that third parties may cause, circumstances that it was never in a position to avoid. The above implies that we are faced with a case of force majeure, as the described circumstances fit within this concept, which determines the lack of responsibility or culpability in the infringing conduct.

Telefónica emphasizes that in our law, there is no detailed definition of the cases encompassed within this concept, and any approach to an enumeration has ultimately been interpreted as a non numerus clausus citation, expanded through analogy or jurisprudential interpretation. Therefore, the most appropriate definition is the one established in our Civil Code, as it defines it by its characteristics, as those “events that could not have been foreseen, or that, if foreseen, were unavoidable” (Art. 1105 CC), traits that have already been seen to occur in our case.

Telefónica believes that it is difficult for the commission of a crime such as a cyberattack to be prevented by Telefónica, especially considering that attackers constantly improve their techniques and the characteristics of these attackers, as has been indicated. Regarding force majeure, as an exemption from liability, due to the prior inevitability or unpredictability of the event, it is important to highlight:

- Judgment of the Provincial Court of Málaga (Section 5) No. 154/2010 of March 22: “Jurisprudential doctrine understands force majeure and fortuitous events as contemplated in Article 1105 of the Civil Code, as exemptions from liability for events that, respectively, could not have been foreseen, or that, if foreseen, were unavoidable.”
- Judgment of the Provincial Court of Barcelona (Section 15) of October 10, 2002 (JUR 2004\14118): “The exemption from liability configured by Article 1105 of the CC (...) in terms of determining the absence of fault, must be assessed by weighing the inevitability of the event in consideration of the required diligence (...)”.
- Judgment of the Provincial Court of Barcelona (Section 15) of December 31, 2002 (JUR 2004\14170): “The exemption from liability configured by the cited norm (whose general expression in our legal system is contained in Article 1105 of the Civil Code [LEG 1889, 27] (...) is configured as the negation of fault, an absence that must be assessed by weighing the prior inevitability or unpredictability of the event in consideration of the required diligence (...), which is not the average or common standard of the ‘good father of the family,’ but that of the good professional, being this the model of conduct to be observed in the execution of their duties.”

Telefónica has always acted with

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
36/128

full and well-founded belief excluding all liability and in compliance with applicable legislation.

More specifically, regarding the consideration of a cyberattack as a case of force majeure, it is essential to take into account Judgment 37/2022 of March 14, 2022 (Rec. 13/2022 of the National Court, Social Chamber). This Judgment begins by recalling the civil judicial doctrine, STS (Civil Chamber) of November 22, 2018, which states that it is “a force superior to all control and foresight that must be weighed in terms of its concurrence with the normal and reasonable foresight that the circumstances require to be adopted in each specific case.” It continues by stating:

“On this note, it has been understood that an evaluation must be carried out studying the uniqueness in each specific case since it is a legal concept that must be deduced from the set of circumstances that motivate the fact or event that, overriding the will of the obligated party, determines them to breach the obligation that corresponds to them, since the possibility of foreseeing events is a broad concept, it must be understood in its legal and practical application, as excluding those events that are completely unusual or extraordinary which, although not physically impossible, are not among those that can be calculated by prudent conduct.

Regarding the concurrence of force majeure as a consequence of the ransomware virus attack on XXXXXXXX, S.A.U. The analysis of the configurational elements of force majeure from the previous sections allows us to conclude that the cyberattack through a ransomware virus that translates into the “kidnapping” of the company's key information, significantly affecting its operability, can be classified as a case of force majeure.

Indeed, all the configurational elements that allow us to conclude the existence of a case of force majeure are present: impossibility, the existence of a causal relationship between the breach of the contractual obligation and the obstructive fact, non-attributability, and (at least) inevitability. Elements applied to the specific situation described in the request for recognition of force majeure submitted by the company. (...) it cannot be stated, as noted in the contested resolution, that the attack cannot constitute a case of force majeure because it was foreseeable, and this is because:

- Force majeure is not limited to cases of an unpredictable nature, but also includes those that, while foreseeable, are unavoidable.
- When it comes to foreseeable cases, the inevitability must be analyzed weighing, on one hand, the measures implemented by the company to prevent the attack and, on the other, the complexity of the external circumstance that causes the objective impossibility. Analyzed the security measures, by an external consultant in a forensic report, it is confirmed that they were those of a diligent trader, without any negligent behavior being attributable, and, moreover, there are no known alternative measures that could have prevented the virus attack, which reveals its inevitable nature, thus, it must be subsumed under the case of force majeure.”

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

37/128

Considering the above, it concludes that:

“the cyber attack through ransomware on a business activity that revolves around an essentially digital 'architecture' such as that carried out by the plaintiff can be subsumed under the concept of force majeure for the following reasons:

- First, the human origin of the obstructive act does not prevent an obstructive fact from being subsumed under the concept of force majeure;
- Second, there is an absolute and objective impossibility regarding one of the essential business obligations of the employment contract (to provide effective employment);
- Third, there is a causal relationship between the breach of the obligation and the obstructive fact;
- Fourth, given the level of preventive diligence adopted by the plaintiff, it can be asserted that the notes of non-attributability and (at a minimum) inevitability are present. In this case, despite being a known risk (and therefore foreseeable), there are sufficient elements to understand that the level of business diligence to prevent this risk has been sufficiently high to rule out that its business conduct can be classified as negligent (and therefore attributable). Especially because the measures that make up the company's "Information Security Policy" constitute adequate precautionary measures within the

degree of effort and cost of a "careful and diligent merchant."

Telefónica concludes that all of the above demonstrates that the essential element of culpability in Telefónica's conduct has not been present in this case, a requirement of sanctioning law, since:

- It is evident and has been proven throughout this document that the actions of this party have been diligent in the implementation and adaptation of its security measures.
- In any case, and in the face of a directed attack, such an attack occurs due to numerous factors that are beyond the will and capacity of Telefónica to act, to the extent that it is evident that it has been third parties who have the intent to commit a crime, an action that is inevitable for Telefónica.

Therefore, Telefónica reiterates that in this case there is no causal link by action or omission between Telefónica and the final result, due to the intervention of third parties with sufficient entity to alter that link. There being no unlawful, typical, or culpable conduct by Telefónica in the alleged facts, we insist that the sanctioning procedure should not have been initiated, nor should any sanction be imposed on Telefónica.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

38/128

Fifth. Breach of the principle of proportionality

Telefónica alleges that, in the hypothetical case that the AEPD, lacking adequate legal support and with the sole aim of imposing a fine, considers sanctioning Telefónica economically, the amount of such a sanction must be estimated in any case in accordance with the principle of proportionality that governs the sanctioning power.

The necessity of proportionality is referred to in the Judgment of the Supreme Court of June 2, 2003, according to which the principle of proportionality "tends to adjust the sanction, by establishing its specific gradation within the possible margins, to the severity of the act constituting the infringement, both in its aspect of unlawfulness and culpability, weighing together the objective and subjective circumstances that integrate the factual basis subject to sanction and, in particular, as stated in Article 131.3 of Law 30/92, the intentionality or repetition, the nature of the damages caused, and the recidivism."

Telefónica notes that the development of this fundamental principle is not limited exclusively to the jurisprudential sphere. National and European legislative bodies have also taken this legal principle into account when shaping data protection regulations, in which we can find multiple references to the principle of proportionality.

Specifically, due to the importance of this legal principle, Telefónica points out that the General Data Protection Regulation itself introduces it in its Recitals 4, 129, and 148. To the general considerations contained in these Recitals, which broadly illustrate the interpretative sense with which the Regulation should be analyzed, are added the specific provisions that affect the imposition of administrative fines. Thus, the General Data Protection Regulation addresses the general conditions for the imposition of administrative fines in its Article 83. Specifically, the first of the sections of this provision establishes that "Each supervisory authority shall ensure that the imposition of administrative fines under this Article for the infringements of this Regulation referred to in paragraphs 4, 5, and 6 is, in each individual case, effective, proportionate, and dissuasive."

For its part, paragraph 2 establishes that "administrative fines shall be imposed, depending on the circumstances of each individual case, as an additional or substitute measure to those provided for in Article 58, paragraph 2, letters a) to h) and j)."

Telefónica argues that from the interpretation of the provisions presented by the AEPD in its Initiation Agreement, a clear breach of the principle of proportionality that should govern the sanctioning power is evident. This breach materializes in the intention to impose on Telefónica a financial sanction that is entirely ineffective and disproportionate.

Specifically, Telefónica considers that the provisions of Articles 83.1 and 83.2 of the GDPR have not been duly taken into account when determining the amount of the proposed administrative fine. In particular, the AEPD has reiterated

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
39/128

constantly the same arguments to justify the alleged application of different aggravating factors and has not taken into account the concurrence of the criteria for graduation that, under the premises of the aforementioned Article 83, would allow for a reduction in the amount of the sanction in the event that a violation of the regulations were to be appreciated.

5.1 Of the aggravating factors assessed by this agency in the initiation agreement

- Nature, severity, and duration (in relation to the alleged violation of Article 5.1 f)

- Firstly, regarding the consideration that "the nature of the infringement is serious since it entails a loss of confidentiality and, therefore, of irremediable disposition and control over personal data,"

Telefónica understands that the AEPD is once again demanding an obligation of results concerning the fact of preventing the existence of a security breach.

Telefónica points out that, following this reasoning, the mere fact that a criminal managed to attack a system and cause a security incident would imply that we are facing a serious infringement, consequently requiring objective liability from any data controller as sufficient justification. As we have been conveying throughout this document, it is evident that in this case, the result of the crime committed by a third party falls outside the sphere of Telefónica's responsibility. In any case, in this instance, the incident did not result in any irremediable loss of control over the personal data of customers (considering the category of affected data and the possible risks to the data subjects, which we have already referred to in the facts and will refer to again below).

- Secondly, regarding the number of affected individuals, Telefónica indicates that the AEPD merely states that "the number of affected individuals is very large, as it amounts to more than one million Telefónica customers: 1,407,257" consistently, without taking into account that regardless of the number of phones that returned data to the attacker, the obtained data does not allow a third party to identify that individual, as these are data that are only used for the support and maintenance of Telefónica's router.

Telefónica reiterates that the category of affected data has not been taken into account, as there was only unauthorized access to the configuration data of some connectivity devices that Telefónica makes available to its customers (router, TV decoder, Wi-Fi amplifier, etc.) by randomly entering fixed phone numbers (not even that number was obtained directly from Telefónica, but rather the attackers already had that data).

Telefónica insists that no data was affected that would allow a third party outside Telefónica to identify an individual. Furthermore, other data such as name and surname, postal address, billing data and bank account, call details, or other types of sensitive information held by Telefónica or that could be found in the mentioned devices were not affected.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
40/128

- Regarding the level of damages suffered, Telefónica points out that the AEPD merely states that it is "High," taking into account the data that was taken. That is to say, the AEPD draws a series of conclusions about the consequences for the affected parties, which it does not prove at any time. Beyond that, it again uses the argument that it involves a very considerable number of customers. However, Telefónica has no evidence that any type of additional exploitation of the mentioned data has occurred. Therefore, the possible consequences that the AEPD mentions in its Initiation Agreement have not materialized.

Telefónica also notes that the category of data affected by the incident does not fall under the category of sensitive data as defined in Article 9 of the GDPR, nor does it involve data whose loss of control could imply serious consequences for the affected parties. In other words, it only involved configuration

data of some connectivity devices that Telefónica makes available to its customers by randomly introducing fixed telephone numbers.

Notwithstanding the above, and to assess the severity of the consequences, to understand what would happen if the third parties who accessed the detailed information wanted to exploit the data for the commission of a crime, Telefónica recalls the analysis it conducted when the Incident occurred. In that case, it should be taken into account that:

- The Wifi network, in its default configuration, is end-to-end encrypted. That is to say, between any device that connects to the router and that router;
- Access to each Wifi network could only be achieved if the intruder is physically within the coverage area of the router's installation location. It should be noted that being in a coverage area outside the home can be quite complex depending on the characteristics of the home or building, and additional means may even be required to obtain it, such as special antennas;
- For the intruder to be physically in the coverage area of the router's installation location, it would be necessary for the third party to have the postal address corresponding to the Wifi keys (a piece of information that has not been extracted from Telefónica's systems).

Beyond the above, it is important to remember that the name of the Wifi network (SSID, Service Set Identifier) and Wifi key are not unique. The SSID of Telefónica's routers may be repeated in the equipment of hundreds of different customers, which makes it difficult to geolocate the exact address of where the Wifi network is physically located, which, as we have indicated, was not data extracted from Telefónica's systems.

Furthermore, let us remember that Telefónica communicated the existence of the Incident to the affected parties and recommended changing their password to increase the security of their network and prevent possible unauthorized access, providing a manual that showed the steps to do so easily. To the extent that they made this change, the attacker would no longer have this information. In any case, it should be noted that a Wifi key does not...

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
41/128

is a static data point, it is data that the client can change at any moment.

- As an additional step, it would be necessary for another intentional action by third parties to take place for the commission of a crime. That is to say, for the attacker to connect to a client's Wifi network, they would need to have the necessary skills to perform an intrusion into their internal network, executing an additional attack.

The likelihood that this attack would allow criminals to achieve a result would also depend on the security of the devices connected to the client's network (whether the devices are updated, whether users use strong passwords, etc.). This matter would go beyond Telefónica's responsibility.

- In the hypothetical case that the attacker managed to connect through an unauthorized device to a specific network, clients would have the possibility of realizing such access. Telefónica offers certain free services that notify network access when a new device connects and protect browsing (these are services that can be easily activated from the Movistar application, from the Movistar television, or even at the time of installing the TDE router).

Furthermore, it should be noted that among the data obtained by the attacker was not the router's administrative password. Without this information, a direct attack against the router could not be carried out, making changes to its configuration.

Telefónica states that if the attackers had wished to attack the Wifi network of a specific person, there are other mechanisms that could be more effective and less costly for such criminals. For example, a targeted attack through malware sent via email, which would have allowed compromising a device and facilitated the intrusion, allowing remote access from the Internet without having to be close to the victim.

Telefónica concludes that knowing the password of a client's Wifi network can facilitate the task of overcoming a first security barrier (which is access to the client's internal network), but does not allow

access to their personal data. (...)

For all the above, Telefónica indicates that to the extent that the data was not associated with other data that would allow the identification of clients and considering the risk assessment presented, it is unlikely that there could be consequences for the interested parties. Evidence of this is that more than a year after the incident, Telefónica has not been aware of any type of publication or exploitation of this data by third parties unrelated to Telefónica, as had already been indicated.

Telefónica concludes that it is evident that the result of the fraud that the AEPD seems to intend to attribute to Telefónica falls outside the sphere of responsibility of Telefónica. Therefore, the appreciation of the aggravating factor contemplated in Article 83.2.a) cannot be based on the perpetration of this type of crime. This would violate the principle of personality of administrative sanctions, closely related to the concepts of intent and fault, since the principle of personality of sanctions is a manifestation of the subjective element of fault (understood in a broad sense), which is necessary for an infringement and the subsequent sanction to exist.

• Aggravating factors that have been considered for both infringements:

Telefónica indicates that the AEPD states that the following aggravating factors can be appreciated in relation to the alleged infringements of Articles 5.1 f) and 32 of the GDPR:

1. Negligence in the infringement

Telefónica recalls that the AEPD considers that the aggravating factor provided for in Article 83.2.b) GDPR (negligence in the infringement) can be appreciated both for the alleged infringement of Article 5.1 f) and for that of Article 32 of the GDPR, providing the same arguments in both cases. Such consideration seems to be based on a supposed ineffectiveness of the security policies designed by Telefónica.

Telefónica understands that it is evident that the AEPD erroneously concludes that, due to the occurrence of a security incident (caused by cyber attackers who also attacked the systems of other companies and institutions such as the General Council of the Judiciary or the Tax Agency), there were no adequate measures in place.

In this way, it is once again demanding an obligation of results (infallibility of the measures) and consequently an objective responsibility, considering the existence of negligence due to the result caused by third parties unrelated to Telefónica.

Telefónica again recalls that:

- It had conducted a risk analysis of the affected system prior to the incident, in accordance with a methodology based on an international standard.
- It periodically conducts awareness campaigns for employees by sending emails simulating a phishing attack.
- It conducts training talks for the detection and reporting of phishing to certain groups of employees.
- In all applications accessible from the public domain ***PORTAL.1.telefonica.es, there is a control against brute force attacks that blocks a user when more than 5 authentication attempts are made within 30 minutes.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

43/128

- There is a password expiration policy of 90 days. After this period, the user must change the password; otherwise, the user will be blocked.

- There was a plan prior to the Incident of deploying a WAF System in the Application ***URL.1. This demonstrates that Telefónica is a company fully aware of the need to evolve security measures and has numerous initiatives for updating these measures. Furthermore, considering the characteristics of the Incident, the plan was executed on October 6, 2022.

Telefónica once again recalls Judgment 543/2022 of the Supreme Court dated February 15, 2022, regarding the obligation to adopt necessary measures to ensure the security of personal data, which cannot be considered an obligation of result, but rather an obligation of means, and that infallibility of the adopted measures cannot be demanded.

Therefore, Telefónica concludes that, based on the information conveyed in this document and in the documentation already held by the AEPD, it could in no case be considered that Telefónica has not acted with the required diligence; rather, the opposite is true.

2. Linkage of the infringer's activity with the processing of personal data

Telefónica indicates that the AEPD considers it appropriate to gradate the sanctions to be imposed according to the following criteria established in section 2 of Article 76 "Sanctions and corrective measures" of the LOPDGDD, and that the argument used to defend the application of this aggravating circumstance is exactly the same in the gradation of the two infringements attributed, with the AEPD insisting on the volume of data processed by this company.

Telefónica recalls that this sanctioning file arises from a specific security incident. That is to say, this file focuses on what has happened in a single case. In light of this, it is striking that, when imposing the sanction, the AEPD refers to the fact that data concerning millions of people is involved, without taking into account that the facts presented would have only affected a specific volume of customers in relation to a particular incident caused by third parties unrelated to Telefónica, and it has been demonstrated that in no case did it pose a risk to those concerned. In this regard, this party can only express its absolute disagreement with the assessment of this aggravating circumstance.

Telefónica understands that it makes no sense and cannot be legally sustained that merely by processing a large volume of data, any infringement committed leads to the direct and objective application of aggravating circumstances, and that to apply aggravating circumstances, a qualification of culpability must occur that cannot be an immediate consequence of size, but rather requires an assessment of the specific circumstances of the responsible party to determine whether it is appropriate or not, and in this case, it must be taken into account that it is only being...

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

44/128

valuing what happened in relation to a single security incident that did not pose a risk to the rights and freedoms of the data subjects. Understanding it otherwise would go against the presumption of innocence proclaimed by the Constitution and would imply considering a conduct as infringing without assessing the concurrent circumstances.

5.2 Regarding the mitigating factors that should have been considered by the AEPD in the initiation agreement

Telefónica points out that the AEPD has only taken into account the alleged existence of aggravating factors but has not considered the evident existence of the following mitigating factors, from Article 83.2 of the GDPR and Article 76.2 of the LOPDGDD:

1. "b) the intentionality or negligence in the infringement" (from Article 83.2 of the GDPR)

Telefónica notes that the requirements of intentionality in the alleged commission of the infringements or a negligent attitude are not present in this case. On the contrary, the diligence in the actions of this party throughout this document has been more than demonstrated, specifically regarding the aggravating factor indicated by the Agency concerning negligence in the previous section.

Telefónica recalls that the Incident has resulted from a targeted attack against Telefónica, revealing this party's unequivocal willingness to act in accordance with the law, with no intention whatsoever to infringe the regulation and with a clear intent to comply.

2. "c) any measures taken by the data controller or processor to mitigate the damages suffered by the data subjects" (from Article 83.2 of the GDPR)

Telefónica indicates that it proceeded to inform all data subjects of what happened, advising them on the measures they should take to change their password and resolving all doubts that arose subsequently. Specifically, from the DPO mailbox of Telefónica, approximately 1,700 emails were sent in the first 10 days, and specific procedures were implemented so that responses could be provided to the data subjects through the different channels of Telefónica.

3. “g) the categories of personal data affected by the infringement” (from Article 83.2 of the GDPR) Telefónica recalls that the category of data affected by the incident does not fall under the category of sensitive data as defined in Article 9 of the GDPR, nor is it data whose loss of control could imply serious consequences for the data subjects.

That is to say, it only involved configuration data of some connectivity equipment that Telefónica makes available to its customers and which do not allow for the direct identification of the data subject (let us remember that these are the unique identifier of the device (the MAC), details of the equipment manufacturer, configuration of the connection ports, the name of the wifi network, and its password). In other words, no other data or sensitive information that Telefónica holds or that could be found in the mentioned equipment was affected, such as names and...

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

45/128

surnames, postal address, billing data, bank account or call details.

Telefónica also notes that it should be taken into account that the names of the WiFis in most cases are repeated and that the VLAN addressing ranges are internal and almost all clients have the same ones. That is to say, this is information that has a limited useful life as it consists of data that may change over time.

4. “h) the manner in which the supervisory authority became aware of the infringement, in particular whether the controller or the processor notified the infringement and, if so, to what extent” (from Article 83.2 of the GDPR)

Telefónica mentions this mitigating factor to the extent that it has been established that it was Telefónica that informed the AEPD of the existence of this Incident, within the legally established timeframe and in accordance with the provisions of the applicable regulations, as reflected in the previous allegation of this document.

5. “j) adherence to codes of conduct under Article 40 or to certification mechanisms approved under Article 42” (from Article 83.2 of the GDPR) and “h) the voluntary submission by the controller or processor to alternative dispute resolution mechanisms, in cases where there are disputes between them and any interested party” (from Article 76.2 h of the LOPDGDD)

Telefónica emphasizes that it subscribed to the “Self-Regulation Code on Data Processing in Advertising Activity.” Through this Code of Conduct, a primarily extrajudicial procedure for resolving disputes between the entities adhering to the Code and the interested parties regarding data processing carried out in the context of advertising activity has been established.

6. “k) any other aggravating or mitigating factor applicable to the circumstances of the case, such as the financial benefits obtained or the losses avoided, directly or indirectly, through the infringement” (from Article 83.2 of the GDPR) and “c) the benefits obtained as a result of the commission of the infringement” (from Article 76.2 c of the LOPDGDD)

Telefónica points out that it has not obtained any financial benefit; moreover, TDE has been yet another victim of a crime that has caused it reputational damage.

Telefónica concludes that, should the Agency decide to maintain the sanctions despite the arguments put forth by this party, these mitigating factors should be taken into account for the reduction of their amount.

For all the above reasons, Telefónica requests that:

i. The absence of responsibility on the part of Telefónica for the alleged infringements attributed to it in this procedure be declared, as there is no unlawful, typical, or culpable conduct by Telefónica in the facts attributed, ordering the filing of the present sanctioning file.

ii. Alternatively, if it is understood that the technical and security measures are not adequate, attention should be paid to what is indicated in section 2.3 of the second allegation of the legal grounds. Thus, if the existence of an infringement is considered, in no case could Telefónica's conduct be classified as very serious.

iii. Alternatively, in the event that the first request is not upheld, the initially proposed sanction should

be reduced in accordance with the criteria of Article 83 of the GDPR and Article 76.2 of the LOPDGDD.

iv. That, in the second allegation of the facts of this document, marked as [CONFIDENTIAL], and in the document attached as Annex 1, information of a particularly sensitive nature is provided that should be protected and declared confidential by the AEPD, in order to prevent future unlawful acts by those responsible for the types of criminal acts described in this document and because it contains information and operations that this party considers critical and confidential. Consequently, its publication could harm Telefónica's interests.

NINTH:

On June 10, 2024, the instructor of the procedure agrees to open a period for the practice of evidence, in which the following is agreed:

"1. The notifications of the personal data breach made by TELEFONICA DE ESPAÑA SAU (Telefónica) and its documentation, the documents obtained and generated during the preliminary investigation phase, and the report of prior investigative actions, which are part of procedure AI/00356/2022, are deemed reproduced for evidentiary purposes.

2. Likewise, the allegations to the initiation agreement of the referenced sanctioning procedure presented by Telefónica, and the documentation accompanying them, are deemed reproduced for evidentiary purposes.

3. Telefónica is requested to provide the following documentation and/or information:

- On November 2, 2022, the acting Inspector during the preliminary investigative actions requested the risk analysis of the treatments affected by the security breach.

Given that the document provided is not a risk analysis of the probability and severity that the processing of personal data may pose to the rights and freedoms of individuals, in accordance with Article 32 of the GDPR, but rather constitutes a risk analysis from the perspective solely of information security, it is requested that the risk analyses or, where appropriate, the Data Protection Impact Assessment regarding the affected processing activities be provided.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

47/128

the personal data breach in accordance with the GDPR and occurring prior to the date of said breach.

- Additionally, if available, reports from audits, testing, etc., that have been conducted in relation to the IT applications affected by the incident (...).

- Whether a two-factor authentication system was in place for access to the affected applications at the time of the incident. If so, evidence of this.

- In the second notification of the personal data breach, submitted on October 26, 2022, it is indicated that, once the complete analysis of the incident was concluded and after confirming that another user was compromised, it was detected that the start date of the attack occurred on September 9, 2022, so the malicious accesses were carried out in three blocks: from September 9 to 11, from September 16 to 20, and on September 28, 2022. Since this Agency has no record of this, information is requested regarding the malicious accesses that occurred between September 9 and 11 (affected user and their role, accesses that occurred, personal data affected, why it was not detected at that time, etc.).

- Country of origin of the IP addresses from which the attack was carried out.

- Evidence of the existence, if applicable, of Action Protocols in case of a breach of personal data security (personal data breach) at the time the incident occurred.

On June 28, 2024, a response was received from Telefónica regarding the proposed evidence, in which they attach documentation and indicate, in summary, the following:

1. Regarding the request to provide risk analyses or, if applicable, the Data Protection Impact Assessment, concerning the processing activities affected by the personal data breach in accordance with the GDPR and conducted prior to the date of said breach, Telefónica indicates the following:

"The data processing that takes place when accessing ***APP.1 does not have an independent data protection impact assessment, as it does not pose a high risk to the rights and freedoms of individuals. Before going into further detail, we must clarify the registration of processing activities of Telefónica,

which, in order to comply with the various obligations arising from the regulations, is organized as follows:

- It includes all the details of the data processing activities carried out for each of the processing purposes, with the detail required by the regulations.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

48/128

- For each of these purposes, it may be necessary to access different systems.
- The systems that are part of a processing activity may have their own risk analysis conducted by the security area.
- Additionally, a privacy risk analysis (Pre-DPIA) is also conducted for each processing activity. If that analysis concludes that a data protection impact assessment (PIA) is necessary, such PIA is carried out.

Once the above is clarified, and without prejudice to the fact that ***APP.1 does not have an independent data protection impact assessment, we must remember that the activity of consulting information for customer fault handling is encompassed in the following processing operations: These processing operations cover a much broader data processing that has not been entirely affected by the attack that caused the Incident subject to this File. That is to say, it is essential to be clear that:

- ***APP.1 is merely one of the systems that can be accessed to provide technical support to customers and,
- (...). In any case, and considering the request from the AEPD, copies of the data protection impact assessments of the mentioned processing operations (hereinafter, Impact Assessments or DPIA) are provided as Annex Documents 1 and 2.

(...) it is important to clarify a series of issues regarding the scope of the Incident and the analyses provided at this point:

a) Regarding ***APP.1 and the categories of data included in that system ***APP.1 allows the team of individuals handling technical incidents for customers to consult the necessary information for diagnosing and addressing faults in connectivity equipment (Router, TV decoder, Wi-Fi amplifier, etc.).

(...)

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

49/128

(...)

Furthermore, it is important to emphasize that Telefónica has continuously assessed what would happen if third-party attackers wanted to exploit the data they accessed to commit a crime and, as has been outlined throughout this File, it was concluded that it was and is unlikely that there would be consequences for the interested parties, considering that:

- (...).

Taking all of the above into account, and to the extent that it was unlikely that the processing would entail a high risk to the rights and freedoms of individuals, at the time of analyzing this activity it was concluded that it was not necessary for access to ***APP.1 to have an independent data protection impact assessment. Let us remember that in the "Risk Analysis Report of ***APP.1", which the Agency already has, it states that the risk "for the asset is calculated as the highest level of all identified risks, thus being Moderate".

b) Regarding the processing operations that include access to ***APP.1

First of all, it is essential to highlight that the need to carry out a data protection impact assessment in both processing operations arose from the categories of data that need to be processed to resolve

certain customer faults (such as traffic data), as can be verified in the responses provided in the privacy risk analyses (Pre-DPIA) that are also attached as Annex Documents 3 and 4.

(...)

However, and as has already been proven, ***APP.1 does not store these categories of data, but rather they are housed in other systems accessed for the purpose of carrying out these processing activities, such as ***SYSTEM.1 and ***SYSTEM.2. Information about these systems is included in the "systems" section of Annex Documents 1 and 2.

In short, the risks identified in both Impact Assessments were associated with the processing of more sensitive data categories (such as traffic data) that occur when accessing the mentioned systems.

(...)

Therefore, it must be kept very much in mind that the risks listed in the Impact Assessments provided are the risks related to all data processing carried out within the framework of the indicated processing operations and do not directly affect ***APP.1.

(...)

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

50/128

The risk management methodology (identification, evaluation, treatment, and monitoring), which is detailed in section 3 of Annex Documents 1 and 2, aims to "identify and evaluate the risks related to processing, as well as to collect the measures planned to mitigate the risks and assess the risk considering the implementation of the mitigating measures.

(...)

Let us remember that in the case of access to system ***APP.1, the maximum detected risk was moderate, although not for unauthorized access. As we have already mentioned, and according to the "Risk Analysis Report of system ***APP.1" that was previously provided along with the response to the Information Request, the specific risk of "Unauthorized access to legitimate user credentials" was classified as "Low Residual Risk".

Therefore, it must be kept very much in mind that the risks listed in the Impact Assessments provided are the risks related to all data processing carried out within the framework of the indicated processing operations and do not directly affect ***APP.1.

(...)

Regarding risk 8 that appears in both documents:

(...).

2. In relation to the request to also provide, if available, audit reports, pestenting, etc., that have been carried out concerning the computer applications affected by the incident (...), Telefónica indicates the following:

Telefónica has already provided in previous allegations the various certificates it holds regarding information security management. In this regard, it is important to remember that Telefónica, in its commitment to comply with applicable regulations and to provide the highest security and quality to its services, holds certificates that attest to the good management of information security. For example:

- (...)

Specifically, the certificates of the information security management system, as noted by AENOR itself, contribute to ensuring that "business processes and/or IT services, assets, and their risks are identified and assessed, and that the most effective and coherent controls and procedures are adopted in line with the business strategy, considering continuous improvement."

For its part, the National Security Scheme establishes a series of measures that guarantee the security of systems, data, communications, and electronic services. In this sense, having this certification ensures that Telefónica has "a managed and controlled system with measures/controls that ensure

C/ Jorge Juan, 6
www.aepd.es

28001 – Madrid
sedeagpd.gob.es
51/128

the correct protection of information systems against internal and external threats and incidents,” as also noted by AENOR.

In short, the certificates held by Telefónica attest to its good management of information security.

3. Regarding the request for information on whether, at the time of the incident, a two-factor verification system was implemented for access to the affected applications. If so, evidence of this, Telefónica states the following:

“At the time of the incident, there was no two-factor verification system for access to ***APP.1 as it was not deemed necessary, according to the risk analysis conducted. Notwithstanding the above, it is important to clarify that ***APP.1 had appropriate technical and organizational measures regarding the processing of personal data, as has been proven throughout this File.

(...)

Specifically, concerning the assessment of the risk related to “Unauthorized access to legitimate user credentials. (Low Residual Risk),” which we have already referenced and which is recorded in the “Risk Analysis Report. System ***APP.1,” we recall that the probability of this threat materializing was rated as low, based on the risk analysis criteria provided. In this case, it was considered that the materialization of the risk had a remote probability, between 0-10%. That is to say, its materialization could only occur under exceptional circumstances, and for this reason, at the time of the incident, there was no two-factor verification system for access to ***APP.1 as it was not deemed necessary, according to the risk analysis conducted.

4. Regarding the request for information on the malicious accesses that occurred between September 9 and 11 (affected user and their role, accesses that occurred, personal data affected, why it was not detected at that time, etc.), Telefónica responds as follows:

In the following table, the users used to carry out the attack and the start and end dates of those attacks can be verified. Specifically, accesses that occurred between September 9 and 11, 2022, are marked in blue, accesses from September 16 to 20 in green, and accesses from the 28th in red:

(...)

During that period, the number of customers and phones consulted was as follows:

- Number of customers: 524,691.
- Number of distinct landlines: 562,608.

As for the data accessed, as the AEPD already knows, they were the same as in the other mentioned periods: (...)

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

52/128

The IP address from which the attack was carried out was ***IP.1, whose country of origin was Lithuania and the internet service provider was UAB Cherry Server. Specifically, from this IP, queries were made to ***APP.1 and data was obtained.

Let us recall that, as a mitigation measure, when the malicious queries were detected (...).

6. Regarding the request for evidence of the existence, if applicable, of Action Protocols in case of violation of the security of personal data (personal data breach) at the time of the incident, Telefónica indicates the following:

At the time the Incident occurred, Telefónica had “(...)” for the management of security breaches affecting personal data, which is attached as Annex Document 5.

The objective of this document was to develop the various stages of the notification and communication process in the event of security and privacy breaches that may affect personal data processed by Telefónica España and, if applicable, communication of the incident to the AEPD and the affected parties.

TENTH:

On July 22, 2024, a resolution proposal was made, in which a response was given to the allegations raised against the initiation agreement and it was proposed that Telefónica be sanctioned with a total fine of €1,300,000 for the commission of two infringements, in particular, for violating the provisions of Articles 5.1.f) and 32 of the GDPR.

ELEVENTH:

Once the resolution proposal was notified in accordance with the rules established in the LPACAP, the accused party submitted a written statement of allegations on August 13, 2024.

In its allegations, in summary, the accused party states:

Preliminary. On the continuation of the present sanctioning file.

It begins its writing insisting that it has complied with the provisions of the regulations applicable regarding the fulfillment of the principle of confidentiality, the definition of security measures associated with the processing of personal data, as well as in the management of the incident in the internal system of Telefónica ***APP.1 that this file addresses. It then emphasizes that it has collaborated at all times with the AEPD and considers that the latter is not taking into account all the information and documentation provided by it. In this regard, it highlights that the only data obtained by the attacker were technical data from some connectivity equipment provided by Telefónica and installed at the customer's home (router, television decoder, WiFi amplifier, etc.). It continues analyzing said data to conclude that neither the landline phone allows for the identification of a natural person by itself, as it corresponds to a household that may be composed of several people, nor does it...

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

53/128

the technical and configuration data of the equipment, even when associated with a fixed telephone number.

Next, it states that the security measures were indeed adequate, briefly referencing the reasons why it believes this to be the case and indicating that these will be developed more extensively throughout the written allegations. Succinctly, it refers to the two-factor authentication to assert that having such a system would not have guaranteed that the incident could not have occurred. It also states that access from a foreign IP cannot be arbitrarily blocked based solely on location. Additionally, it adds that it has employees who may need to access their systems from outside the national territory and that Lithuania is not considered a conflict country regarding cyberattacks.

In relation to the alerts concerning the massive volume of queries, it argues that this is a situation that can occur in its company regularly due to the existence of automation and extraction processes, and that establishing limitations on queries by users could cause dysfunctions in the performance of their tasks.

Regarding ***MEASURE.2: it begins by noting that a large part of the affected data is of a dynamic nature, then referring to the passwords of WiFi networks.

Finally, it refers to the characteristics of the incident to insist that it is documented that they have been victims of a highly targeted attack executed by professionals, and that the risk of a third party having internal knowledge of Telefónica's systems is not a probable risk. It reiterates the professional nature of the attackers and the fact that police investigations are underway.

First. Clarification regarding the description of proven facts made by the AEPD.

Telefónica believes that there are a series of errors in the proven facts and reiterates the first allegation presented against the initiation agreement of this sanctioning procedure. Thus, it asserts that it is not true that the containment measures were implemented 4 days later, nor that the massive requests ceased until the employee changed their credentials, as the user was blocked at the very moment of detection, nor that massive queries significantly higher than usual were being detected without action being taken by Telefónica. Regarding this last point, it clarifies that when massive queries were detected on September 20, the user was blocked that same day, even discovering after conducting the investigation that massive queries had also been made on September 16.

Second. Regarding the incident in ***APP.1 and the security measures: Telefónica contemplates technical and organizational measures that are appropriate to ensure adequate security of its customers' personal data, including protection against unauthorized or unlawful processing. Telefónica categorically denies that the causes that led to the incident can be attributed to a lack of foresight or control on its part. As a consequence of this...

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
54/128

previously, it considers the non-existence of a breach of obligations regarding data protection, and should be regarded as a victim of unlawful acts committed by third parties. It reiterates the explanation provided regarding the initiation agreement concerning ***APP.1 and insists that the loss of control over the information by the system does not generate a high risk for the rights and freedoms of users. In this regard, it emphasizes that the landline phone number is a piece of information that can be found in telephone directories and that, therefore, the only information affected would relate to the configuration of Telefónica's connectivity equipment. Regarding the latter, it reiterates its assertions: the WiFi network name (SSID) and WiFi password are not unique; the existence of the Incident was communicated to the interested parties, and they were advised to change their password to enhance the security of their network and prevent possible unauthorized access; user communications over the WiFi network, in its default configuration, are encrypted end-to-end; access to each WiFi network could only occur when the intruder was physically within the coverage area of the router's installation; for the intruder to be physically present in the coverage area of the router's installation, it would be necessary for the third party to have the postal address corresponding to the WiFi passwords (a piece of information that has not been extracted from Telefónica's systems); and ***APP.1 does not contain the router's administrative password either. All of the above leads it to consider the AEPD's conclusion that access to the category of data affected by the Incident could even reach "(...)" as disproportionate. In short, Telefónica believes that no security measure is completely infallible, nor can such a requirement be demanded, and that Telefónica had indeed analyzed the system affected by the Incident and had a risk analysis in place that assessed the measures applied to ensure adequate security of its customers' personal data, including protection against unauthorized or unlawful processing. It highlights its usual practice regarding these treatments by referring to the conduct of an impact study for the rights and freedoms of individuals whose personal data is being processed in the corresponding privacy risk analysis (Pre-DPIA) and in the impact assessment (PIA), if deemed necessary. It also conducts the corresponding security risk analyses. And, in relation to the data affected in this case, it states that, although the residual risk of unauthorized access to legitimate user credentials was low, Telefónica already had a plan (prior to the Incident) for additional measures, such as the deployment of a WAF (Web Application Firewall) system at ***URL.1 to have even greater traceability of actions in this environment. For all these reasons, it disagrees with the assertions made in the proposal.

Next, it refers to access from a foreign IP geolocated in Lithuania to express its disagreement with what this Agency stated in the proposal. It explains that it has employees and subcontracted companies that may need to access its systems from outside the national territory and that it does not consider geolocation-based IP blocking measures effective since they can use IP anonymization systems.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
55/128

Next, it refers to the measures that Telefónica has in place to comply with its obligations and which it already mentioned in its allegations against the initiation agreement, and which it believes have not been taken into account. In its opinion, the AEPD has not considered whether Telefónica acted

diligently regarding the known risk at that time, but rather focused on the absence of certain security measures that it deems would have been ideal. To this, it adds its consideration that the affected data did not need to be encrypted and concludes that it did have adequate technical and organizational measures in accordance with the applicable regulations.

Third. Overcoming the sphere of responsibility of Telefónica: exceptional circumstances that have allowed third parties to surpass the implemented security policies.

In this regard, it reiterates what it has already indicated in its allegations against the initiation agreement.

Fourth. On the preliminary issues raised by the AEPD within the framework of this file.

In this section of its allegations, it argues that the Opinion from 2011 referenced by the AEPD in the proposal does not pertain to a situation analogous to the one occurring here, as it relates to geolocation services on smart mobile devices, whereas in this case the attackers did not obtain any type of location of the customers and we are dealing with the MAC of a connectivity device located at a specific customer's address. It adds an excerpt from the Preliminary Proceedings document issued by the Court of Instruction No. 31 of Madrid, related to that incident, in which it agrees to "the provisional dismissal of the proceedings," to the extent that "the private data of the supposedly affected holders is unknown, and it is unclear which physical or legal person has been affected, given that the crime of revelation of secrets is subject to the requirement of prior denunciation."

Fifth. On the alleged infringements committed by Telefónica: violation of the principle of legality.

Under this heading, Telefónica reproduces the allegation made against the initiation agreement for this same reason. It understands that the described facts are not subsumable under the types described in Articles 5.1.f and 32 of the GDPR and that, therefore, the processing of a sanctioning procedure is not applicable. It insists that there is an assumption of the existence of an obligation of results and an objective responsibility.

Furthermore, in relation to the wording of the applicable regulatory provisions, it considers that the AEPD is acting arbitrarily by focusing solely on the outcome produced without taking into account that the application of specific measures or the infallibility of the measures adopted cannot be demanded. It believes that, to understand the cited provisions as infringed, it would be necessary for appropriate technical and organizational measures not to be applied to ensure an adequate level of security relative to the risk, and, in general, that a "security...

56/128

"adequate" in the processing of personal data. These issues are understood not to occur in their case because, they assert, they have appropriate technical and organizational measures regarding the processing of personal data in their systems, and these measures are adequate and guarantee a level of security that is appropriate to the risk, taking into account the state of the art, the costs of implementation, and the nature, scope, context, and purposes of the processing, as well as variable probability and severity risks for the rights and freedoms of individuals.

They reiterate that they consider it proven that their measures are reviewed and updated when necessary and that the causes that have led to the present incident are not attributable in any case to Telefónica.

They continue their writing by reproducing again their allegations regarding the drafting of the applicable regulations, insisting that a situation of legal uncertainty has occurred that hinders their defense and that would imply a violation of constitutional principles (Articles 24, 25, and 9.3 of the Spanish Constitution).

They also reiterate the arguments made against the initiation agreement concerning what they consider an error in the typification and qualification of the facts as well as in the determination of the sanction. This is because they understand that the provisions of Article 5.1.f) do not apply to this case as it regulates the security of personal data in a more generic manner, while Article 32 is more specific. Continuing with this line of argument, they understand that since the action cannot be subsumed under the provisions of Article 5.1.f), the infringement could not be classified as very serious.

They conclude this allegation by reiterating the arguments related to the reiteration in the intention to aggravate both infringements on the same grounds.

Sixth. Telefónica's conduct is not unlawful.

Once again, Telefónica reiterates what was alleged against the initiation agreement regarding the non-existence of unlawfulness in its conduct. In this regard, they insist that they have technical and organizational measures designed to ensure adequate security of personal data (certificates, protocols, and manuals that certify security management, employee awareness measures, device protection measures, etc.) and multiple mechanisms to detect unauthorized access to personal data. Seventh. Absence of culpability.

In their next allegation, they reiterate the arguments already raised regarding the non-existence of fault in their conduct. They insist that they have acted in good faith with all the required professional diligence, in good faith, and that the circumstances that have led to the facts subject to this proceeding are attributable to third parties who acted in the commission of a crime.

Eighth. Violation of the principle of proportionality.

Next, Telefónica reproduces almost literally the arguments made regarding what they consider a violation of the principle of proportionality in the determination of sanctions, specifying each of the aggravating circumstances present in each of the two infringements, as well as the mitigating circumstances that, in their opinion, should have been taken into account.

Telefónica concludes its written allegations requesting that the non-existence of responsibility on the part of Telefónica for the alleged infringements attributed to it in this procedure be declared, as there is no unlawful, typical, or culpable conduct by Telefónica in the imputed facts, ordering the filing of the present sanctioning procedure.

Subsidiarily, and in case it is understood that the technical and security measures are not adequate, it should be taken into account as indicated in the written allegations so that, in the event of considering the existence of an infringement, the conduct of Telefónica could in no case be classified as very serious, as it would be contrary to Article 5.1 f) of the GDPR.

Subsidiarily, in case the first request is not upheld, the initially proposed sanction should be reduced in accordance with the criteria of Article 83 of the GDPR and Article 76.2 of the LOPDGDD.

In view of all that has been acted upon by the Spanish Agency for Data Protection in the present procedure, the following facts are considered proven,

PROVEN FACTS

FIRST: First notification of personal data breach

On September 26, 2022, Telefónica notified the AEPD of a personal data breach in which it reported the following (Registration number: REGAGE22e00042226564):

“(…)”

It is indicated that the number of individuals whose personal data has been affected is 1,021,253, customers of this company.

It indicates the start date of the breach as September 16, 2022.

It indicates the resolution date of the breach as September 20, 2022.

It indicates the detection date of the breach, understood as the date on which the responsible party is certain that personal data has been affected: September 23, 2022.

It is indicated that the personal data is not encrypted.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

58/128

SECOND: Second notification of personal data breach

On October 26, 2022, Telefónica presents a new notification completing the initial notification regarding the personal data breach, indicating the following information (Registration Number: REGAGE22e00048156613):

- “(…)”

- It is stated that the start date of the breach is September 9, 2022.

- It is stated that the incident was detected on September 20 by a warning from a member of the organization.

- It is stated that the breach is considered resolved as of September 20, 2022.

- It is stated that on September 23, 2022, it was detected that the breach affected personal data.
- It is indicated that, in total, the personal data of a total of 1,407,257 individuals have been affected, all of whom are residents of Spain.
- It is stated that the breach could have been avoided by adopting additional measures, but that it did not occur due to deficiencies in current measures.
- It is stated that the new reactive measures implemented have been “***MEASURE.1” and “***MEASURE.2.”
- It is stated that a Risk Analysis and Incident Register are available.
- It is stated that the incident has been reported to the police authorities.
- It is stated that affected individuals will be notified by no later than October 28, 2022.
- There is no data processor affected by the breach.

Along with the notification, the following documentation is provided:

“Privacy incident report unauthorized access to ***APP.1,” with the following relevant information:

- Unauthorized accesses were detected in one of the internal applications of Telefónica's employee portal called ***PORTAL.1 (***URL.1), ***APP.1. Access to this portal was public from the internet and used an authentication method based on credentials that each employee possesses (username and password).
- A screenshot of an internal email sent on September 23, 2022, at 22:17 by the security team (CSIRT) is provided with the following content: “(…)”.

THIRD: The following emails are included in the file:

Email 1: A screenshot of an email sent on Wednesday, September 20, 2022, is included, which Telefónica provided in its “Privacy incident report unauthorized access to ***APP.1” submitted on 10/26/2022 along with the second notification of the personal data breach (Registration Number: REGAGE22e00048156613):

(…)

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

59/128

Email 2: A screenshot of an email sent on September 21, 2022, directed by the employee whose username was used to carry out the cyberattack and sent to the Telefónica security team, provided by the entity as “Annex Document 3” in the response submitted on 11/28/2022 (Registration Number: REGAGE22e00054164415):

“(…)”

This email has been provided by Telefónica upon being requested to verify the email that the affected user sent to the Telefónica security team (CSIRT-TE) notifying the incident.

Email 3: At the request of the acting Inspector to verify the communication of the incident that was directed from the security team (CSIRT-TE) to the DPO, a screenshot of the email sent on September 23 is provided, submitted by the entity as “Annex Document 2” in the response submitted on 11/28/2022 (Registration Number: REGAGE22e00054164415) with the following content:

(…)

FOURTH: Chronology and description of the attack:

According to information provided by Telefónica, the chronology of the attack is as follows:

1.- Start date of the attack: September 9, 2022

In its “Privacy incident report unauthorized access to ***APP.1” submitted on 10/26/2022 along with the second notification of the personal data breach (Registration Number: REGAGE22e00048156613), Telefónica states that “...once the complete analysis of the incident was concluded, it was determined that the malicious accesses occurred in three blocks of days, from September 9 to 11, from September 16 to 20, and on September 28.”

In its response, through a document submitted on 06/28/2024 (Registration Number: REGAGE24e00048325431) to the request for information made during the evidence gathering period

opened by the Instructor of this sanctioning procedure, regarding the request for information on the malicious accesses that occurred between September 9 and 11 (affected user and their role, accesses that occurred, personal data affected, why it was not detected at that time, etc.), Telefónica responds as follows:

For the period requested by the AEPD, from 09/09/2022 to 09/11/2022, the user used was ***USER.1. During that period, the number of customers and phones consulted was as follows:

- Number of customers: 524,691.
- Number of distinct landlines: 562,608.

As for the data accessed, it was the same as in the other mentioned periods.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

60/128

2. Period from September 16 to 20, 2022:

In the breach notification made by Telefónica to the AEPD on September 26, 2022 (Registration Number: REGAGE22e00042226564), the following is reported:

“(…).”

3. September 28, 2002.

In the “Privacy Incident Report Unauthorized Access to ***APP.1” submitted on October 26, 2022, along with the second notification of personal data breach (Registration Number: REGAGE22e00048156613), Telefónica states that:

“(…)”

FIFTH: Activities of processing affected by the incident and regarding the application ***APP.1 According to Telefónica, in the report “Privacy Incident Report Unauthorized Access to ***APP.1” submitted on October 26, 2022, along with the second notification of personal data breach (Registration Number: REGAGE22e00048156613), the activities of processing affected by the breach are as follows:

Regarding the application ***APP.1:

In the “Privacy Incident Report Unauthorized Access to ***APP.1,” submitted on October 26, 2022, along with the second notification of personal data breach to the AEPD (Registration Number: REGAGE22e00048156613), as well as in the response document, through a document submitted on June 28, 2024 (Registration Number: REGAGE24e00048325431) to the information request made during the evidence practice period opened by the Instructor of the present sanctioning procedure, it is indicated:

- ***APP.1 is an application that “(…) ... All this information is used for customer support and maintenance purposes by the technical teams of Telefónica.”

- (…)

- Access to ***APP.1 is carried out through logical access via username and password.

SIXTH: Causes that made the breach possible

In the “Privacy Incident Report Unauthorized Access to ***APP.1,” submitted on October 26, 2022, along with the second notification of personal data breach to the AEPD (Registration Number: REGAGE22e00048156613), it is indicated:

- “Malicious accesses occurred in three blocks of days, from September 9 to 11, from September 16 to 20, and on September 28, (…).”

- “(…)”

In the response document, through a document submitted on June 28, 2024 (Registration Number: REGAGE24e00048325431) to the information request regarding the country of origin of the IP addresses from which the attack was carried out, made during the evidence practice period opened by the Instructor of the present sanctioning procedure, Telefónica indicates:

- “(…)”

SEVENTH: Security measures prior to the incident

In the “Privacy Incident Report Unauthorized Access to ***APP.1,” submitted on October 26, 2022,

along with the second notification of personal data breach to the AEPD (Registration Number: REGAGE22e00048156613), it is indicated as measures prior to the personal data breach:

- (...).

EIGHTH: Reactive mitigation measures applied

In the "Privacy Incident Report Unauthorized Access to ***APP.1," submitted on October 26, 2022, along with the second notification of personal data breach to the AEPD (Registration Number: REGAGE22e00048156613), it is indicated:

- "...".

This blocking occurred on September 28, 2022, the date of the last attack.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

61/128

- (...)

This blocking occurred on September 20, 2022.

- (...)

NINTH: Measures following the security incident

In the "Privacy Incident Report Unauthorized Access to ***APP.1," submitted on October 26, 2022, along with the second notification of personal data breach to the AEPD (Registration Number: REGAGE22e00048156613), it is indicated as security measures implemented after the incident:

- (...)

Telefónica also indicates in the aforementioned report the main follow-up measures that were being worked on at the time of submission of that report:

- (...)

TENTH: Risk analysis of the application affected by the personal data breach:

From the copy of the "Risk Analysis Report of the ***APP.1 System," dated November 24, 2021, which states "Risk Assessment conducted in the following time period: July-October 2021," submitted by Telefónica on November 28, 2022 (entry registration number REGAGE22e00054164415) along with its response document to the information request by the acting Inspector in the preliminary investigations, the following information is extracted:

The following list of threats is analyzed, and a residual risk level is concluded by assigning each of them a probability of impact level:

(...)

In its response document, through a document submitted on June 28, 2024 (Registration Number: REGAGE24e00048325431) to the information request made during the evidence practice period opened by the Instructor of the present sanctioning procedure, the following is indicated:

- "...".

ELEVENTH: Methodology of the risk analysis

The security risk analysis methodology of the entity provided to the procedure (...).

In this international standard, a catalog of threats is defined, and for each of them, the probability of materialization and the level of degradation (potential

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

63/128

damage that a threat can cause to a specific asset) in each security dimension. Furthermore, this standard also includes a catalog of controls in each security dimension, the level of mitigation of the probability and/or degradation for each threat, and the type of asset to which the control objective applies.

Specifically, Telefónica's security risk analysis methodology is based on the following steps:

(i) Identification of assets, modeling, and analysis of business impact. Regarding the assessment of the impact of a threat on a specific asset, Telefónica states (...).

TWELFTH: Absence of risk analysis for the rights and freedoms of individuals and data protection impact assessment.

In relation to the request to provide the risk analyses or, where applicable, the Data Protection Impact Assessment, regarding the processing activities affected by the personal data breach in accordance with the GDPR and conducted prior to the date of said breach, Telefónica indicates the following in its response letter dated 28/06/2024:

"The data processing that occurs when accessing ***APP.1 does not have an independent data protection impact assessment, as it does not pose a high risk to the rights and freedoms of individuals."

THIRTEENTH:

Absence of two-factor authentication

In the aforementioned response letter, in response to the request for information on whether a two-factor verification system was implemented for access to the affected applications at the time of the incident. If so, evidence of this, Telefónica responds as follows:

- (...)

FOURTEENTH: Number of affected individuals and type of affected data

1,407,257 individuals, customers of Telefónica, all residing in Spain

Type of affected data:

In the "Incident Report of Privacy Unauthorized Access to ***APP.1", it is indicated that the affected information was as follows:

- Landline phone,
- Associated with it: technical and configuration data (...).

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

64/128

FIFTEENTH: Communication to the affected individuals

In the response letter to the information request made by this AEPD, during the preliminary investigation proceedings, submitted on November 28, 2022 (entry registration number REGAGE22e00054164415), Telefónica states that it has communicated the personal data breach to the affected individuals, indicating the following:

- The medium used predominantly has been email and in some cases postal mail when the email data is not available.
- A total of 89,244 postal letters have been sent, and this fact is evidenced by providing a certificate from the postal service dated October 31, 2022.
- A total of 1,313,395 emails have been sent, providing details of the dates on which the emails were sent, which are between October 27, 2022, and November 2, 2022.
- It was necessary to carry out the communication in phases and on the previously indicated dates to ensure and guarantee adequate attention to possible information requests from customers. They state that another reason for carrying out the communication in phases was to be able to properly assist the affected customers and avoid the collapse of the various management channels enabled for the password change suggested in the content of the communication (due to a possible excessive demand).
- The affected users were customers of both Telefónica Movistar and Telefónica O2.

LEGAL GROUNDS

I Competence

In accordance with the powers granted to each supervisory authority by Article 58.2 of the GDPR, and as established in Articles 47, 48.1, 64.2, and 68.1 of the LOPDGDD, the Director of the Spanish Data Protection Agency is competent to initiate and resolve this procedure.

Furthermore, Article 63.2 of the LOPDGDD states: "The procedures processed by the Spanish Data Protection Agency shall be governed by the provisions of Regulation (EU) 2016/679, by this organic law, by the regulatory provisions issued in its development, and, in so far as they do not contradict them, subsidiarily by the general rules on administrative procedures."

II Preliminary Issues

Telefónica is a large telecommunications operator, and its business development requires continuous processing of a very high volume of personal data.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

65/128

In accordance with the provisions of Article 4.1 of the GDPR, there is a processing of personal data, given that Telefónica carries out, among other processes, the collection, storage, consultation, use, deletion, etc., of personal data of individuals, such as: name, surname, ID number, postal address, telephone number, email address, bank details, etc.

In the case at hand, the security breach suffered has affected personal data processed by Telefónica in its capacity as data controller, as it determines the purposes and means regarding such processing, pursuant to Article 4.7 of the GDPR.

Article 4, paragraph 12 of the GDPR broadly defines "personal data security breaches" (hereinafter security breach) as "all breaches of security that result in the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or unauthorized communication or access to such data."

In this case, there is a personal data security breach under the circumstances mentioned above, categorized as a confidentiality breach, due to unauthorized access by a third party to personal data processed by Telefónica.

III On the nature of the data affected by the breach

Article 4 of the GDPR defines in its paragraph 1) "personal data" as any information relating to an identified or identifiable natural person ("the data subject"); an identifiable natural person is considered to be any person whose identity can be determined, directly or indirectly, in particular by reference to an identifier, such as a name, an identification number, location data, an online identifier, or one or more specific elements of the physical, physiological, genetic, mental, economic, cultural, or social identity of that person.

It follows that the concept of personal data requires the concurrence of a double element: on the one hand, the existence of information or data, and on the other, that such data can be linked to an identified or identifiable natural person.

The concept of identifiable person is also addressed in Recital 26 of the GDPR, which states the following:

(26) The principles of data protection should apply to all information concerning an identified or identifiable natural person. Pseudonymized personal data, which could be attributed to a natural person by the use of additional information, should be considered information about an identifiable natural person. To determine whether a natural person is identifiable, all means reasonably likely to be used by the data controller or any other person to identify the natural person, directly or indirectly, should be taken into account. To determine whether there is a reasonable likelihood that means will be used to identify a natural person, all objective factors, such as the costs and time required, should be considered.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

66/128

for identification, taking into account both the technology available at the time of processing and technological advancements. Therefore, the principles of data protection should not apply to

anonymous information, that is, information that does not relate to an identified or identifiable natural person, nor to data that has been rendered anonymous in such a way that the data subject is no longer identifiable, or ceases to be so. Consequently, this Regulation does not affect the processing of such anonymous information, including for statistical or research purposes.

Thus, this concept of personal data cannot be broader. The National Court in its ruling of 08/03/2002 has indicated that for personal data (as opposed to dissociated data) to exist, it is not essential for there to be a full match between the data and a specific person; it is sufficient that such identification can be made without disproportionate effort.

With the current wording of the GDPR, it is automatically inferred that a landline phone number is personal data concerning the holder of the line - it is an identifier - which is sufficient to make them identifiable.

Opinion 4/2007 on the concept of personal data from the Article 29 Working Party, adopted on June 20, 2007, determines regarding what is identifiable that “a natural person is ‘identifiable’ when, even if they have not yet been identified, it is possible to do so (which is the meaning of the suffix ‘ble’). (...) Identification is normally achieved through specific data that we can call ‘identifiers’ and that have a privileged and very close relationship with a particular person...”.

In this sense, in the case of the landline phone number, it should be noted the existence of subscriber directories, provided for in Article 72 of Law 11/2002, of June 28, General Telecommunications Law (hereinafter, LGTel), and developed through Royal Decree 424/2005 of April 15, which approves the Regulation on conditions for the provision of electronic communications services, universal service, and user protection (in force as long as it does not oppose the LGTel in accordance with the provisions of the sole repealing provision, section c).

Thus, Article 30.4 of the aforementioned RD 424/2005 indicates that “Without prejudice to the provisions of Article 67, regarding the data relating to each subscriber, at least the following information must be included: a) Name and surname or business name. b) Subscriber number or numbers. c) Postal address of the residence, except for floor, letter, and staircase. d) Specific terminal that they wish to declare, if applicable. ...”

And it continues to indicate in its section 6 that “...The data will be listed in alphabetical order of the first surname or business name. After the first surname, the second will be fully reflected, followed by a comma, the first name or their initials. Associated with each number, the subscriber's address will also appear, without specification of floor or letter, and, if applicable, an identifier of the type of terminal (normal telephone, fax, ISDN, videoconference, mobile phone, text telephone for deaf people, among others) that the subscriber has expressed a desire to have included in such a way that allows for the record of the content of the request and the identity of the requester.”

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

67/128

From all of this, it can be inferred that a fixed telephone number is indeed associated with other identifying data of a natural person.

In this regard, and merely for illustrative purposes, it is appropriate to recall Opinion 5/2000 on the use of public telephone directories for reverse or multi-criteria search services (Reverse Directories) by the Article 29 Working Party, adopted on April 13, 2000, which raised the ease of obtaining other personal data from the telephone number of the line holder.

Thus, identification does not have to be direct or complete; an indirect identification that makes a person identifiable in any way is sufficient.

Lastly, it turns out that for a person to be identifiable, it is not necessary for all the information that allows identifying the interested party to be held by a single person.

In the case of a fixed telephone number, if a third party unrelated to the data controller obtains it, it will be considered personal data since it is possible to singularize the person, even if the information does not refer to an identified person— it does allow identifying the line holder, in the sense outlined in Recital 26 of the GDPR:

(26) The principles of data protection must apply to all information relating to an identified or identifiable natural person. Pseudonymized personal data, which could be attributed to a natural person through the use of additional information, must be considered information about an identifiable natural person. To determine whether a natural person is identifiable, all means, such as singularization, that the data controller or any other person could reasonably use to identify the natural person directly or indirectly must be taken into account. To determine whether there is a reasonable likelihood that means will be used to identify a natural person, all objective factors, such as the costs and time required for identification, must be considered, taking into account both the technology available at the time of processing and technological advancements. Therefore, the principles of data protection should not apply to anonymous information, that is, information that does not relate to an identified or identifiable natural person, nor to data that has been rendered anonymous in such a way that the interested party is no longer identifiable, or ceases to be so. Consequently, this Regulation does not affect the processing of such anonymous information, including for statistical or research purposes.

Therefore, merely by the existence of the possibility of identifying a natural person from an identifier, that information must be considered personal data, regardless of whether that possibility materializes. In this specific case, in any event, and without prejudice to the existence of other forms, there are subscriber directories, as noted, that allow for easy identification.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
68/128

identification, even outside the scope of the data controller, constitutes a personal data.

On the other hand, the personal data accessed by the third party in this specific case also qualifies as personal data.

The Article 29 Working Party in its Opinion 4/2007, on the concept of personal data, adopted on June 20, referred to this issue in the following terms:

“When we talk about ‘indirectly’ identified or identifiable, we are generally referring to the phenomenon of ‘unique combinations’, whether these are small or large. In cases where, at first glance, the available identifiers do not allow for the singularization of a specific person, that person may still be ‘identifiable’ because that information combined with other data (whether the data controller is aware of them or not) will allow distinguishing that person from others...”

It is worth noting that, while identification through name and surname is practically the most common, that information may not be necessary in all cases to identify a person. This may occur when other ‘identifiers’ are used to singularize someone.

Indeed, computerized files of personal data usually assign a unique identifier to registered individuals to avoid any confusion between two persons included in the file. Also on the Internet, traffic control tools easily identify the behavior of a machine and, therefore, that of the user behind it. In other words, the possibility of identifying a person no longer necessarily equates to the ability to know their name and surname. The definition of personal data reflects this fact.”

Therefore, it is now widely accepted that the possibility of identifying a person does not necessarily equate to the ability to know their name and surname.

And when referring to “means of identification,” the same Opinion states: “On the other hand, it is a dynamic test, so the degree of technological advancement at the time of processing and its possible development during the period in which the data will be processed must be taken into account...”

The appellant has stated that the attackers also accessed information related to:

- MAC and details of the device manufacturer;
- Configuration of the ports of the connection associated with the landline;
- Names of the wifi network and its password.

Therefore, according to the definition contained in the cited regulations, which consider personal data “any information concerning identified or identifiable natural persons,” the information collected in this case fits this concept, as it concerns information about identified or identifiable natural persons, since

with the data affected by the breach, it is possible to identify the holders of the same without excessive or disproportionate effort.

IV Allegations to the initiation agreement

In response to the allegations presented by Telefónica against the initiation agreement, the following was indicated:

First. - Preliminary considerations and clarification regarding the description of the facts made by the AEPD in the Initiation Agreement

In this section, Telefónica makes the following considerations:

Telefónica claims that it is not true, as stated in the Initiation Agreement, that on September 16, 2022, the attack was detected and that it was not until four days later, on September 20, that the compromised user was blocked, but that it was actually on that day, September 20, when the team from ... (application managing requests to systems) detected a higher number of requests than usual to ***APP.1 and, after the relevant checks, proceeded to block it and restore its credentials. It indicates as proof of this Email 1 sent by a person from the team of ... on 09/20/2022.

Furthermore, Telefónica indicates that, while in the first notification the date of detection of the incident was indicated as September 16, 2022, it was actually meant to say that it was the date the attack began and that, once the final report was concluded, this aspect was corrected upon confirming that the actual date of detection was September 20, 2022.

Telefónica also states that the entity's incident response team, CSIRT-TE, was informed without undue delay and when certain measures had already been taken by ... and not 5 days later, as indicated in the Initiation Agreement.

Therefore, Telefónica indicates that it is not true that the containment measures occurred 4 days later, as on the same day they were detected, September 20, the user from which the queries had been made was blocked.

In contrast, it should be noted that the emails sent regarding the incident suggest otherwise.

Thus, in the so-called Email 1 in the Proven Fact Three, sent on 09/20/2022, it indicates that "(...)" Therefore, what the cited email reflects is that a person from the team of ... is stating on 09/20/2022 that since 09/16/2022 the volume of requests has grown alarmingly. Moreover, the email is not addressed to CSIRT-TE.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
70/128

On its part, in the so-called Email 2 in Proven Fact Three, which the employee whose user account was used to carry out the attack sent on 21/09/2022 to CSIRT-TE, the following is indicated:

"(...)"

It should be noted that the date of its sending, 21/09/2022, was a Wednesday, so the previous Friday referred to was precisely 16/09/2022.

Finally, in the so-called Email 3 in Proven Fact Three, sent on 23/09/2022 and provided by Telefónica specifically to substantiate the communication of the incident by CSIRT-TE to the Data Protection Delegate, it is indicated that:

"(...)"

From the above, it has been established what was indicated in the Initiation Agreement, namely, that:

- On September 16, 2022, the team responsible for APIS (...) detected an anomalous consumption caused by massive requests from the application ***APP.1. (...)
- On September 20, 2022, the user from whom these requests originated was blocked after it was verified, upon the return of said user from vacation, that it was not this user who was legitimately making the requests.
- On September 21, 2022, this user reported the incident to Telefónica's security team (CSIRT).
- During the days of September 21, 22, and 23, 2022, the incident was analyzed by the security team (CSIRT).
- On September 23, 2022, it was indicated that this was when there was knowledge of the data breach

following the requests made by the attackers, and the incident was classified as a security breach. On the same day, the incident was reported to Telefónica's DPD via email.

Therefore, massive queries were being made through a single user that were significantly higher than usual to a Telefónica application accessed through a portal published on the Internet, and the initial containment measures (blocking the user) were not implemented until 4 days later, when said user returned from vacation and indicated that, for that reason, it was not him. And it is this same user who, the following day, informs CSIRT-TE of the incident, at which point they first became aware of the security incident (5 days later).

However, to further emphasize the above, it is noted that, even assuming that the detection date had been 20/09/2022, this is also demonstrative of the same: that there were no adequate preventive measures in place nor was any alert or security event generated, with immediate warning to CSIRT-TE that massive requests significantly exceeding the usual levels (from 55,000 per day to 4 million daily) were occurring for 4 days, and moreover from a single user, which reflects a clear anomalous behavior and suspicion of being malicious. Likewise, the attack suffered between September 9 and 11, 2022, which affected the personal data of more than half a million people, was also not detected.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

71/128

Telefónica customers, an attack that the entity was later able to verify during the detailed analysis of the attack carried out between September 16 and 20. In this regard, it is noteworthy that during the testing phase, Telefónica did not explain why the attack that occurred between September 9-11 was not detected at the time. That is to say, numerous accesses were not detected, which were made from a single user (**USER.1), who turns out to be the same as in the attack that occurred between September 16 and 20, 2022.

This highlights the absence of adequate preventive measures and appropriate alert systems, as will be indicated later, arguing the lack of appropriate technical and organizational measures to ensure a level of security commensurate with the risk.

On the other hand, Telefónica states that it is not true what is indicated in the Initiation Agreement regarding that "...it was established that in each automatic request launched by the attackers, a random phone number was included, and if this number matched any Telefónica customer, the following data was obtained as a result of the query..." but rather that the attacker automated the queries to the system with a series of requests in which they entered fixed phone numbers of customers that they also knew in advance. Furthermore, Telefónica indicates that the attack was very sophisticated as the attacker knew the personal numbers of the employees to whom they sent the SMS, as well as other aspects of the attack related to the introduction of specific URL routes that only allowed access to certain information stored in **APP.1 and not to all, etc.

In this regard, it should be noted that it is Telefónica who indicates, in its "Incident Report on Privacy Unauthorized Access to **APP.1" submitted on 10/26/2022 along with the second notification of personal data breach, that "Malicious accesses were made in three blocks of days, from September 9 to 11, from September 16 to 20, and on September 28, (...).

Moreover, given that the attack carried out using consecutive (or random) fixed phone numbers involved more than 16 million requests, of which access to the personal data of 1,407,257 customers was achieved when the fixed phone number matched that of a Telefónica customer, it only highlights that the attacker did not previously know those fixed phone numbers. However, to elaborate further, in light of what happened, it is not relevant whether the attacker previously knew the fixed phone numbers of Telefónica customers, nor how the specific attack occurred in terms of how the queries were made and the data to which the attacker could not access, or if, as Telefónica claims, it was very sophisticated and had prior knowledge of employee data, etc., but rather what is relevant is that with the credentials of a single Telefónica employee (username and password), massive queries were made to the affected application, ultimately obtaining personal data of more than 1,400,000 customers, which could have been avoided with the existence of a two-factor verification for the employee users of

Telefónica, or any other measure that acted against massive information requests, at the very least, the impact could have been significantly mitigated if control and monitoring measures had existed that would have detected and alerted the attack early, as will be indicated in more detail later.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
72/128

Regarding the fact that there have been other entities that have suffered similar attacks, it signifies that, in addition to highlighting that this type of attack is commonplace and therefore largely foreseeable, each attack is different because, even if the attack was similar, the companies affected are distinct, with different and specific personal data processing practices, and in each case, it is necessary to analyze the existing measures (whether they existed, whether they were adequate to guarantee an appropriate level of security relative to the specific risk in each case, whether they were effective, whether they were observed, etc.).

Second. - Regarding the incident in ***APP.1 and the security measures. Telefónica considers that it has technical and organizational measures that are appropriate to ensure adequate security of personal data, including protection against unauthorized or unlawful processing.

In this section, Telefónica makes a series of allegations aimed fundamentally at indicating that the attack was very sophisticated, that the perpetrator was familiar with the operation of the application ***APP.1, that they obtained the credentials of the employees through a very sophisticated smishing attack, and, above all, that it has been abundantly demonstrated that Telefónica's security measures are appropriate and reasonable to ensure adequate security. To this end, it points out the risk analysis methodology it uses, which has certifications that attest to security management, with awareness measures for employees (primarily anti-phishing), and proceeds to outline the security measures it has, for which we refer to Background Ninth, where everything alleged by Telefónica has been transcribed more extensively.

In contrast, it is noted that, contrary to what Telefónica has indicated, from the analysis of the attack and all the documentation generated and provided during the preliminary investigation phase, as well as in the evidentiary phase conducted in the present sanctioning procedure, which is in the file and to which we refer, the opposite conclusion is reached, as the absence of the following measures that would have prevented the attack, or at least significantly mitigated its impact on the personal data of customers in the event of a successful attack, has been evidenced:

1.- (...).

Secondly, the analysis or assessment of the risks to the rights and freedoms of the data subjects must take into account the processing as a whole: context (in this case, access from a public portal from the internet), type of processing, scope of processing (for example, whether it is mass processing or not, as is the case), risks of probability and severity for the rights and freedoms of individuals, etc., and not only, therefore, considering the type or category of personal data processed (whether they are sensitive or not).

One must not forget the existence of risks associated with knowing the phone number: it could be used to call its owner or contact them via SMS, etc., and through phishing or social engineering, obtain more identifying data (address) and having, in addition, the

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
73/128

the name of the wifi and the passwords, to access the same and impersonate identity, to use them for fraud, computer scams, etc.

Even assuming that, as Telefónica claims, the probability of accessing the wifi of customer users is low, the impact of this is very high on the rights and freedoms of individuals: identity theft, hacking of

devices connected to that wifi, and obtaining data such as health information, routines, consumption, etc., so the final risk cannot be considered low.

Moreover, attempts and frauds carried out by cybercriminals to obtain access credentials to applications and other personal data are ongoing and prevalent, especially through phishing techniques in their various forms (phishing proper, smishing, qrishing, etc.), so the risk of obtaining them is always high or at least considerable, and consequently, unauthorized access may occur. The anti-phishing awareness campaigns for employees are not sufficient to significantly mitigate the risk. Therefore, it cannot be agreed that there was a low residual risk of unauthorized access to legitimate user credentials, given the sole risk mitigation measures actually implemented by Telefónica. In this case, the attack, as it occurred, could have been avoided, for example, if there had been a requirement for two-factor verification for access to the affected application, a measure that is perfectly existing and known, according to the state of the art at the time of the incident, being viable and within the reach of a company like Telefónica, as well as necessary considering (...).

2. (...)

(...)

This shows that at the time of the incident there was no system in place to block potentially insecure connections - or if it existed, it was not effective - based on, for example, country of origin (deny, by default, incoming traffic from all origins except those necessary for the provision of the entity's services; known malicious origins (TOR network nodes, low-reputation IP addresses or identified as potentially malicious, etc.).

(...)

Therefore, there were no adequate measures to prevent access to Telefónica's infrastructure from Internet addresses that could be malicious or, if they existed, they were not effective.

Evidence of this is that subsequently to the attack suffered, one of the measures to be implemented has been precisely one consisting of (...).

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

74/128

3.- Measures aimed at detection, deployment of alerts, and reaction to suspicious or anomalous situations or behaviors.

In relation to the attack that occurred between September 16 and 20, 2022, whether it is taken into account that mass requests to ***APP.1 were being detected from the first day or not until the last (as Telefónica claims), the fact is that no security alert was triggered in the face of such a high number of requests, remember, far exceeding the usual (from 55,000 daily to 4 million a day) and from a single user.

Given such a level of requests - totally far from the normal in a day - no security alert was deployed, nor any blocking measure, so that for four days nothing was done or nothing was warned until a person from ... (...) sent an email asking if this would continue so that necessary measures could be adopted to maintain the application.

Subsequent to the incident, Telefónica implemented measures specifically aimed at detecting, deploying alerts, and immediate reaction to anomalous situations. Among them:

-(...).

The above reflects, as indicated in the Initiation Agreement of the present sanctioning procedure, that prior to the incident, there were no appropriate technical and organizational measures in place to ensure adequate security in the processing of personal data concerning the associated risks. Or, if they existed, they were not effective or were not observed. This is so because:

a) In the attacked application, which was accessed through a portal published on the Internet, and which allowed access to personal data, (...).

b) Precisely the CSIRT of Telefónica (Computer Security Incident Response Team), which aims to respond urgently and in a coordinated manner in case an attack materializes, to mitigate the impact

and, therefore, the consequences, was not aware of the incident until 5 days later, which resulted in a considerable delay both in the adoption of possible containment and mitigation measures for the attack, as well as in the analysis and assessment of the same as a personal data security breach. Furthermore, it should not be forgotten that the attack that occurred between September 9 and 11, 2022, was neither detected nor was any alert generated, which prevented any action or containment measure, with Telefónica being aware of this when the CSIRT subsequently analyzes the incident that occurred between September 16 and 20.

In conclusion, Telefónica did not have or did not have adequately implemented systems or measures to generate security alerts in the face of suspicious situations when not alarming, such as the fact that for 4 days an average of 4 million requests per day were being made to an application that usually receives about 55,000 daily requests, and all of this, moreover, from a single user.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

75/128

indicates in the Email1), which, to all appearances, was obviously not being carried out by a human being.

Furthermore, it is worth noting that during the testing phase, Telefónica did not provide information regarding why the attack suffered between September 9-11, 2022, was not detected at the time. In this context, they did not detect the accesses that were made and were from a single user (**USER.1) who, moreover, turns out to be the same as in the attack that occurred between September 16-20, 2022.

4.- The data was not encrypted

The personal data of the clients accessed via an application from the internet was not securely encrypted, anonymized, or protected in such a way that it would be unintelligible in cases of unauthorized access or that individuals could not be identified, which would have considerably mitigated the risks to the rights and freedoms of individuals.

Subsequently, Telefónica adopted measures consisting of (...).

In light of all the above, it is concluded that, according to the state of the art, there were already measures specifically aimed at. However, it was not until after the personal data breach that such measures were implemented.

From all of the above, it is concluded that the technical and organizational measures implemented prior to the breach were not appropriate to ensure a level of security adequate to the risk posed by the processing of personal data carried out, regardless of the specific attack suffered— which merely highlights these deficiencies once the risk has materialized—measures that, according to the state of the art at the time of the incident, already existed and were known, the costs of which were perfectly manageable by a company like Telefónica that, in addition, processes data on a large scale and with applications accessible from the internet that contain personal data, and is therefore obliged to adopt appropriate technical and organizational security measures to address these risks.

Third.- Overcoming Telefónica's sphere of responsibility: Exceptional circumstances that have enabled third parties to surpass the implemented security policies.

Under this heading, Telefónica alleges issues related to the sophistication of the attack it suffered, as well as its position as a victim of a crime committed by cybercriminals.

In this regard, it should be noted that in no case has total infallibility of the measures that can be adopted to ensure adequate protection in the processing of personal data been required. However, once the attack occurred, which resulted in a personal data breach, the diligence of the data controller in applying the appropriate technical and organizational measures to ensure a level of security adequate to the risk must be evaluated, taking into account

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

the state of the art, the costs of implementation, the nature, scope, context, and purposes of the processing.

In the previous section, it has already been indicated and argued that Telefónica did not have, at the time of the data protection breach, the appropriate measures in relation to the risks of processing for the protection of personal data, which would have prevented the attack - as it occurred - or at least significantly mitigated its impact.

Finally, regarding Telefónica's condition as a victim of a crime, in accordance with the Judgment of June 22, 2021 - Rec. 1210/2018, and the Judgment of November 5, 2011 - Rec. 1796/2019, which evaluates the subjective or culpability element, it is emphasized that the culpability of the plaintiff cannot be considered excluded or mitigated by the fact that there was fraudulent action by a third party, since the responsibility of the plaintiff does not derive from the actions of this third party, but from their own actions.

It is noted that, indeed, the principle of responsibility provided for in Article 28.1 of Law 40/2015, of October 1, on the Legal Regime of the Public Sector, states that: "Only individuals and legal entities, as well as, when a Law recognizes their capacity to act, groups of affected parties, unions, and entities without legal personality and independent or autonomous estates, that are responsible for the same by way of fraud or fault, may be sanctioned for acts constituting administrative infractions."

However, according to the ruling in STS 7887/2011 of November 24, 2011, Rec. 258/2009, "(...) since its judgment 76/1990, of April 26, the Constitutional Court has declared that objective or faultless liability is not applicable in the administrative sanctioning sphere, a doctrine that is reaffirmed in judgment 164/2005, of June 20, 2005, whereby the possibility of imposing sanctions for mere results is excluded, without proving a minimum level of culpability even in terms of mere negligence. However, the method of attributing responsibility to legal entities does not correspond to the forms of culpability that are imputable to human conduct, whether fraudulent or negligent."

Thus, in the case of infringements committed by legal entities, although the element of culpability must be present (see the ruling of this Chamber of the Supreme Court of November 20, 2011 (cassation appeal in the public interest 48/2007), it is necessarily applied differently than it is for individuals.

According to STC 246/1991 "(...) this different construction of the attribution of the authorship of the infringement to the legal entity arises from the very nature of the legal fiction to which these subjects respond. They lack the volitional element in the strict sense, but not the capacity to infringe the norms to which they are subject. The capacity for infringement and, therefore, direct reproachability derives from the legal good protected by the norm that is infringed and the necessity for that protection to be genuinely effective and from the risk that, consequently, the legal entity must assume that is subject to compliance with that norm."

To the above, it should be added, following the judgment of January 23, 1998, partially transcribed in STS 6262/2009, of October 9, 2009, Rec 5285/2005, C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

y STS 6336/2009, of October 23, 2009, Rec 1067/2006, which states that "although the culpability of the conduct must also be subject to proof, it must be considered in relation to the assumption of the corresponding burden, that ordinarily the volitional and cognitive elements necessary to appreciate it form part of the proven typical conduct, and that their exclusion requires evidence of the absence of such elements, or in its normative aspect, that due diligence has been exercised by the party claiming their non-existence; it is not sufficient, in summary, for exculpation against typically unlawful behavior to invoke the absence of fault."

Fourth.- On the preliminary issues raised by the AEPD.

Under this heading, Telefónica reiterates its argument that the fixed telephone cannot be considered a personal data and that without any other data or additional information it is a pseudonymous data, to the extent that it cannot be attributed to an interested party without using additional information.

Consideration of the fixed telephone number as personal data

In this regard, it is appropriate, first of all, to refer to everything indicated in Legal Basis III of the proposed resolution, which is also transcribed in the Initiation Agreement, to which we refer in full in order to avoid unnecessary repetitions.

With the current wording of the GDPR, it is automatically inferred that the fixed telephone number is a personal data regarding the holder of the line - it is an identifier - which is sufficient to make them identifiable.

The Opinion 4/2007 on the concept of personal data from the Article 29 Working Party, adopted on June 20, 2007, determines regarding what is identifiable that “a natural person is ‘identifiable’ when, even if they have not yet been identified, it is possible to do so (which is the meaning of the suffix ‘ble’). (...) Identification is normally achieved through specific data that we can call ‘identifiers’ and that have a privileged and very close relationship with a particular person...”.

In this sense, in the case of the fixed telephone number, it is appropriate to recall what has already been indicated in Legal Basis III regarding the subscriber directories, provided for in Article 72 of Law 11/2002, of June 28, General Telecommunications Law, LGTel, and developed by Royal Decree 424/2005 of April 15, which approves the Regulation on conditions for the provision of electronic communications services, universal service, and user protection (in force to the extent that it does not oppose the LGTel in accordance with the provisions of the sole derogatory provision, section c)).

Thus, Article 30.4 of the aforementioned RD 424/2005 indicates that “Without prejudice to the provisions of Article 67, in relation to the data concerning each subscriber, at least the following information must be included: a) Name and surname or corporate name. b) Subscriber number or numbers. c) Postal address of the home, except for floor, letter, and staircase. d) Specific terminal they wish to declare, if applicable. ...”

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

78/128

In relation to the Legal Report 0285/2006 of the AEPD, which Telefónica highlights, it is noted that it states that “the telephone number will constitute a personal data when it is assigned to a specific holder of the same, or is associated with additional identifying data such as the address, and this is stored with the calling number, in accordance with the definition of personal data included in Article 3.a) of the Organic Law, which encompasses ‘any information concerning identified or identifiable natural persons.’” It is necessary to contextualize the object of the inquiry to which this report responds and indicate that it does not conclude that the landline telephone number is not personal data in itself and that it requires association with additional information.

In this report, the inquiry concerns whether Organic Law 15/1999, of December 13, on the Protection of Personal Data applies to the registration in a database of the numbers of the telephone terminal (landline or mobile) from which the telephone calls received in the provision of a taxi user service via telephone (tele-taxi) are made.

Thus, in this Report, it is indicated, as Telefónica has pointed out, the following:

“In this regard, it should be noted that, from the perspective of personal data protection, the telephone number will constitute personal data when it is assigned to a specific holder of the same, or is associated with additional identifying data such as the address, and this is stored with the calling number, in accordance with the definition of personal data included in Article 3.a) of the Organic Law, which encompasses ‘any information concerning identified or identifiable natural persons.’”

It should be taken into account that in this inquiry, both landline and mobile phones were being stored in the same database, along with the address provided by the clients to which the taxi had to go. And at the time this report was issued (in 2006), it was not yet mandatory for mobile phones operating with prepaid cards to register the identification of the holder. Therefore, the paragraph indicates two possibilities for considering the telephone number as personal data: either when it is assigned to a specific holder (as is the case with landline numbers or mobile numbers with a contract), or, if this is not the case (as in the case of mobile numbers with prepaid cards), that it is associated with additional identifying data such as the address, and this is stored together with the calling number (as the

tele-taxi company was doing).

Therefore, it is not appropriate to accept the conclusion reached by Telefónica regarding the need for another type of additional information to be associated with telephone numbers (whether landline or mobile) for them to be considered personal data.

Furthermore, it should be noted what is also indicated in this report:

"This criterion has been ratified by the National Court in a ruling dated March 8, 2002. As cited therein, 'for there to be a piece of personal data (as opposed to dissociated data), a full match between the data and a specific person is not essential; it is sufficient that such identification can be made.'"

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

79/128

"to be carried out without disproportionate efforts" and "to determine whether a person is identifiable, one must consider the set of means that may reasonably be used by the data controller or by any other person to identify that person." (the underlining is ours)

On the other hand, it is worth noting that Article 1.4 of Royal Decree 1332/1994 of June 20, which develops some of the provisions of the Organic Law, considers personal data to be "any numerical, alphabetical, graphic, photographic, acoustic, or any other type of information susceptible to collection, registration, processing, or transmission concerning an identified or identifiable natural person."

Article 1.5 of the aforementioned Royal Decree closes the concept by defining or describing the identification of the affected party as "any element that allows determining, directly or indirectly, the physical, physiological, psychological, economic, cultural, or social identity of the affected natural person."

In turn, Article 2.a) of Directive 95/46/EC considers identifiable any person whose identity can be determined, directly or indirectly, in particular by means of an identification number or one or several characteristic elements of their physical, physiological, psychological, economic, cultural, or social identity." Recital 26 of the Directive warns that to determine whether a person is identifiable, one must consider the set of means that may reasonably be used by the data controller, or by any other person, to identify the data subject." (the underlining is ours)

In this regard, it is currently easy to associate landline phones with their holders and their postal addresses since, as noted, there are subscriber directories, provided for in Article 72 of the LGTel, and developed through Royal Decree 424/2005 of April 15. Furthermore, nearly 20 years later, with technological advances, there are much more sophisticated tools available to relate personal data existing in different places and from different databases.

Regarding the Judgment of the National Court, Administrative Litigation Chamber, Section 1, of September 17, 2008 (rec. 353/2007) mentioned by Telefónica to argue again that the landline phone is not personal data unless associated with other types of information, it is appropriate to analyze its content.

This judgment resolves a contentious-administrative appeal filed against a resolution of the Director of the AEPD dated June 15, 2007, concerning events that occurred in 2005 regarding a mobile phone number. Therefore, it was not debated whether the landline phone is or is not personal data, regarding which it has already been indicated that it is personal data and that it is currently very easy to associate landline phones with the addresses of their holders through subscriber directories.

In this sense, since the landline phone number is personal data in itself, a matter that is undisputed in the AEPD, at the

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

80/128

courts and, until now, by all telecommunications operators, is the reason

that there are no reports or judicial resolutions questioning the configuration of the landline phone number as personal data, which has not occurred with other data that were initially doubted as to whether they were personal or not (such as mobile phone numbers).

However, and to elaborate further, an analysis of said Judgment is conducted because it contains arguments that mobile phone numbers are indeed personal data and that they further reinforce the fact that the landline phone number is personal data in itself, without the need for additional information about its owner.

Thus, in the fourth legal basis, it is highlighted: (the emphasis is ours)

“Well, the first problem that arises in this case is whether the mobile phone number can be included in the concept of “personal data” as defined in

Article 3.a) of the LOPD, which identifies as such “any information concerning identified or identifiable natural persons.” It is clear that a telephone number associated with a name and surname is a piece of personal data as it provides us with information about an identified person. Moreover, the phone number itself, even if not directly associated with a person, can be considered personal data if it can be used to identify its owner.

In this case, the Spanish Agency for Data Protection has not reasoned, nor has it proven, that the owner of the mobile phone number has been identified through that number or that such identification was possible based on the mentioned number, so that the said phone number, devoid of other circumstances that identify or could allow the identification of its owner, prevents it from fitting into the legal definition of personal data.”

Since 2005 (the date of the events that led to the resolution of the Director of the AEPD on June 15, 2007) until now, almost 20 years have passed during which significant changes have occurred.

On one hand, the regulation of the protection of personal data has undergone a significant transformation, driven by the GDPR. A European regulation that advocates for a broad interpretation of concepts such as personal data, processing, data controller, etc. In this new regulatory context, it can be understood that the previous conception, based on which a mobile phone number, not accompanied by more data, could not be considered personal data, has been surpassed.

On the other hand, significant advances have occurred, both regulatory and technological, that allow for the identification of the person to whom the phone number belongs based on that number.

Regulation contained in the GDPR: (the emphasis is ours)

Article 4.1) of the GDPR defines personal data as: “any information relating to an identified or identifiable natural person (‘the data subject’); a natural person shall be considered identifiable...”

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

81/128

Identifiable physical person: any person whose identity can be determined, directly or indirectly, in particular by means of an identifier, such as a name, an identification number, location data, an online identifier, or one or several elements specific to the physical, physiological, genetic, mental, economic, cultural, or social identity of that person;”

As determined by Opinion 4/2007 of the Article 29 Working Party on the concept of personal data, WP136, adopted on June 20, 2007, “this definition reflects the intention of the European legislator to maintain a broad concept of ‘personal data.’” It further states, “The expression ‘any information’ used in the Directive clearly indicates the legislator’s intention to give a broad meaning to the concept of ‘personal data.’ This wording requires a broad interpretation.”

For its part, Recital 26 of the GDPR provides: (the underlining is ours)

“(26) The principles of data protection should apply to all information relating to an identified or identifiable natural person. Pseudonymized personal data, which could be attributed to a natural person by the use of additional information, should be considered information about an identifiable natural person. To determine whether a natural person is identifiable, all means, such as singling out,

that could reasonably be used by the data controller or any other person to identify the natural person, either directly or indirectly, must be taken into account. To determine whether there is a reasonable likelihood that means will be used to identify a natural person, all objective factors, such as the costs and time required for identification, must be considered, taking into account both the technology available at the time of processing and technological developments. Therefore, the principles of data protection should not apply to anonymous information, that is, information that does not relate to an identified or identifiable natural person, nor to data rendered anonymous in such a way that the data subject is not identifiable, or ceases to be identifiable. Consequently, this Regulation does not affect the processing of such anonymous information, including for statistical or research purposes.”

In this regard, Opinion 4/2007 of the Article 29 Working Party on the concept of personal data, WP136, adopted on June 20, 2007, states: (the underlining is ours)

“In general, a natural person can be considered ‘identified’ when, within a group of people, they are ‘distinguished’ from all other members of the group. Consequently, a natural person is ‘identifiable’ when, although they have not yet been identified, it is possible to do so (...)

Identification is normally achieved through specific data that we can call ‘identifiers’ and that have a privileged and very close relationship with a particular person.

(...)

‘Directly’ or ‘indirectly’ identifiable

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

82/128

This idea is further clarified in the comments to the articles of the modified proposal from the Commission, where it is stated that “a person can be identified directly by their name and surname or indirectly by a telephone number, a car registration, a social security number, a passport number, or by a combination of significant criteria (age, employment, residence, etc.), which makes it possible to identify them by narrowing down the group to which they belong.”

Furthermore, following the entry into force of Law 25/2007, of October 18, it is possible to further identify the person to whom a telephone number (landline and mobile) belongs (although it is true that this information is provided to authorized agents, following the corresponding judicial authorization).

Additionally, Article 58.5 of Law 11/2022, of June 28, has established a correlation between the telephone number and the identity of the person to whom that number belongs.

Next, we proceed to analyze this regulation:

Law 25/2007, of October 18, on the retention of data related to electronic communications and public communication networks and Article 58.5 of Law 11/2022, of June 28, General Telecommunications Law (the underlining is ours)

Law 25/2007, of October 18, transposed into the Spanish legal system Directive 2006/24/EC of the European Parliament and of the Council, of March 15, on the retention of data generated or processed in relation to the provision of publicly available electronic communications services or public communication networks, and which amends Directive 2002/58/EC of the European Parliament and of the Council, of July 12.

Article 1, which determines the object of the Law, provides:

“1. This Law aims to regulate the obligation of operators to retain the data generated or processed in the context of providing electronic communications services or public communication networks, as well as the duty to transfer such data to authorized agents whenever they are requested through the corresponding judicial authorization for the purposes of detecting, investigating, and prosecuting serious crimes covered by the Penal Code or special criminal laws.

2. This Law shall apply to traffic and location data concerning natural and legal persons and to the related data necessary to identify the subscriber or registered user. (...)”

Article 3 (Data subject to retention) provides:

1. The data that must be retained by the operators specified in Article 2 of this Law are as follows:

“a) Data necessary to trace and identify the origin of a communication:

1.º With respect to fixed network telephony and mobile telephony:

i) Calling telephone number.

ii) Name and address of the subscriber or registered user.

(...)

b) Data necessary to identify the destination of a communication:

1.º With respect to fixed network telephony and mobile telephony:

i) The number or numbers dialed (the destination telephone number or numbers) and, in cases where other services are involved, such as call forwarding or transfer, the number or numbers to which the calls are transferred.

ii) The names and addresses of the subscribers or registered users.

(...)"

Advances in the field of communications over the last 19 years

No one disputes the significance of the changes that have occurred in the last 19 years in the field of communications, both from an innovation-based perspective and from a purely technological perspective.

In addition to the mechanism regulated in Law 25/2007, of October 28, there are other possibilities that currently allow for the identification of the person to whom a fixed or mobile telephone number belongs (online search engines, apps, websites with telephone directories, and even using profiles on some social networks).

In this regard, Opinion 4/2007 of the Article 29 Working Party on the concept of personal data, WP136, adopted on June 20, 2007, clarifies regarding the possibility of identifying the person: (the underlining is ours)

"it is a dynamic test, so the degree of technological advancement at the time of processing and its possible development during the period in which the data will be processed must be taken into account. Identification may not be feasible today with the set of means that can reasonably be used at present. If it is expected that the data will be retained for one month, it may not be feasible to advance the identification so that it is completed within the 'lifetime' of the information, and therefore, that information should not be considered personal data. However, if the expected retention period is ten years, the data controller must consider the possibility that identification may occur after nine years, at which point it would acquire the category of personal data. It is necessary for the system to be able to adapt to technological advances as they occur and to introduce appropriate technical and organizational measures in due time."

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

84/128

For all the above reasons, it can be stated that currently, a telephone number, whether fixed or mobile, perfectly fits the definition of what constitutes personal data according to Article 4.1) of the GDPR.

On the one hand, it allows, by itself, the identification of the person to whom it belongs, even when not accompanied by any other data.

On the other hand, it is possible to identify, through the telephone number, the person to whom it belongs without making disproportionate efforts.

Moreover, Telefónica forgets that for a person to be identifiable, it is not necessary for all the information that allows identifying the data subject to be held by a single person. In this regard, the Judgment of the CJEU of October 19, 2016, in case C-582/14, in the proceedings between Patrick Breyer and Bundesrepublik Deutschland, states that "for a data to be classified as 'personal data', in the sense of Article 2(a) of that Directive, it is not necessary for all the information that allows identifying the data subject to be held by a single person." (the emphasis is ours).

Therefore, the Resolutions, Reports, and Judgments that Telefónica brings up to argue that the telephone number is not considered personal data unless accompanied by additional information that allows identifying its holders or makes them identifiable, are from 15 years ago or more and refer to mobile phones for which there was then disagreement or doubts about their status as personal data by

themselves, a matter that is currently surpassed by all the previously indicated. Especially for fixed telephone numbers, which are always and have always been assigned to a specific holder and are very easy to identify.

Regarding the Judgments of the Court of Justice of the EU indicated by Telefónica to understand that, extrapolating what they indicate, a data can only be considered personal data for a third party when that third party has legal means that allow them to identify the data subject thanks to the additional information they have about that person, it is noted that these conclusions have been drawn without considering the context of them, and that such a conclusion directly contradicts the definition of personal data provided by the GDPR, as well as everything that has been argued previously, since this would imply that if personal data is accessed illegally, it would not have such status, which is unacceptable, as it would even lead to the conclusion that no security measures would be necessary against any risk of breaching the confidentiality, integrity, and availability of personal data, given that for such a breach to exist, it is necessary for it to be carried out unlawfully and by an unauthorized third party.

Regarding the technical and configuration data accessed by the attackers, Telefónica indicates that due to their nature and because they are only associated with the fixed telephone number and, understanding that the latter is not personal data related to an identifiable person, they cannot be considered personal data either.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
85/128

In this regard, it is important to recall that among the data to which the attackers had access, Telefónica indicated the following:

- MAC and details of the device manufacturer;
- Configuration of the ports of the connection associated with the landline;
- Names of the Wi-Fi network and its password.

In this sense, it is appropriate to refer to everything mentioned above regarding the consideration of the landline number as personal data in itself. Therefore, since the rest of the data accessed was associated with the landline of its holders, all information relating to an identified or identifiable natural person constitutes personal data.

Furthermore, regarding the information on MAC addresses, it should be noted that the Article 29 Working Party, in its Opinion 13/2011 on geolocation services in smart mobile devices, highlighted the risks associated with the collection of MAC addresses through signal scanning and the possibility of associating that information with natural persons:

“Passive scanning: recording the signals transmitted periodically by each access point (generally 10 times per second). Alternatively and exceptionally, some devices record all Wi-Fi signals transmitted by access points, including those that do not emit beacon signals. If this type of scanning is carried out without adequately applying privacy protection by design, it may lead to the acquisition of data exchanged between the points, the MAC addresses of computers, laptops, and access printers, and the devices connected to them. In this way, they could be recorded. This type of scanning could also lead to the illegal recording of the content of communications. These contents are easily readable if the owner of the Wi-Fi access point has not activated Wi-Fi encryption (WEP/WPA/WPA2).”

(...)

“Wi-Fi access points. This indirect form of identifiability also applies to Wi-Fi access points. The MAC address of a Wi-Fi access point, in combination with its calculated location, is closely linked to the location of the owner of the access point.

A data controller reasonably equipped can increasingly accurately calculate the location of a Wi-Fi access point using signal strength and location updates being made by users of their geolocation services.

With these resources, in many cases, a small group of apartments or houses where the owner of the access point might live can be identified. The ease with which the owner of the MAC address can be

identified will depend on the environment:

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

86/128

. In sparsely populated areas, where the MAC address points to a single house, the owner of the residence can be directly identified using tools such as, for example, land registry records, telephone white pages, electoral rolls, or even a simple search engine.

. In more densely populated areas, with the help of resources such as, for example, signal strength or SSID (which anyone with a Wi-Fi device can detect), it is possible to determine the precise location of the access point and thus, in many cases, the identity of the person living in the specific place (house or apartment) where the access point is located.

. In very densely populated areas, even with the help of information about signal strength, the MAC address will indicate several apartments as possible locations for the access point. In these circumstances, it is not possible to determine the identity of the person living in the apartment where the point is located with precision and without excessive effort.

The fact that, in some cases, the owner of the device cannot be identified at that moment without unreasonable effort does not prevent the general conclusion that the combination of a MAC address of a Wi-Fi access point with its calculated location should be treated as personal data.

In these circumstances, and considering that it is unlikely that the data controller will be able to distinguish between cases where the owner of the Wi-Fi access point is identifiable and where they are not, the controller must consider all data about Wi-Fi routers as personal data.

It is important to remember that it is not necessary for the purpose of processing this geolocation data to be to identify users. The fact that it requires unreasonable effort to identify the owners of Wi-Fi access points is greatly influenced by the technical capabilities available to the data controller or any other person to identify them.”

Therefore, based on the definition contained in the cited regulations, which consider personal data to be “any information concerning identified or identifiable natural persons,” the information collected in this case fits this concept, as it concerns information about identified or identifiable natural persons, since with the data affected by the breach, it is possible to identify the holders without excessive or disproportionate effort.

Fifth.- Regarding the alleged infringements committed by Telefónica.

Violation of the principle of legality.

Under this heading, Telefónica alleges the following:

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
87/128

5.1.- The conduct of Telefónica could in no case be considered subsumable under any of the provisions that this Agency considers violated.

Telefónica states that it has been accused of a violation of Article 5.1.f) of the GDPR and a violation of Article 32 of the GDPR, but it considers that its conduct is in no case subsumable under any of those provisions that it is said to have violated, as it understands that it has appropriate technical and organizational measures regarding the processing of personal data in its systems, as has been proven.

In contrast, it is noted that from all the arguments presented in the Second section of this Legal Basis, to which we refer in full, the opposite has been proven and accredited, that is, that Telefónica did not have appropriate measures to ensure a level of security adequate to the risk, taking into account the nature, scope, context, and purposes of the processing, as well as the variable probability and severity risks for the rights and freedoms of natural persons.

Thus, considering that the application ***APP.1 allowed access to personal data of around 6 million customers (as Telefónica stated in its two notifications to this Agency regarding the personal data breach), and that access was made through a portal published on the Internet, there was no two-factor verification for access to it, there were no measures or tools whose functionality was aimed at blocking users in case of mass access in a short period of time or aimed at monitoring the operation and generating security events automatically, all of which allowed the attack to occur as configured. Not even in the event that it had been an inevitable attack, Telefónica detected any of those mass queries during the attack carried out between September 9 and 11, 2022, nor were there any alerts or early warnings generated during the attack suffered between September 16 and 20 that would have allowed it to immediately undertake measures aimed at mitigating the attack (blocking the compromised user/s; blocking the foreign IP from which the attack was being made) and thus significantly mitigate the impact of the attack, in which, ultimately, the confidentiality of the personal data of more than 1,400,000 people was affected. Even a simple measure, (...) would have prevented the personal data breach that occurred.

Subsequently, Telefónica implemented measures whose functionalities were precisely aimed at preventing the use of user credentials to carry out a mass attack (blocking the user upon a high number of requests in a short time) or to detect anomalous situations suspected of being malicious through early detection tools and security alert generators, as well as reaction tools, such as blocking access from suspicious IP addresses.

Therefore, all of this demonstrates the commission of the alleged violations of Article 5.1.f) and Article 32 of the GDPR, which are distinct, as will be explained later.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

88/128

Article 5.1.f) states that:

1. Personal data shall be:

f) processed in such a way as to ensure an adequate security of personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction, or damage, by means of appropriate technical or organizational measures (“integrity and confidentiality”).

For its part, Article 32 states:

“1. Taking into account the state of the art, the costs of implementation, and the nature, scope, context, and purposes of the processing, as well as the variable probability and severity risks for the rights and freedoms of natural persons, the controller and the processor shall implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk, which may include, among others:

- a) the pseudonymization and encryption of personal data;
- b) the ability to ensure the ongoing confidentiality, integrity, availability, and resilience of processing systems and services;
- c) the ability to restore the availability and access to personal data promptly in the event of a physical or technical incident;
- d) a process for regularly testing, assessing, and evaluating the effectiveness of technical and organizational measures to ensure the security of processing.

2. In assessing the adequacy of the level of security, particular consideration shall be given to the risks presented by the processing of data, in particular as a consequence of the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data.

(...)”

Furthermore, the classification of the violation of Article 5.1.f) of the GDPR is found in Article 83.5 of the GDPR when it states:

5. Violations of the following provisions shall be subject to administrative fines of up to 20,000,000

EUR or, in the case of an undertaking, an amount equivalent to 4% of the total annual global turnover of the preceding financial year, whichever is higher:

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
89/128

a) the basic principles for processing, including the conditions for consent under Articles 5, 6, 7, and 9; Whereas the classification of the infringement of Article 32 of the GDPR is found in Article 83.4 of the GDPR:

4. Infringements of the following provisions shall be sanctioned, in accordance with paragraph 2, with administrative fines of up to 10,000,000 EUR or, in the case of an undertaking, an amount equivalent to a maximum of 2% of the total global annual turnover of the preceding financial year, opting for the higher amount:

a) the obligations of the controller and the processor under Articles 8, 11, 25 to 39, 42, and 43; Therefore, the infringements are perfectly classified in the GDPR, and the conduct of Telefónica is perfectly subsumable under them, having also been unlawful and culpable. Therefore, the principle of legality is not considered violated.

Furthermore, Telefónica states that the provisions indicated as infringed do not require the infallibility of security measures, but rather that they be appropriate, arguing that the applicable regulations do not establish an obligation of result regarding security measures, but only of means, and that the contrary would imply accepting objective or faultless liability, bringing up the Supreme Court Judgment STS 543/2022 (cassation appeal no. 7359/2020), of February 15, 2022.

Secondly, and in relation to the cited Judgment, it indeed indicates, regarding security measures in data protection, that "... the obligation that falls on the controller and the processor regarding the adoption of necessary measures to ensure the security of personal data is not an obligation of result but of means, and the infallibility of the adopted measures is not required. Only the adoption and implementation of technical and organizational measures, which according to the state of technology and in relation to the nature of the processing carried out and the personal data in question, reasonably allow for the prevention of their alteration, loss, unauthorized processing, or access, is required."

However, the Judgment continues by indicating, in the specific case being analyzed therein, that "... the program used for collecting customer data did not contain any security measures that would allow verifying whether the email address entered was real or fictitious and whether it actually belonged to the person whose data was being processed and who was providing consent for it. The state of the art at the time these events occurred allowed for the establishment of measures aimed at verifying the authenticity of the email address, conditioning the continuation of the process on the user receiving the contract at the provided address and only from there providing the necessary consent for its collection and processing. Measures that were not adopted in this case.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
90/128

(...) Thus, at the moment these events occurred, there were technical measures related to the registration process that would have prevented the leakage of personal data that took place. This implies that the technical measures adopted did not comply with the security conditions as required by Article 9.1 of Law 15/1999, thus incurring the infringement provided for in Article 44.3.h) consisting of "Maintaining files, premises, programs, or equipment containing personal data without the necessary security conditions determined by regulation [...]".

(...) It is stated that the technical security measures related to the software program were the responsibility of Telefónica Consumer Finance, which designed the program and was responsible for the file and the processing, and that the sanctioned company only acted on its behalf by collecting data

from customers who opted for financing. The truth is that the data processor - the natural or legal person who, alone or jointly with others, processes personal data on behalf of the data controller, as defined in Article 4, paragraph 8 of the Regulation, and Article 3.g) of Law 15/1999 on Data Protection (LOPD), and the collection of data implies processing (Article 3.c) - must also adopt the necessary technical and organizational measures to ensure the security of personal data, as provided in Article 32.1 of Regulation (EU) 2016/679 of the Parliament and of the Council and Article 9.1 of the LOPD, and is subject to the sanctioning regime established in the Law (Article 43 of Law 15/1999 on Data Protection).

The appealing company processed customer data on behalf of the data controller, thus implementing and using said program while being aware, or should have been aware, that it lacked the necessary security measures..." (the emphasis is ours)

First of all, it should be noted that this judgment is issued under the regulations prior to the GDPR, in which, according to the system established in the LOPD and the RLOPD, security measures were perfectly standardized. There has been a transition from a system with standard and static security measures for any data controller to specific security measures for each organization (adapted to its characteristics and idiosyncrasies), which consider the specific risks of the entity in question; moreover, they are now dynamic, in such a way that they are not exhausted with the implementation of the appropriate security measures at the beginning of the processing, but must adapt to the risks that may arise.

The new regulation provided for in the GDPR significantly expands the obligations of the data controller and its scope of action and responsibility, now clearly extending to the actions carried out by its data processors, which fall within its area of responsibility.

The judgment does not deliberate on the adequacy of the security measures of the then data controller, but rather denounces a data processor, who did not have the appropriate security measures implemented, an obligation that clearly derived from Article 79 and subsequent articles of the RLOPD, which indicated what, specifically, were the security measures that, according to Title VIII of the aforementioned Regulation, should be implemented by the processors. However, [...]

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

91/128

Furthermore, the judgment indicates that the system was not used properly, which would have prevented the leak.

Secondly, it should be noted that the cited Supreme Court Judgment considers, in relation to an infringement of Article 9 of the LOPDP, that "the obligation that falls on the data controller and on the data processor regarding the adoption of necessary measures to guarantee the security of personal data is not an obligation of result but of means, and the infallibility of the measures adopted is not required. It is only required to adopt and implement technical and organizational measures that, according to the state of technology and in relation to the nature of the processing carried out and the personal data in question, reasonably allow for the prevention of their alteration, loss, unauthorized processing, or access."

In this regard, it specifies that "It is not enough to design the necessary technical and organizational means; their correct implementation and appropriate use are also necessary, so that there will also be liability for the lack of diligence in their use, understood as reasonable diligence considering the circumstances of the case."

Therefore, as has been pointed out, the infringements are perfectly typified in the GDPR, and the conduct of Telefónica is perfectly subsumable under them, having also been unlawful and culpable. Therefore, the principle of legality is not considered violated.

5.2.- On the drafting of the applicable regulations: indeterminate legal concepts that contribute to increasing legal uncertainty and the defenselessness of Telefónica.

Telefónica asserts that the ambiguity and indeterminacy of the concepts included in the articles of the GDPR that have been considered infringed, such as "adequate security," "appropriate technical and

organizational measures,” or “level of security appropriate to the risk,” are noteworthy. These concepts are not defined in the GDPR or in the rest of the data protection regulations, understanding Telefónica, therefore, that this Agency acts arbitrarily by demanding objective liability, focusing solely on the result produced in a specific incident and without taking into account that it cannot require the infallibility of the measures adopted.

It believes that this violates the principle of legal certainty and the prohibition of arbitrariness of public powers enshrined in Article 9.3 of the Spanish Constitution, and that the AEPD is fostering a situation of legal uncertainty and hindering Telefónica's defense.

In this regard, it should be noted that while constitutional regulations require, in the punitive (criminal and administrative) sphere, that there is a sufficient degree of certainty in determining infringing conduct, this does not mean that indeterminate legal concepts, such as those pointed out by Telefónica, cannot be used, which, however, can be easily specified by the competent authority—in this case,

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
92/128

by this Agency - that must apply the norm to the case, based either on cognitive circumstantial elements or on evaluative ones, always of an objective nature.

In this regard, it is appropriate to point out the Judgment of the Constitutional Court 13/2021, of January 28 (Constitutional Appeal 3848/2015) in which the following is indicated: (the underlining is ours)

“Entering into the analysis of the section subject to challenge, the State Attorney refers to the allegation of the appeal regarding the imprecision of the legal terms used, opposing to it that the Council of State in its opinion 557/2014, of March 30, issued regarding the draft law, considered that it is possible, without incurring in arbitrariness or lack of typification, the use of indeterminate legal concepts because “[l]egal reasoning is not a mechanical reasoning and, therefore, the legislator cannot foresee in detail all and each of the circumstances of the case to which the law must be applied, especially in such a fluid matter as the maintenance of public safety. For this reason, both the recourse to indeterminate legal concepts and the reasonableness of the interpretation of the norm and the valuation of the facts at hand are appropriate and reasonable.”

(...)

a) The principle of typification enshrined in Article 25.1 CE requires that, through its normative predetermination, it be ensured that the sanctioning reaction is foreseeable and not surprising. This requirement of *lex certa*, as developed in legal foundation 4 a), does not oppose the use of an indeterminate legal concept such as “disturbance of public safety” in the definition of the infringing conduct, as long as its specification is reasonably foreseeable by virtue of logical, technical, or experiential criteria.

In accordance with the terms in which the claim fulfills the burden of alleging that falls on the one who promotes a constitutional appeal, the court must focus its attention on whether Article 36.1 is sufficiently precise in two aspects: (i) the level of disturbance of public safety that constitutes the infringing type, and in particular whether it encompasses non-serious disturbances; and (ii) whether the typical conduct requires the production of a result and what that result should be.

It is important to highlight, regarding the first issue, that Article 36.1 LOPSC must be interpreted in the context of the legal system in which it is embedded in order to identify what level of disturbance of public safety constitutes the infringing conduct and whether it includes or not minor disturbances of public safety. In other words, a punitive norm may appear incomplete when considered in itself, but this does not mean that it will disregard the principle of typification *ex* Article 25.1 CE if it can be completed by reference to the legal context in which it is integrated (STC 89/1993, FJ 2).

C/ Jorge Juan, 6
www.aepd.es

The court, considering that the present challenge has been delineated by the parties in the terms exposed, deems it appropriate to dismiss it based on the same arguments used to conclude that Article 36.1 of the LOPSC did not violate the dimension of the principle of legality invoked in the constitutional challenge. In other words, Article 36.8 of the LOPSC does not disregard the aspect of the principle of legality invoked in the constitutional challenge because the term "disturbance," interpreted in the context of other sanctioning norms of the LOPSC (among others, Articles 35.2, 36.2, and 36.3) and in light of the relevant provisions of the Penal Code (Articles 557.1 and 557 bis.1.3), is an indeterminate legal concept whose specification is reasonably foreseeable based on logical, technical, or experiential criteria.

However, Article 32 itself provides much information on what must be done to comply with it and to have adequate security measures in place to ensure an appropriate level of security, thus reducing that possible initial indeterminacy. It indicates that to implement such measures, one must take into account the state of the art, the costs of implementation, and the nature, scope, context, and purposes of the processing, as well as variable probabilities and severity risks for the rights and freedoms of the natural persons included, among others:

- a) the pseudonymization and encryption of personal data;
- b) the ability to ensure the confidentiality, integrity, availability, and permanent resilience of the processing systems and services;
- c) the ability to restore the availability and access to personal data quickly in the event of a physical or technical incident;
- d) a process of regular verification, evaluation, and assessment of the effectiveness of the technical and organizational measures to ensure the security of the processing.

2. In evaluating the adequacy of the level of security, particular attention shall be paid to the risks presented by the data processing, particularly as a consequence of the destruction, loss, or accidental or unlawful alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data. (the underlining is ours)

Furthermore, the provisions that have been considered infringed can also be interpreted in the context of other provisions of the GDPR such as Articles 24, 25, and 35, and many Recitals that refer to the risks that must be taken into account (such as Recitals 39, 51, 71, 75, among others) and to the measures that can be implemented (Recitals 28, 29, 83, 94, among others).

For the reasons stated, although initially the concepts included in the provisions that have been considered infringed in the present case may seemingly have some indeterminacy, some margin of appreciation, this does not prevent, in light of what has been indicated,

C/ Jorge Juan, 6

www.aepd.es

that a reasonable interpretation of the regulation and assessment can be made, especially when such interpretation is carried out by the AEPD with proper justification.

Thus, in the case at hand, once the specific circumstances of the case have been analyzed, it has been possible to determine without incurring any type of arbitrary assessment or interpretation the lack of adequate technical and organizational measures of all kinds, including security measures to guarantee, on the one hand, the principle of integrity and confidentiality, and on the other, an appropriate level of security relative to the risk of the processing of personal data carried out by Telefónica (since it lacked adequate and reasonable security measures concerning the available technology and implementation costs at the time of the incident, which would have prevented, if not considerably minimized or mitigated, the impact of the incident on personal data).

To this end, in order to avoid repetition, we refer to everything indicated in Section Two of this Legal Basis, where all of this has been argued in detail, without any arbitrariness.

5.3.- Error in the classification and qualification of the infringement and consequent determination of the sanction

Telefónica claims to disagree with the qualification of the infringement of Article 5.1.f) as a very serious infringement in accordance with Article 72.1 and that of Article 32 has been qualified as serious, in accordance with Article 73.f.

In this regard, it should be noted that the GDPR classifies infringements in its Article 83, without qualifying them as minor, serious, or very serious.

Thus, Article 83, in its paragraph 4, determines:

4. Infringements of the following provisions shall be sanctioned, in accordance with paragraph 2, with administrative fines of up to 10,000,000 EUR or, in the case of an undertaking, an amount equivalent to 2% of the total annual global turnover of the previous financial year, opting for the higher amount:

a) the obligations of the controller and the processor under Articles 8, 11, 25 to 39, 42, and 43;

5. Infringements of the following provisions shall be sanctioned, in accordance with paragraph 2, with administrative fines of up to 20,000,000 EUR or, in the case of an undertaking, an amount equivalent to 4% of the total annual global turnover of the previous financial year, opting for the higher amount:

a) the basic principles for processing, including the conditions for consent under Articles 5, 6, 7, and 9;

However, the qualification as serious or very serious established in the aforementioned provisions of the LOPDGDD is only for the purposes of the prescription of the sanctions, and not for the qualification of the infringements.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

95/128

Regarding Telefónica's assertion that there has also been an error in the grading of the proposed sanctions, as they are constantly reiterated and, consequently, duplicated for the two infringements, which reflects a clear reiteration in the intention to aggravate the two alleged infringements on the same grounds, it should be noted that, regarding the application of identical aggravating factors in both infringements, the circumstances provided for in Article 83.2 of the GDPR and those established in Article 76.2 of the LOPDGDD are the only ones that can be applied by the AEPD for any infringement. What is decisive in this case, regarding those that have been taken into account, is not that they coincide in their use, but the justification that is established for their consideration.

Sixth. - Telefónica's conduct is not unlawful

Telefónica argues that its conduct has not been unlawful since it has technical and security measures designed to ensure adequate security of its customers' personal data, and that infallibility of such measures cannot be demanded, but rather that they contribute to reducing risk.

In response, it is appropriate to refer again to what has been previously argued, that it has been proven otherwise, the lack of adequate measures, and that in no way has infallibility of the measures been demanded.

Seventh. - Absence of culpability

Telefónica claims the absence of culpability in its actions, as there was no intention to infringe the regulation and it always had the will to comply. It also indicates that it acted in good faith and with total professional diligence in managing the incident.

Furthermore, Telefónica again indicates that the AEPD seems to be focusing only on the outcome, considering that there is an infringement due to suffering a cyberattack, for which Telefónica is not responsible, but rather the perpetrators and accomplices of the crime, being authors those who commit the act by themselves, jointly, or through another whom they use as an instrument (Article 28 of the Penal Code).

Therefore, Telefónica concludes that it is faced with actions of third parties with the intent to cause harm through the commission of criminal conduct and that it has acted at all times in good faith and with due diligence in the face of circumstances that it was never in a position to prevent, which implies that we are dealing with a case of force majeure, determining the absence of responsibility or

culpability in the infringing conduct.

In response, it is emphasized, as already indicated previously, that Telefónica focuses on its condition as a victim of a cybercrime (cyberattack by a third party) and that it could not or was not possible to prevent it.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
96/128

In this regard, it must be reiterated that in no case has total infallibility of the measures that can be adopted to ensure adequate protection in the processing of personal data been required. However, once the attack has occurred, the diligence of the data controller in implementing the appropriate technical and organizational measures to ensure a level of security appropriate to the risk must be evaluated, taking into account the state of the art, the costs of implementation, the nature, scope, context, and purposes of the processing.

In the present case, as has already been reiterated, Telefónica did not have adequate measures in place regarding the risks of processing for the protection of personal data at the time the personal data breach occurred, as indicated in the Initiation Agreement of the present sanctioning procedure, which is again referenced in Section Two of this Legal Basis and to which we refer. There were no adequate measures in relation to access control to the application (...).

All these measures were, at the time of the incident, known according to the state of the art and affordable implementation costs, which highlights Telefónica's negligent conduct and, therefore, culpable, without the need to require the existence of intent. This is also contrary to the force majeure situation alleged, as from the circumstances of the present case, already repeatedly exposed, it cannot be deduced that the attack was entirely unforeseeable and inevitable, since, as noted, it could have been avoided and, if not, certainly its impact could have been considerably mitigated.

Therefore, there was a known and, hence, foreseeable risk, in which, considering and analyzing the specific circumstances, there are sufficient elements to understand that Telefónica's level of diligence to prevent or mitigate it was not sufficiently high to rule out that its conduct could be classified as negligent.

Thus, in accordance with the Judgment of June 22, 2021 - Rec. 1210/2018, and the Judgment of November 5, 2011 - Rec. 1796/2019, which assesses the subjective or culpability element, it is emphasized that the culpability of the plaintiff cannot be considered excluded or mitigated by the fact that there was fraudulent action by a third party, as the responsibility of the plaintiff does not derive from the actions of the latter, but from its own actions.

Ninth. - Breach of the principle of proportionality

Telefónica understands that the principle of proportionality has been violated in the sanction proposal as it disagrees with the aggravating factors taken into account and also with the mitigating circumstances that have not been applied.

Regarding the aggravating circumstances taken into account:

9.1 Nature, severity, and duration of the infringement, in relation to the infringement of Article 5.1.f) (Article 83.2.a GDPR)

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
97/128

Telefónica does not agree with the application of this aggravating factor, reiterating that the loss of confidentiality is the result of a crime committed by a third party and that this falls outside the scope of Telefónica's liability. Furthermore, it indicates that the incident has not resulted in any irreparable loss of control over the personal data of customers, taking into account the category of affected data and the possible risks to them.

In this regard, it is appropriate to refer to all the arguments made throughout this Legal Basis regarding

both the liability, and therefore, the culpability, required of Telefónica, which does not derive from the fraudulent actions of a third party, but from its own actions and responsibilities concerning compliance with the GDPR, especially regarding security measures.

Regarding the disagreement with the consideration that the number of affected individuals was very high, Telefónica argues that the data obtained does not allow a third party to identify said individual, as it pertains to data that is only used for the support and maintenance of Telefónica's router. Additionally, Telefónica reiterates that even the fixed telephone number was not obtained, as the attackers already had that information; they were already aware of it.

In this respect, regarding the assertion that the data accessed by the attackers is not personal data, it is appropriate to refer to all that has already been argued in this Proposal for Resolution on this matter. In relation to the attackers already knowing and having in their possession the personal data of the fixed telephone number, it is noted that, analyzing the *modus operandi* of the attack, the reality is that the attackers randomly or sequentially entered telephone numbers that, when matched with a subscribed number of a Telefónica customer, allowed them to access the rest of the personal data stored in the application. It cannot be deduced, as Telefónica indicates, that the attackers already knew and had the personal data of the fixed telephone number; rather, what can be deduced is that they applied sequential or random numbers without knowing if they corresponded to a subscriber, but when they managed to match it with that of a subscriber, they indeed obtained the fixed telephone number of a customer of the company and, consequently, the personal data that it entails. Evidence of this is also the fact that out of approximately 16 million queries (random or sequential telephone numbers used), they only managed to match and, therefore, obtain the numbers of just over 1,400,000 subscribed customers.

In this sense, it should not be forgotten that it was Telefónica who indicated, in its "Incident Report on Privacy Unauthorized Access to ***APP.1," submitted on 26/10/2022 along with the second notification of the personal data breach to the AEPD (Registration Number: REGAGE22e00048156613), that the malicious accesses occurred by making requests to Telefónica's internal applications using consecutive fixed telephone numbers to obtain those that were customer numbers of Telefónica, obtaining technical or configuration data of the Movistar equipment associated with the consulted fixed number.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
98/128

Telefónica also argues again that the category of the affected data was not sensitive data as defined in Article 9 and that they are not data whose loss of control could imply serious consequences for the data subjects.

In this regard, it is appropriate to refer again to what has already been argued previously about the risks that the knowledge of the fixed telephone number associated with configuration data, the name of the Wi-Fi, and its password pose for the affected individuals. These risks do not diminish by the fact that more than a year later, as Telefónica indicates, there has been no awareness of any type of publication or exploitation of this data by third parties, since what is taken into account in this aggravating circumstance is the damage and risk that the loss of confidentiality itself entails, which leads to a total loss of control over one's own personal data and the high risk that it may be used fraudulently, as it has been stolen by a cybercriminal.

9.2. Negligence in the infringement (Article 83.2.b) GDPR)

Telefónica rejects the application of this aggravating circumstance, arguing again that the AEPD erroneously concludes that, due to the occurrence of a security incident, there were no adequate measures in place, thus requiring an obligation of results (infallibility of the measures) and, consequently, objective liability, considering the existence of negligence due to the result caused by third parties outside Telefónica, again citing Judgment 543/2022 of February 15, 2022, from the Supreme Court.

In this sense, it is appropriate to reiterate everything previously argued regarding Telefónica's

negligence and responsibility concerning the lack of adequate measures that would have either prevented the attack or significantly mitigated it, highlighting the breach of the duty of care required by law, as well as everything argued regarding the fact that no obligation of result has been demanded in any way, analyzing the aforementioned Judgment.

9.3. Linkage of the infringer's activity with the processing of personal data

Telefónica reproaches the application of the circumstance of processing data of millions of people as an aggravating factor without taking into account the specific circumstances of what occurred.

Furthermore, it understands that it makes no sense and cannot be legally sustained that merely by processing a large volume of data, any infringement committed leads to the direct and objective application of aggravating circumstances.

In this regard, it is noted that this provision takes into account the linkage with the processing of personal data, as it involves mass and large-scale processing (of millions of customers), through software applications and web applications and continuously.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

99/128

In this regard, the Spanish legislator has considered including in Article 76 of the LOPDGDD that: “2. In accordance with the provisions of Article 83.2.k) of Regulation (EU) 2016/679, the following may also be taken into account:

(...)

b) The link between the infringer's activity and the processing of personal data.”

This Agency simply takes that circumstance, provided by the legislator, into account when deciding on the imposition of the administrative fine.

Regarding the mitigating factors that Telefónica believes should have been considered:

9.4. The intent or negligence in the infringement (art. 83.2.b GDPR)

Telefónica argues that since the requirements of intent in the commission of the infringements or a negligent attitude do not apply in this case, but rather the diligence demonstrated by it, this should be taken into account as a mitigating factor.

In response, two points should be noted. First, it has been argued throughout this Proposal for Resolution that, while there has been no intent, there has indeed been negligent conduct on the part of Telefónica. It should be noted that “non-intentional” means that there was no intention to cause the infringement, but it did fail to comply with the duty of care required by law.

Secondly, this circumstance, established in paragraph b) of Article 83.2 of the GDPR, can only, in its case, operate as an aggravating circumstance, since the absence of intent and negligence would directly imply the absence of culpability.

At this point, it should be clarified that one thing is that, in order to attribute an administrative infringement, the existence of intent or negligence is necessary, and another is that the existence of a particularly highlighted negligence, due to the circumstances of the case, can be used as an aggravating factor. The opposite would be contrary to Article 83.2.b) itself, which establishes that “When deciding on the imposition of an administrative fine and its amount in each individual case, the following shall be duly taken into account:

b) the intent or negligence in the infringement.”

Thus, as noted, in any infringement of data protection regulations, the existence of intent or negligence must be present. This applies to both a natural person responsible for processing and a legal entity, whether it is a small business with little connection to the processing of personal data, or a large company, a multinational, etc., with continuous and large-scale processing of personal data, for example.

Therefore, once it has been determined that, as a premise, this subjective culpability element is present, this does not prevent this circumstance from being considered as an aggravating factor, as it is deemed that, in accordance with the specific circumstances of the case, a different degree of intent

or negligence in the conduct of the infringing party may be considered. However, in no case can this circumstance be considered as a mitigating factor in the sense argued by Telefónica, as this would imply, as stated, a contradiction.

9.5. Any measures taken by the data controller or processor to mitigate the damage and harm suffered by the data subjects (Article 83.2.c)

Telefónica claims that it proceeded to inform all affected parties about what happened, indicating the measures they should adopt.

In this regard, it should be noted that communicating a personal data breach in the case of a probable high risk to the rights and freedoms of the affected individuals is an obligation imposed by the GDPR in its Article 34, the infringement of which is subject to further sanctioning procedures.

Furthermore, it should be recalled that Telefónica did not voluntarily communicate the personal data breach to the affected parties, but rather communicated to all affected parties as an obligation imposed by this Agency through the Resolution of September 30, 2022, which ordered it to carry out the communication of the personal data breach to the data subjects in accordance with Article 34 of the Regulation, due to Telefónica's refusal to do so.

For the reasons stated, this circumstance should not be considered as a mitigating factor regarding the liability incurred.

9.6. The categories of personal data affected by the infringement (art. 83.2.g) GDPR)

Telefónica argues that since no special categories of personal data as defined in Article 9 of the GDPR have been affected, and that only configuration data of some connectivity devices were involved, which do not allow for the direct identification of the data subject, this circumstance should be applied as a mitigating factor.

In response, it is noted that Article 83.2.g) indicates as a circumstance for grading the sanction "The categories of personal data affected by the infringement," thus being a circumstance to be taken into account based on the type or category of the affected data, which would apply as an aggravating factor, for example, if special categories of data have been affected, but it is not limited solely to special categories of data, as it can also be applied as an aggravating factor depending on the type of data affected.

In the present case, taking into account the nature of the personal data affected by the breach (the risk of which is much greater and is disregarded by Telefónica) and the considerable number of individuals affected by it, with the probable high risk of fraudulent use and the high risk to the rights and freedoms of the affected individuals, it should not be considered in any case as a mitigating factor.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

101/128

9.7. The manner in which the supervisory authority became aware of the infringement, in particular whether the controller or the processor notified the infringement and, if so, to what extent. (art. 83.2.h GDPR)

Telefónica claims that it was the one that informed the AEPD of the existence of this incident within the legally established timeframe.

In this regard, it should be noted that this cannot be considered a mitigating factor since notifying this Agency of the existence of a personal data breach without undue delay is mandatory in accordance with the provisions of Article 33 of the GDPR. The consideration of the notification to the Agency of the breach as a mitigating factor, as Telefónica intends, is not linked to any of the cases in which there may be an obligation by virtue of a legal mandate, when the actions are due and required by law, as in the case at hand.

9.8. Financial benefits obtained or losses avoided directly or indirectly through the infringement.

Telefónica argues that it did not obtain any financial benefit but was a victim of a crime that has caused it reputational damage.

In response, it should be noted that, regarding this criterion, Article 76.2 of the LOPDGDD, in its letter c), includes among the criteria that must be weighed when determining the amount of the sanction "the

benefits obtained as a result of the commission of the infringement” and not the absence of these benefits. The Judgment of the National Court, dated 05/05/2021, refers to the need for the “fact” requirement contemplated in the regulation to be met in order for a specific grading criterion to be applied, and, as mentioned, the absence of benefits is not among the circumstances regulated in the cited article.

This grading criterion is established in the LOPDGDD in accordance with the provisions of Article 83.2.k) of the GDPR, according to which administrative fines shall be imposed taking into account any “aggravating or mitigating factor applicable to the circumstances of the case, such as the financial benefits obtained or the losses avoided, directly or indirectly, through the infringement,” understanding that avoiding a loss has the same nature for these purposes as obtaining benefits.

If we add to this that the sanctions must be “effective, proportionate and dissuasive in each individual case,” in accordance with the provisions of Article 83.1 of the GDPR, admitting the absence of benefits as a mitigating factor is not only contrary to the factual premises contemplated in Article 76.2.c), but also contrary to the provisions of Article 83.2.k) of the GDPR and the principles outlined. Thus, valuing the absence of benefits as a mitigating factor would nullify the deterrent effect of the fine, as it diminishes the effect of the circumstances that effectively impact its quantification, providing the responsible party with a benefit to which they are not entitled. It would be an artificial reduction of the sanction that could lead to the understanding that violating the regulation without obtaining benefits, financial or otherwise, would not produce a negative effect proportional to the seriousness of the infringing act. In any case, the administrative fines established in the GDPR, in accordance with the provisions of...

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
102/128

Established in its article 83.2, sanctions are imposed based on the circumstances of each individual case and, in the present case, the absence of benefits is not considered an adequate and determining factor for assessing the severity of the infringing conduct.

As a general and final consideration, it should be noted that none of the sanctions imposed violate the principle of proportionality. Thus, it should be recalled that articles 83.4 and 83.5 of the GDPR, where the infringement of article 32 and that of article 5.1.f) are respectively classified, establish limits on the amounts of fines that can be imposed which are far removed from those that have ultimately been established.

Thus, article 83.4 of the aforementioned Regulation establishes that they will be sanctioned, in accordance with paragraph 2, with administrative fines of up to 10,000,000 EUR or, in the case of a company, an amount equivalent to a maximum of 2% of the total annual global turnover of the previous financial year, opting for the higher amount. In this regard, according to the report collected from the AXESOR tool, the turnover for 2021 of Telefónica was ***CANTIDAD.1 euros, which would have allowed for a sanction of up to ***CANTIDAD.2 euros for the infringement of article 32.

For its part, article 83.5 of the GDPR establishes that they will be sanctioned, in accordance with paragraph 2, with administrative fines of up to 20,000,000 EUR or, in the case of a company, an amount equivalent to a maximum of 4% of the total annual global turnover of the previous financial year, opting for the higher amount. In this regard, according to the indicated turnover, it would have allowed for a sanction of up to ***CANTIDAD.3 euros for the infringement of article 5.1.f).

Therefore, taking into account the above, as well as Telefónica's negligence in not having implemented adequate access control measures to an application published on the internet (two-factor verification; blocking access from suspicious or untrusted IP addresses), as well as measures aimed at generating alerts and blocks in the face of completely anomalous situations, with no alerts or security events generated, with immediate warning to CSIRT-TE that massive requests were occurring for 4 days that were significantly higher than usual (from 55,000 per day to 4 million daily) and also from a single user, which reflects a clear anomalous and suspicious behavior of being malicious. Likewise, the attack suffered between September 9 and 11, 2022, which affected personal data of more than half

a million Telefónica customers, was also not detected.

Therefore, it cannot be said that the sanctions ultimately imposed violate the principle of proportionality, considering that “Each supervisory authority shall ensure that the imposition of administrative fines under this article for the infringements of this Regulation indicated in paragraphs 4, 5, and 6 are in each individual case effective, proportionate, and dissuasive.” (the underlining is ours)

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

103/128

V. Allegations to the resolution proposal

In response to the allegations presented by Telefónica, it should be noted, in the order presented, the following:

Before addressing the allegations against the resolution proposal, it is indicated that, given the reiteration in the arguments presented regarding those raised against the initiation agreement and in order not to repeat them, the same are considered reproduced.

Preliminary. On the continuation of the present sanctioning file.

In relation to this allegation, it is reiterated that, as has been indicated throughout the entire procedure, compliance with the regulations on data protection is not considered to have been met. It is not true that the data affected in the incident subject to this file do not have the character of personal data. It seems necessary to state again that the very definition of personal data given in Article 4 of the GDPR includes all information about an identified or identifiable natural person ("the data subject"); a natural person is considered identifiable if their identity can be determined, directly or indirectly, in particular by means of an identifier, such as a name, an identification number, location data, an online identifier, or one or more elements specific to the physical, physiological, genetic, mental, economic, cultural, or social identity of that person.

It follows that the concept of personal data requires the concurrence of a double element: on the one hand, the existence of information or data, and on the other, that such data can be linked to an identified or identifiable natural person.

There is no doubt, therefore, about the personal data nature of the fixed telephone number that allows identifying its holder or the other data that were affected in this breach that also allow identifying them. Furthermore, it is emphasized that, given that the attack carried out using consecutive (or random) fixed telephone numbers involved more than 16 million requests, of which access was gained to the personal data of 1,407,257 customers when the fixed telephone number matched that of a Telefónica customer, it only highlights that the attacker did not previously know those fixed telephone numbers. However, to elaborate further, in light of what happened, it is not relevant whether the attacker previously knew the fixed telephone numbers of Telefónica customers, nor how the specific attack occurred in terms of how the queries were made and the data to which the attacker could not access, or if, as Telefónica claims, it was very sophisticated and had prior knowledge of employee data, etc. What is relevant is that with the credentials of a single Telefónica employee (username and password), who, it should be noted, was on vacation, massive queries were made to the affected application (increasing from 50,000 daily queries to 4 million daily queries by a single user), from Lithuania, ultimately obtaining personal data of more than 1,400,000 customers, which could have been prevented with the existence of some technological alternative that would have impeded it, such as a two-factor verification for Telefónica employee users.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

104/128

also any other measure that would act in response to massive information requests, that would detect completely unusual and extraordinary information flows, which would have allowed or at least significantly mitigated the impact of the same if there had been control and monitoring measures that

would have detected and alerted to the attack in a timely manner, as will be indicated in more detail later.

On the other hand, and in relation to the claims made by Telefónica regarding which the AEPD has not taken into account the existing measures at the time the breach occurred, but rather considers as valid only those suggested by it in the resolution proposal, it must be clarified that this is not the intention of this Agency. What has been reflected throughout the procedure is that the measures that Telefónica had did not guarantee either the principle of integrity and confidentiality provided for in art. 5.1.f) of the GDPR nor did they guarantee an adequate level of security, proceeding to cite different examples of measures that could have contributed to achieving that level. In this regard, it seems necessary to specify that at no time has this Agency determined the opportunity to arbitrarily block access from a foreign IP, but rather what has been suggested is the establishment of systems that would allow for effectively blocking potentially insecure connections by denying, by default, incoming traffic for those origins that were not necessary for the provision of the entity's services. To this is added the fact that, even though it claims that it needs access to its networks from foreign IPs because either its employees or subcontracted companies need to make use of it, at no time is this necessity proven in relation to the country from which the incident originated beyond the mere generic assertion regarding non-national territories.

First. Clarification regarding the description of proven facts made by the AEPD.

Regarding the first of the claims made about the date of the incident, the assertions made in the initiation proposal and recorded in the proven facts are reiterated. And this is because, as stated in the file, on September 16, 2022, there was already a massive increase in queries that was not detected and corrected until the 20th, as Telefónica itself acknowledges. Consequently, four days elapsed from the occurrence of the first incident until measures began to be implemented.

Second. From the incident in ***APP.1 and the security measures: Telefónica contemplates technical and organizational measures that are appropriate to ensure an adequate security of the personal data of its clients, including protection against unauthorized or unlawful processing.

In this regard, what has already been indicated throughout the sanctioning procedure is reiterated. To the above, it should be added that it is clear that, according to data protection regulations, the data controller is obliged to process personal data in such a way as to guarantee the principle of integrity and confidentiality provided for in Article 5.1.f) of the GDPR, "including protection against unauthorized or unlawful processing and against its loss, destruction or accidental damage," through the application of measures.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

105/128

appropriate technical and organizational measures. This guarantee imposed by the legal framework must be achieved through the application of appropriate technical or organizational measures of all kinds. They are not strictly or solely security measures. There are various and multiple technical and organizational measures that are not security-related and that the data controller can implement as a means to ensure this principle. Thus, it has been previously mentioned, by way of example, the "non-security" measure consisting of raising awareness and training employees in data protection matters.

Compliance with obligations regarding data protection requires that the data controller focuses on the risks to the rights and freedoms of the data subjects that the processing of personal data may entail, identifying, assessing, and evaluating them for the purpose of determining appropriate technical and organizational measures of all kinds (not only security measures) to prevent such risks, which are often very serious, irreparable, and irreversible, from materializing into harm for the data subjects. In many cases, strict information security measures (only concerning information) confront appropriate technical and organizational measures of all kinds, including specific security measures for data protection, to the extent that the application of one may clash with the other.

For example, this confrontation may occur within the framework of the National Security Scheme

(ENS), regulated by Royal Decree 311/2022. Let us recall that, to justify a correct risk analysis regarding the examined case and the corresponding adoption of adequate security measures in data protection, Telefónica cites compliance with, among other certifications, the ENS.

Well, the ENS aims at information security, as provided in Article 1.2 of the aforementioned Royal Decree, and not at the protection of personal data.

On the other hand, it is only applicable to private entities, such as Telefónica, insofar as, as determined in its Article 2.3, "... when, in accordance with the applicable regulations and by virtue of a contractual relationship, they provide services or solutions to public sector entities for the exercise of their competencies and administrative powers."

Moreover, in such cases specified by the legal framework - a private sector entity that maintains a contractual relationship with a public sector entity providing a service or solution - compliance with the ENS is not generic or general, but its provisions must be fulfilled for specific personal data processing, corresponding the security measures to those of the public sector entity in question and in accordance with the ENS. This is because the first additional provision of the LOPDGDD establishes: "First additional provision. Security measures in the public sector... In cases where a third party provides a service under a concession, management assignment, or contract, the security measures shall correspond to those of the originating public administration and shall comply with the National Security Scheme."

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

106/128

In addition to the above, as we previously indicated, compliance with the ENS does not imply compliance with the GDPR, since (i) compliance with the ENS does not exempt compliance with the (different) obligations regarding data protection and (ii) the measures resulting from the ENS may conflict with those of the GDPR (with the latter prevailing), as evidenced in Article 3 of the aforementioned Royal Decree:

"Article 3. Information systems that process personal data.

1. When an information system processes personal data, the provisions of Regulation (EU) 2016/679 of the European Parliament and of the Council, of April 27, 2016, regarding the protection of natural persons with regard to the processing of personal data and the free movement of such data, which repeals Directive 95/46/EC (General Data Protection Regulation), and in Organic Law 3/2018, of December 5, on the Protection of Personal Data and the guarantee of digital rights, or, where applicable, Organic Law 7/2021, of May 26, on the protection of personal data processed for the purposes of prevention, detection, investigation, and prosecution of criminal offenses and the execution of criminal sanctions, the remaining applicable regulations, as well as the criteria established by the Spanish Data Protection Agency or, within its competence, by the autonomous data protection authorities, without prejudice to the requirements established in this royal decree, shall apply.
2. In these cases, the data controller or the data processor, advised by the data protection officer, shall conduct a risk analysis in accordance with Article 24 of the General Data Protection Regulation and, in the cases referred to in Article 35, a data protection impact assessment.
3. In any case, the measures to be implemented as a result of the risk analysis and, where applicable, the impact assessment referred to in the previous section shall prevail if they are more stringent than those provided for in this royal decree."

Without detracting from the importance that information security measures represent for a company considering the risks of its organization (protecting its assets, avoiding loss of information related to industrial property or trade secrets, or claims for damages, etc.), we cannot overlook that the appropriate technical and organizational measures of all types of data protection respond to the protection of natural persons and the fundamental right to data protection of which they are holders. Without the proper focus, as has been made evident throughout this procedure, it is impossible to detect the risks actually foreseen in the processing of personal data, since what is not looked at cannot be seen.

Telefónica claims that the loss of control of information by the system does not generate a high risk for the rights and freedoms of users without taking into account that any loss of control over one's own personal data necessarily translates into a violation of the fundamental right to data protection recognized in Article 18.4 of the Spanish Constitution, since, as indicated by the Constitutional Court (Judgment 292/2000, of November 30, 2000): "the fundamental right to data protection aims to guarantee to the individual a...

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
107/128

power of control over their personal data, over its use and destination, with the purpose of preventing its illicit trafficking and harm to the dignity and rights of the affected party (...)", since the right to data protection guarantees individuals a power of disposal over that data, which can only be in the hands of persons authorized by some lawful basis provided in the data protection regulations. It is emphasized that knowing a phone number generates a series of risks, such as its use to call its owner or contact them via SMS, etc., and through phishing or social engineering to obtain more identifying data (address) and, additionally, having the Wi-Fi name and passwords, to access it and impersonate identity, using it for fraud, computer scams, etc. Let us imagine if the Wi-Fi and password correspond not to an anonymous person, but to an important personality in the country. It is completely unknown what information or data the criminal was "seeking" and what other data they had in their possession; however, these issues must also be considered in the risk analysis, regardless of the categorization of the risk.

Even in the event that, as Telefónica claims, it could be accepted that the probability of accessing the Wi-Fi of customer users is low, the impact of this is very high on the rights and freedoms of individuals: identity theft, commission of crimes through that Wi-Fi that would be attributed to the line holder, hacking of devices connected to that Wi-Fi and obtaining data such as health information, routines, consumption, etc., so the final risk cannot be considered low.

Thus, at first glance and without great effort, the presence, for example, of a risk regarding the fundamental right to the secrecy of communications is observed, which has neither been identified nor analyzed.

Third. Overcoming the sphere of responsibility of Telefónica: exceptional circumstances that have made it possible for third parties to surpass the security policies implemented.

In this regard, and since no new arguments have been provided to those already addressed in the proposal, it is reiterated what has already been indicated in response to the allegations presented against the initiation agreement.

Fourth. Regarding the preliminary issues raised by the AEPD within the framework of this file.

In its fourth allegation, Telefónica dismisses the applicability of Opinion 13/2011 to which this Agency referred in the proposal as it pertains to geolocation on mobile devices without taking into account that, even though in this case the affected information essentially referred to geolocation services on smart mobile devices, as they indicate, it is concluded without a doubt that the nature of personal data must include information related to the MAC address since it makes the physical person identifiable.

On the other hand, the excerpt highlighted by the infringing party from the Order issued by the Court is surprising because, as you must know, the fact that no criminal charge is brought due to the lack of requirements for it, specifically in this case, the existence of a prior complaint to be able to charge a subject with a crime.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
108/128

Disclosure of secrets does not necessarily imply the non-existence of an administrative breach.

Fifth. Regarding the alleged infringements committed by Telefónica: violation of the principle of legality.

Again, and in order not to repeat oneself, it is reiterated what has already been stated in this regard in the resolution proposal.

In relation to the inapplicability of the provisions of Article 5.1.f) to the case at hand, it seems necessary to clarify once again both its wording and its applicability. What Article 5.1.f) of the Regulation establishes is a principle whereby the controller of any processing of personal data is obliged, as a guarantee, to prevent unauthorized or unlawful processing of such data, as well as their loss or destruction. In other words, a data controller must not process personal data unless they are in a position to guarantee the confidentiality and integrity of such data and to prevent a third party from accessing data that does not concern them, as well as to avoid their loss or destruction.

By virtue of the above, the data controller is obliged to process personal data in such a way as to ensure adequate security, "including protection against unauthorized or unlawful processing and against their loss, destruction, or accidental damage, through the application of appropriate technical or organizational measures."

Unauthorized access to personal data by a third party means that such data may be used for unknown, even fraudulent, purposes, resulting in a total and absolute loss of control over them.

This loss of control over one's own personal data, it is emphasized, constitutes a violation of the fundamental right to data protection recognized in Article 18.4 of the Spanish Constitution, since, as indicated by the Constitutional Court (Judgment 292/2000, of November 30, 2000): "the fundamental right to data protection aims to guarantee individuals a power of control over their personal data, over its use and destination, in order to prevent its unlawful trafficking and harm to the dignity and rights of the affected party (...)", given that the right to data protection guarantees individuals a power of disposition over such data, which can only be in the hands of persons authorized by some lawful basis provided for in the data protection regulations.

Furthermore, the loss or destruction of personal data can also cause harm to the interested party, such as the lack of provision of a service (consider a healthcare service) or the incorrect provision of such service (if not all personal data of the interested party is available).

Regarding the potential consequences of a loss of confidentiality and integrity, reference should be made to those contained in Opinion 03/2014 on the notification of personal data breaches by the Article 29 Working Party.

The guarantee imposed by the legal system will be achieved through the application of appropriate technical or organizational measures of all kinds. They are not strictly or...

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
109/128

only security measures. There are various and multiple technical and organizational measures that are not security-related and that the data controller can implement as a means to guarantee this principle. In this regard, the aforementioned AEPD Guide on "Risk Management and Impact Assessment in Personal Data Processing" states that, "As interpreted by Declaration WP218, it should be emphasized that addressing the risks that may arise from data processing for the rights and freedoms of individuals cannot be limited to applying exclusively security measures. Therefore, the management of security risks is just one of the activities for managing risks to rights and freedoms and must be subordinated to the latter. Furthermore, from the perspective of the GDPR, mitigation measures must be aimed at reducing the impact and the likelihood that personal data breaches affect the data subject."

If only security measures were considered in relation to Article 5.1(f) of the GDPR, it would be tantamount to simplifying the essence of the GDPR, whose compliance is not limited to the implementation of technical and organizational security measures; it would mean, in our case, reducing the guarantee required by the principle of integrity and confidentiality to its achievement solely through security measures. Of course, the appropriate technical or organizational measures referred to in Article 5.1(f) of the GDPR can be security measures, but not exclusively.

A violation of this provision, a loss of confidentiality or integrity, can occur without the absence or

deficiency of security measures.

The appropriate technical and organizational measures of all kinds that must be applied to guarantee the principle of integrity and confidentiality in the terms of Article 5.1(f) of the GDPR are not cited by Telefónica in relation to the personal data breach, neither in its allegations nor in the documentation provided throughout the sanctioning procedure. The risk analysis carried out by Telefónica, as evidenced in its allegations, focuses on risks to information security related to the organization and not on the risks to the rights and freedoms of data subjects arising from personal data processing.

With the incorrect risk approach that is not focused on the rights and freedoms of data subjects, it will be difficult to identify, assess, and evaluate the risks of processing, from which it will be determined what specific technical and organizational measures of all kinds should be implemented in the organization to prevent the loss of integrity and confidentiality of personal data.

All the measures referred to by Telefónica in its defense are security measures, specifically, moreover, information security measures (risk approach in the organization). However, there are multiple appropriate technical and organizational measures that, in consideration of the risks to the rights and freedoms present in personal data processing, an organization can implement that are not security-related (nor information security-related), through which the data controller can guarantee the principle of integrity and confidentiality.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

110/128

For example, we will cite a generic one (since we do not have a risk analysis prepared by Telefónica in the terms of Article 5.1.f) of the GDPR) applicable to any data controller, which is related to the awareness and training of employees in data protection matters, which is not solely about security.

Telefónica has also not subsequently mentioned appropriate technical and organizational measures that it has implemented in relation to Article 5.1.f) of the GDPR that are not strictly security-related.

Therefore, it cannot be agreed with the statements made by Telefónica regarding the non-violation of the provisions of Article 5.1.f) since the loss of confidentiality is clear in the matter at hand.

On the other hand, regarding the necessity that there were no technical and organizational security measures, it should be noted that, for a violation of Article 32 of the GDPR to occur, the data controller must not have established adequate security measures commensurate with the level of risk in relation to a specific processing operation, including not only cases of failure to implement security measures but also those cases where the security measures are breached (failure of the security measures).

In this regard, the Supreme Court ruling of February 15, 2022 (Rec. 7359/2020) indicates that “It is not enough to design the necessary technical and organizational means; their correct implementation and appropriate use are also necessary, so that they will also be liable for the lack of diligence in their use, understood as reasonable diligence considering the circumstances of the case.”

In the present case, it is emphasized that it is not a matter of the absence of security measures, but rather that these were not adequate to ensure a level of security appropriate to the risk, taking into account the nature, scope, context, and purposes of the processing, as well as the variable probability and severity risks to the rights and freedoms of individuals. As already stated in the proposal, there were not sufficient measures to ensure security, citing possible examples such as the establishment of a two-factor verification for access to the personal data collected in the application ***APP.1 or the possibility of blocking users in the event of mass access within a short period of time, or measures aimed at monitoring operations and generating security events automatically.

It cannot be forgotten that Telefónica did not detect any of those mass queries that generated extraordinary traffic (from 55,000 daily queries to 4 million per day by a single user (which is also totally exceptional) who was on vacation and from Lithuania) and that should have triggered all alarms (if they had existed) during the attack that occurred between September 9 and 11, 2022, nor were there any alerts or early warnings generated in the attack suffered between September 16 and 20 that would have allowed it to immediately undertake measures aimed at mitigating the attack (for example, blocking the compromised user(s); blocking the foreign IP from which the attack was being carried out)

and thus significantly mitigate the impact of the attack, in which, ultimately, the confidentiality of the personal data of more than...

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
111/128

1,400,000 people. Even a simple measure, perfectly within the reach of Telefónica, such as

***MEASURE.2 would have prevented the breach of personal data that occurred.

Regarding a supposed attribution of objective liability, it should be clarified that this is not imposed by the GDPR and consequently is not required by the AEPD.

The obligation of confidentiality that Article 5.1(f) of the GDPR imposes on the data controller is an obligation of result, such that for the provision to be considered violated, the confidentiality of the data must be breached (injury to a protected legal right). This is in contrast to the security obligation imposed on the data controller by Article 32 of the GDPR. However, in neither case is liability objective. As specified in the Supreme Court ruling of 15/02/2022 (rec. of cassation 7359/2020), "In obligations of means, the commitment undertaken is to adopt the technical and organizational means, as well as to deploy diligent activity in their implementation and use, aimed at achieving the expected result with means that can reasonably be classified as suitable and sufficient for its achievement; hence they are referred to as 'obligations of diligence' or 'behavioral obligations.'" (The emphasis is ours)

As has been evidenced and argued throughout this sanctioning procedure, Telefónica (i) did not have appropriate technical and organizational measures to guarantee the principle of integrity and confidentiality in the terms of Article 5.1(f) of the GDPR, that is, that personal data were processed in such a way as to ensure security, including protection against unauthorized or unlawful processing and against accidental loss, destruction, or damage, and (ii) did not have appropriate technical and organizational measures that guaranteed an adequate level of security relative to the risk, taking into account the nature, scope, context, and purposes of the processing, as well as the variable probability and severity risks to the rights and freedoms of natural persons, as prescribed by Article 32 of the GDPR.

It should be emphasized that there were no strictly security-related technical and organizational measures in place as required by Article 32 of the GDPR, resulting in a violation of this provision independently and prior to the occurrence of the personal data breach.

In this regard, this Agency wishes to point out that it does not consider that the obligation to implement technical and organizational measures of all kinds, including security measures imposed by data protection regulations, has a nature of an obligation of result rather than means. However, it is equally true that Telefónica did not have appropriate measures in place, as previously stated, before the incident occurred.

On the other hand, regarding the claims made about the drafting of the applicable regulations and its insistence, it is reiterated what has already been said in the response to your allegations given in the proposed resolution. Additionally, it should be noted that, in any case,

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
112/128

It has been the Community legislator who has included indeterminate legal concepts in the regulation, and not the AEPD, so any potential legal uncertainty regarding the wording of the GDPR must be attributed to them and not to the AEPD.

This does not prevent the fact that, even though the concepts included in the provisions that have been considered infringed in the present case may initially appear to have some indeterminacy and a certain margin of appreciation, a reasonable interpretation of the regulation and assessment can be made, especially when such interpretation is carried out by the AEPD with proper justification.

The original interpretation, which, by the way, corresponded to Telefónica, who, as the data controller,

was obliged to comply with the GDPR by integrating the indeterminate legal concepts of the same into the reality of its personal data processing, taking into account the risks to the rights and freedoms of the data subjects present in them and determining and implementing appropriate measures of all kinds to prevent their materialization.

And this considering both the principle of proactive responsibility, to which it is obliged by virtue of Article 5.2 of the GDPR, and the risk-based approach.

Thus, proactive responsibility implies the implementation of a compliance and management model for the GDPR that determines the widespread compliance with obligations regarding data protection. It includes the analysis, planning, establishment, maintenance, updating, and control of data protection policies in an organization, especially if it is a large company—understood as the set of guidelines that govern the actions of an organization, practices, procedures, and tools, among others— from privacy by design and by default, which ensure compliance with the GDPR, prevent the materialization of risks, and allow the controller to demonstrate its compliance.

It pivots on the management of risk to the rights and freedoms of data subjects regarding the processing of personal data carried out by a data controller.

As the AEPD has repeatedly pointed out (Report 17/2019, among many others) and is included in the Explanatory Memorandum of the LOPDGGD: “the greatest novelty presented by Regulation (EU) 2016/679 is the evolution from a model based fundamentally on compliance control to one that rests on the principle of active responsibility, which requires a prior assessment by the controller or the processor of the risk that the processing of personal data may generate, in order to adopt the appropriate measures based on that assessment.”

In this way, truly understanding what the GDPR is and implies, in a risk management system, it is logical that the regulation encompasses indeterminate legal concepts that may respond to the multiplicity of data controllers that may exist (with their own idiosyncrasies) and personal data processing that may be carried out; indeterminate legal concepts that imply greater flexibility for the data controller (with the ultimate aim of protecting natural persons) who must exercise due diligence.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

113/128

integrating said indeterminate legal concepts into their reality in the fulfillment of their obligations regarding data protection.

Furthermore, regarding the typification of the GDPR, it should be noted that as determined by the Opinion of the Council of State dated October 26, 2017, concerning the Draft Organic Law on the Protection of Personal Data, “The European Regulation does indeed typify, albeit in a generic sense, the behaviors constituting an infringement: indeed, paragraphs 4, 5, and 6 of its article 83, transcribed above, contain a catalog of infringements for violations of the provisions of the European norm indicated in such paragraphs.”

The AEPD has exercised its sanctioning power concerning behaviors that fall within the norms that typify them, as imposed, among others, by STC 151/1997, of September 29.

The facts established in the administrative file fit perfectly within the elements of the type provided in article 83.5 of the GDPR, with the AEPD merely integrating the facts into it without any type of arbitrariness, which has also not been demonstrated by Telefónica.

Thus, in the case at hand, once the specific circumstances of the case were analyzed, it was possible to determine without incurring in any type of arbitrary valuation or interpretation the lack of adequate technical and organizational measures of all kinds, including security measures to guarantee, on one hand, the principle of integrity and confidentiality, and on the other, an appropriate level of security relative to the risk of the personal data processing carried out by Telefónica (as it lacked adequate and reasonable security measures concerning the available technology and implementation costs at the time of the incident, which would have prevented, if not minimized or significantly mitigated, the impact of the incident on personal data).

Sixth. Telefónica's conduct is not unlawful.

Once again, Telefónica reiterates what was alleged against the initiation agreement regarding the non-existence of unlawfulness in its conduct. In this regard, it insists that it has technical and organizational measures designed to ensure adequate security of personal data (certificates, protocols, and manuals that attest to security management, employee awareness measures, device protection, etc.) and multiple mechanisms to detect unauthorized access to personal data. Regarding these assertions, it is only necessary to reiterate what has already been transcribed throughout the procedure.

Seventh. Absence of culpability.

In its next allegation, it reiterates once again the arguments already presented regarding the non-existence of fault in its conduct. It insists that it has acted in good faith with all the required professional diligence, and that the circumstances that led to the facts subject to this file are attributable to third parties who acted in the commission of a crime.

Regarding the infringement of the principle of culpability, it should be noted that article 70 of Organic Law 3/2018, of December 5, on the Protection of Personal Data and the Guarantee of Digital Rights (LOPDPGDD) is applicable, according to which "1. They are...

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

114/128

subject to the sanctioning regime established in Regulation (EU) 2016/679 and in this organic law:

- a) The data controllers.
- b) The data processors.
- c) The representatives of the controllers or processors not established in the territory of the European Union.
- d) The certification bodies.
- e) The accredited entities supervising the codes of conduct.

For its part, Article 28 of Law 40/2015 states: "1. Only individuals and legal entities, as well as, when a law grants them legal capacity, the groups of affected parties, unions, and entities without legal personality, and independent or autonomous estates, may be sanctioned for acts constituting administrative infractions, provided they are responsible for them due to intent or negligence."

On the other hand, regarding the alleged good faith of Telefónica, it should be clarified that, while it is clear that intent or negligence must be present in the actions of the infringer, we cannot confuse these elements with the presence or absence of good faith, as the acting entity intends, because the voluntariness of the result of the action is not an essential constitutive element of the administrative infraction, but rather a factor of gradation, so that it maintains the necessary proportionality with the fact that motivates it, which links to the principle of proportionality whose infringement is also being claimed.

The Supreme Court (Contentious-Administrative Chamber, Section 5) in Judgment No. 179/2023, of February 15, 2023, establishes: Judgment (STS 354/2023)

(...) we must begin by recalling that culpability constitutes, indeed, a requirement of administrative infractions, inherent in Article 25 of the Constitution, which has undergone an elaborate doctrinal construction in the field of Criminal Law from which Administrative Sanctioning Law derives. This requirement entails, in brief summary for the purposes of the debate raised, that the act typified in the type of infraction can and must be attributable to the subject being sanctioned, who is considered guilty of it, that is, responsible, according to the terminology of the Common Administrative Procedure Law of Public Administrations. This attribution involves an intellectual element according to which the typical action is not only executed by the subject themselves, but is done consciously and willingly, that is, intentionally, or through more or less intense negligence, in that the diligence that would be required in the execution of the act to avoid the harmful effect has been omitted.

In this same sense, it is appropriate to refer to the Judgment of the Court of Justice of the European

Union, of December 5, 2023, in the case C-807/21 (Deutsche Wohnen), which indicates:

“76 In this regard, it should also be specified, concerning the question of whether an infraction has been committed intentionally or negligently and, therefore, can be sanctioned with an administrative fine under Article 83 of the GDPR, that a data controller can be sanctioned for behavior...

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

115/128

included within the scope of the GDPR when it could not ignore the infringing nature of its conduct, whether or not it was aware of violating the provisions of the GDPR (see, by analogy, the judgments of June 18, 2013, Schenker & Co. and others, C 681/11, EU:C:2013:404, paragraph 37 and cited case law; of March 25, 2021, Lundbeck/Commission, C 591/16 P, EU:C:2021:243, paragraph 156, and of March 25, 2021, Arrow Group and Arrow Generics/Commission, C 601/16 P, EU:C:2021:244, paragraph 97).” (the underlining is ours).

Eighth. Breach of the principle of proportionality.

Next, Telefónica reproduces almost literally the arguments made regarding what it considers a violation of the principle of proportionality in determining the sanctions, highlighting each of the aggravating circumstances present in each of the two infringements, as well as the mitigating circumstances that, in its opinion, should have been taken into account.

In response to the claimant's assertion, in which it considers that the amount of the imposed sanction, which exceeds the minimum amount, is not justified, it should be noted that this sanction falls within the margins that the law provides for this type of infringement, having taken into consideration the specific circumstances that apply in the present case for its individualization, which is necessary within the legally established margins. This adjustment of the sanction to the specific case not only does not violate the principle of proportionality but, as will be indicated below, is required to ensure proper compliance with it.

More specifically, it is stated in Judgment 10488/2010 of the High Court of Justice of Madrid (Contentious-Administrative Chamber, Section 6), dated April 22:

“After examining the correct legal assessment of the facts, and their perfect fit within the infringing type, it is alleged in the complaint a supposed lack of proportionality in the determination of the amount of the sanction, which cannot be appreciated in the present case.

Indeed, it must be noted that the minimum sanction that could be imposed was 6,010.12, and that the one imposed was for an amount of 6,100. That is to say, the proportionality of the sanction is demonstrated given the fact that the lack of authorization is unquestionable.

At this point, it should be indicated that for a sanction to be proportional, case law requires (e.g., Supreme Court Judgments of December 16, 1994, and September 30, 1995) two requirements, which can be summarized as the administrative activity adequately weighing the concurrent circumstances and that the sanction is imposed within the limits established by the norm. If both requirements are met, the Administration has a margin of discretion to impose the sanction, limited only by what has been stated above, so if in the present case the CHT has carried out the indicated weighing, and the sanction is at half of the minimum limit, it can only be concluded that it is proportional.

It is due to this that the imposed sanction is legally justified, and the complaint should be dismissed.”

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

116/128

Thus, in the individualization of the sanction, the Administration enjoys a certain margin of discretion, with repeated jurisprudential doctrine on this matter, which determines that the judicial control of the proportionality criterion must focus on the analysis of the correctness of the chosen degree, minimum, medium, or maximum, in order to determine whether there is the necessary adequacy between the alleged facts and the required responsibility. The choice of the amount within each degree

corresponds to the Administration, which will discretionarily set the specific amount of the sanction, not subject to judicial control, unless a well-founded claim of arbitrariness in the administrative decision is made.

In the present sanctioning procedure, from the very Agreement of Initiation, the circumstances considered for the purpose of grading the indicated sanction have been made evident, circumstances that, it is worth noting, are included in Article 83.2 of the GDPR, and in Article 76.2 of the LOPDPGDD, so the administrative activity is far from being arbitrary. Thus, within the margins that the law grants it and referring to the criteria that it establishes, this Agency has analyzed the specific circumstances present in this case and determined the amount of the sanction to be imposed, thereby ensuring the necessary proportion between the alleged facts and the required responsibility, thus exposing and reasoning the criterion used for the specification or individualization of the indicated sanction.

Consequently, it is appropriate to dismiss this claim by the interested party, considering that the imposed sanction is adequate and proportional to the infringement committed, with its amount duly justified in accordance with the criteria provided in Article 83.2 of the GDPR, and in Article 76.2 of the LOPDPGDD.

VI Integrity and confidentiality

Article 5.1.f) "Principles relating to processing" of the GDPR establishes:

"1. Personal data shall be:

(...)

f) processed in such a way as to ensure an adequate security of personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction or damage, by means of appropriate technical or organizational measures ('integrity and confidentiality')."

The principle of integrity and confidentiality imposes on the data controller the obligation to guarantee the integrity and confidentiality of personal data by preventing the alteration of personal data, its loss, unauthorized or unlawful processing or access through appropriate technical and organizational measures. The existence of this fundamental right is not possible if confidentiality, integrity, and availability of personal data are not guaranteed.

Hence, the integrity and confidentiality of personal data are considered essential to prevent data subjects from suffering negative effects. Therefore, they must be processed in a manner that ensures adequate integrity and confidentiality of

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

117/128

personal data, especially to prevent unauthorized access, processing, or use of such data.

Ultimately, it is the data controller who has the obligation to integrate the necessary guarantees into the processing, in order to comply with and be able to demonstrate compliance, in accordance with the principle of proactive responsibility, while respecting the fundamental right to data protection.

In this regard, it should be noted that the confidentiality of personal data is regulated in Article 5 of the GDPR, being, therefore, one of the principles related to processing. The principles related to processing are, on one hand, the starting point and the closing clause of the legal framework for data protection, constituting true guiding rules of the system with intense expansive force; on the other hand, having a high level of specificity, they are mandatory norms that can be infringed.

Therefore, the principle of confidentiality must inform all aspects, rights, and obligations involved in the processing of personal data. This is so because the breach of confidentiality leads to the loss of control over the data for its holders, which can pose serious risks to their rights and freedoms.

Article 5.1(f) of the GDPR establishes a clear obligation of compliance consisting of preventing unauthorized or unlawful processing by implementing appropriate security measures. Consequently, data controllers must be able to guarantee the confidentiality and integrity of personal data to prevent a third party from accessing data that does not belong to them, as it is precisely their responsibility to process personal data in accordance with the GDPR and LOPDPGDD. For this reason, the diligence exercised by them is fundamental to avoid such access.

In the present case, the principle of confidentiality has been violated as it is recorded that after suffering a cyberattack consisting of massive requests to the application ***APP.1 accessible from the employee portal ***PORTAL.1 of Telefónica, with public access from the internet through username and password, there was an illegitimate access to personal data, which resulted in the loss of confidentiality and control over several personal data: landline phone number; data of the equipment associated with the client (EDC): MAC Address, service VLANs; published names of wifi networks (SSIDs); encryption standard, the addressing ranges of the internal networks, and the passwords of the unencrypted wifi networks. This affected 1,407,257 individual clients of Telefónica.

The above constitutes a breach of the duty to guarantee the confidentiality of personal data, as indicated, Article 5.1(f) states that they must be processed in such a way as to ensure an adequate level of security of personal data, including protection against unauthorized or unlawful processing. This loss of control over one's own personal data translates into a violation of the fundamental right to data protection recognized in Article 18 of the Spanish Constitution, as indicated by the Constitutional Court.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
118/128

(Judgment 292/2000, of November 30, 2000) “the fundamental right to data protection seeks to guarantee individuals a power of control over their personal data, regarding its use and destination, with the purpose of preventing its illicit and harmful trafficking to the dignity and rights of the affected party (...) The right to data protection guarantees individuals a power of disposition over that data.” For all the above reasons and in accordance with the evidence available in this sanctioning procedure, it is considered that the known facts could constitute an infringement, attributable to Telefónica, for violation of Article 5.1.f) of the GDPR.

VII Qualification of the infringement of Article 5.1.f) of the GDPR

The aforementioned infringement of Article 5.1.f) of the GDPR constitutes the commission of the infringements classified in Article 83.5 of the GDPR, which under the heading “General conditions for the imposition of administrative fines” states:

“Violations of the following provisions shall be subject to administrative fines of up to 20,000,000 EUR or, in the case of an enterprise, an amount equivalent to a maximum of 4% of the total annual global turnover of the preceding financial year, opting for the higher amount:

a) the basic principles for processing, including the conditions for consent under Articles 5, 6, 7, and 9; (...)”

In this regard, the LOPDGDD, in its Article 71 “Infringements” establishes that “Acts and behaviors referred to in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679, as well as those that are contrary to this organic law, constitute infringements.”

For the purposes of the statute of limitations, Article 72 “Very serious infringements” of the LOPDGDD indicates:

“1. In accordance with what is established in Article 83.5 of Regulation (EU) 2016/679, the following shall be considered very serious and shall be subject to a three-year statute of limitations: infringements that constitute a substantial violation of the articles mentioned therein and, in particular, the following:

a) The processing of personal data in violation of the principles and guarantees established in Article 5 of Regulation (EU) 2016/679. (...)”

VII Sanction for the infringement of Article 5.1.f) of the GDPR

For the purpose of deciding on the imposition of an administrative fine and its amount, in accordance with the evidence available, it is appropriate to grade the sanction to be imposed according to the following criteria established in Article 83.2 of the GDPR:

As aggravating factors:

C/ Jorge Juan, 6

- Article 83.2.a) GDPR: Nature, severity, and duration of the infringement.

It is considered that the nature of the infringement is serious since it entails a loss of confidentiality and, therefore, of disposition and irremediable control over personal data.

Number of affected parties: The number of affected individuals is very large, as it amounts to more than one million customers of Telefónica: 1,407,257.

Level of damages suffered: High. Personal data was stolen (fixed phone number associated with technical data and configuration of the customer's equipment (MAC of the router; VLANs of the services; names of the published wifis: SSIDs; password of unencrypted wifi networks; addressing ranges of internal networks) and from a very considerable number of customers, thus losing all control over them, which poses a high risk of fraudulent use (identity theft, fraud, financial losses, access to other personal data through access to other connected devices of the customer to their wifi network, etc.), thus emptying the fundamental right to personal data protection of its content, which, as indicated by the Constitutional Court in the aforementioned Judgment, seeks to guarantee individuals a power of control and disposition over their personal data, regarding its use and destination, with the purpose of preventing its illicit and harmful trafficking to the dignity and rights of the affected party.

- Article 83.2.b) GDPR. Negligence in the infringement: There is evidence of negligence in fulfilling the obligation to ensure the necessary security for the protection of personal data, specifically to ensure the confidentiality of such data. In this regard, it should be noted that Telefónica is a large company that processes data on a large scale, affecting numerous individuals (millions of Telefónica customers), for which a higher level of diligence and appropriate security measures are required to ensure the confidentiality of the personal data it processes.

It is worth recalling, in this sense, the Judgment of the National Court of 10/17/2007 (rec. 63/2006), which regarding entities whose activity involves the continuous processing of customer data, states "...the Supreme Court has understood that there is recklessness whenever a legal duty of care is neglected, that is, when the offender does not behave with the required diligence. And in assessing the degree of diligence, the professionalism or lack thereof of the subject must be especially weighed, and there is no doubt that, in the case now examined, when the activity of the appellant involves constant and abundant handling of personal data, it is necessary to insist on the rigor and exquisite care to comply with the legal provisions in this regard.

Furthermore, it is considered appropriate to grade the sanction to be imposed according to the following criteria established in paragraph 2 of Article 76 "Sanctions and corrective measures" of the LOPDGDD:

As aggravating factors:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

- Article 76.2.b) LOPDGDD. Link between the infringer's activity and the processing of personal data:

The development of the business activity carried out by Telefónica involves continuous and large-scale processing of personal data, as it processes data from millions of people. Therefore, it is a large company accustomed to the processing of personal data.

In accordance with the available evidence and taking into account the circumstances of the case and the criteria established in Article 83.2 of the GDPR regarding the infringement committed by violating the provisions of Article 5.1.f) of the GDPR, a sanction of €800,000 (eight hundred thousand euros) is proposed.

IX Article 32 of the GDPR

Article 32 "Security of processing" of the GDPR states:

“1. Taking into account the state of the art, the costs of implementation, and the nature, scope, context, and purposes of the processing, as well as the risks of varying likelihood and severity for the rights and freedoms of natural persons, the controller and the processor shall implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk, which may include, among others:

- a) the pseudonymization and encryption of personal data;
- b) the ability to ensure the ongoing confidentiality, integrity, availability, and resilience of processing systems and services;
- c) the ability to restore the availability and access to personal data quickly in the event of a physical or technical incident;
- d) a process for regularly verifying, assessing, and evaluating the effectiveness of the technical and organizational measures to ensure the security of processing.

2. In assessing the appropriateness of the level of security, particular consideration shall be given to the risks presented by the processing of data, in particular as a result of the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data.

3. Adherence to an approved code of conduct pursuant to Article 40 or to an approved certification mechanism pursuant to Article 42 may serve as an element to demonstrate compliance with the requirements set out in paragraph 1 of this Article.

4. The controller and the processor shall take measures to ensure that any person acting under the authority of the controller or the processor and having access to personal data may only process such data on instructions from the controller, unless required to do so by Union or Member State law.”

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

121/128

Article 32 does not establish static security measures; rather, it is the responsibility of the data controller to determine the necessary security measures to ensure the confidentiality, integrity, and availability of personal data. Therefore, the same data processing may involve different security measures depending on the specific circumstances in which such data processing takes place.

In line with these provisions, Recital 75 of the GDPR states: “The risks to the rights and freedoms of natural persons, of varying severity and probability, may arise from data processing that could cause physical, material, or immaterial harm, particularly in cases where processing may lead to discrimination, identity theft or fraud, financial losses, damage to reputation, loss of confidentiality of data subject to professional secrecy, unauthorized reversal of pseudonymization, or any other significant economic or social harm; in cases where data subjects are deprived of their rights and freedoms or prevented from exercising control over their personal data; in cases where the processed personal data reveal ethnic or racial origin, political opinions, religion or philosophical beliefs, trade union membership, and the processing of genetic data, data concerning health, or data concerning sexual life, or criminal convictions and related security measures; in cases where personal aspects are evaluated, in particular the analysis or prediction of aspects related to work performance, economic situation, health, personal preferences or interests, reliability or behavior, situation or movements, in order to create or use personal profiles; in cases where personal data of vulnerable individuals, particularly children, are processed; or in cases where processing involves a large amount of personal data and affects a large number of data subjects.” (the underlining is ours)

Furthermore, Recital 83 of the GDPR states: “In order to maintain security and prevent processing from infringing the provisions of this Regulation, the controller or the processor must assess the inherent risks of processing and implement measures to mitigate them, such as encryption. These measures must ensure an adequate level of security, including confidentiality, taking into account the state of the art and the cost of their implementation in relation to the risks and the nature of the personal data that must be protected. When assessing the risk in relation to data security, the risks arising from the processing of personal data must be taken into account, such as the accidental or

unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data, which may in particular cause physical, material, or immaterial harm.” (the underlining is ours)

Ultimately, the first step in determining security measures will be the risk assessment. Once assessed, it will be necessary to determine the security measures aimed at reducing or eliminating the risks associated with data processing.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

122/128

Data security requires the application of appropriate technical or organizational measures in the processing of personal data to protect such data against access, use, modification, dissemination, loss, destruction, or accidental, unauthorized, or unlawful damage. In this sense, security measures are key to guaranteeing the fundamental right to data protection. The existence of the fundamental right to the protection of personal data is not possible if confidentiality, integrity, and availability of such data cannot be guaranteed. It should not be forgotten that, in accordance with Article 32.1 of the cited GDPR, the technical and organizational measures to be applied to ensure an adequate level of security in relation to the risk must take into account the state of the art, the costs of implementation, the nature, scope, context, and purposes of the processing, as well as the variable probability and severity risks to the rights and freedoms of natural persons. The approach must be focused on the risks to the rights and freedoms of natural persons and not on the risks that the processing entails for the organization, centering it, as in the examined case, solely on information security measures.

Therefore, Telefónica, when assessing risks and determining the appropriate technical and organizational measures to ensure an adequate level of security in relation to the risk, is obliged to take into account the specific activity that its business entails, which involves continuously and on a large scale processing personal data (numerous data to be collected, processed, stored, etc.); the type of data processed: fixed telephone number, technical data and configuration of wifi network access equipment, etc.; the context: use of an application accessible through a web portal on the internet, that is, in a non-isolated environment, which entails risks arising from the very interconnectivity that the network implies, which must be addressed in a specialized manner.

Therefore, due to the activity in which it is engaged, Telefónica is obliged to carry out a highly specialized analysis of the risks and the implementation of appropriate technical and organizational measures to ensure an adequate level of security in relation to the risk of its activity for the rights and freedoms of individuals.

In the present case, as previously noted, Telefónica suffered a cyberattack on its application ***APP.1 through an internet portal, causing a security breach consisting of a breach of confidentiality due to access to personal data of its customers contained in said applications.

The application ***APP.1 is an application of Telefónica that contains information, including personal data of its customers, which is used for customer support and maintenance purposes by Telefónica's technical teams (diagnosis and treatment of faults in connectivity equipment: router, TV decoder, wifi amplifier, etc.), which, as noted, can be accessed by technicians through a portal published on the Internet.

From the analysis of the documentation provided by Telefónica in the various notifications of the security breach and the responses to the information requests regarding the causes that made the breach possible and the existing security measures prior to it, the following results:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

123/128

1. Chronology of events:

- On September 16, 2022, the team responsible for APIS (...) detected anomalous consumption

caused by massive requests from the application ***APP.1, an application accessible from the employee portal ***PORTAL.1 of Telefónica. This anomalous consumption persisted for the following 4 days and consisted of massive requests of around 4 million per day when the usual consumption is around 55,000 daily requests, all originating from a single user.

- On September 20, 2022, the user from whom these requests originated was blocked after it was verified, upon the user's return from vacation, that they were not the one legitimately making the requests.
- On September 21, 2022, this user reported the incident to Telefónica's security team (CSIRT).
- During September 21, 22, and 23, 2022, the incident was analyzed by the security team (CSIRT) using the centralized logging system (SIEM).
- On September 23, 2022, it was indicated that this was when the data breach was confirmed following the requests made by the attackers, and the incident was classified as a security breach. On the same day, the incident was reported to Telefónica's DPD via email.
- On September 26, 2022, an initial notification of the security breach was submitted to this Agency.
- On September 29, 2022, a new intrusion was detected, thanks to the security measures deployed after the attack, involving a different Telefónica user whose credentials had also been compromised. The password was changed, and all users of the affected application ***APP.1 were blocked.
- On October 26, 2022, a complete notification of the breach was submitted, including a documented report of the incident as an attachment. It was indicated that, once the complete analysis of the incident was concluded and after verifying that another user was compromised, it was detected that the attack began on September 9, 2022, and that, therefore, the malicious accesses occurred in three blocks of days: from September 9 to 11, from September 16 to 20, and on September 28, 2022. Therefore, it has been established that the security breach began on September 9, 2022, and was resolved on September 29, 2022, affecting the application ***APP.1 accessible from Telefónica's employee portal (***PORTAL.1). This application contains information, including personal data, which is used for technical support and maintenance purposes for Telefónica's clients by the technical teams. The employee portal (***PORTAL.1) was exposed on the internet with the only restriction being authentication via username and password.

According to the email sent by Telefónica's CSIRT to the DPD on September 23, 2022, literally transcribed in the Fifth Background of this Agreement, on September 16, 2022, massive queries were detected from a single specific user to the indicated applications through the portal ***PORTAL.1, proceeding on September 18 (2 days later) to contact this user.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
124/128

sending him an email. The user was on vacation and it was not until September 20 (another 2 days later), when he returned to the office, that he became aware of what had happened and informed the PIGW managers that he did not recognize those requests, at which point they proceeded to block the user. At the moment the user changed his corporate credentials, the requests ceased.

This same employee, whose user account was used for the mass requests and whose credentials had been compromised, is the one who on 21/09/2022 notified the CSIRT mailbox of the incident via email, at which time he became aware of the security incident for the first time (5 days later).

In short, it was not until four days later that the first measures were taken to contain the attack (blocking the user), despite the fact that massive queries far exceeding the usual levels were occurring, and it was not until 5 days later that the first analyses and investigations of the attack were initiated by the CSIRT, confirming 3 days later that the incident had resulted in a breach of personal data.

2. Regarding the attack vector, it has been confirmed by Telefónica that the cause of the incident was the compromise of valid credentials (...). In this regard, in the risk analysis document provided by Telefónica, conducted during the period of July-October 2021, the threat or risk factor is analyzed "(...). It should be noted that this is a security analysis, without taking into account other risk factors for

the rights and freedoms of the affected individuals arising from the nature, scope, context, or purposes of the processing, as it identifies and evaluates exclusively the risks in terms of information security.

3. According to Telefónica, as measures implemented after the incident, it indicates among others: (...).

The above reflects that, prior to the incident, there were no appropriate technical and organizational measures in place to ensure adequate security in the processing of personal data concerning the associated risks. Or, if they existed, they were not effective or were not observed. This is the case because:

a) In the attacked application, which was accessed via an internet portal, and which provided access to personal data, (...).

It should not be forgotten that during the attack, requests from the same user reached up to 4 million per day, (...) affecting personal data of more than 1.4 million individuals, a number that could have been much lower had there been a quicker response.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

125/128

b) Specifically, the Telefónica CSIRT (Computer Security Incident Response Team), which aims to respond urgently and in a coordinated manner in the event of an attack to mitigate the impact and, therefore, the consequences, was not aware of the incident until 5 days later, which resulted in a considerable delay both in adopting possible containment and mitigation measures for the attack, as well as in the analysis and assessment of the same as a personal data security breach.

c) The personal data of customers accessed via an application from the internet was not securely encrypted, anonymized, or protected in such a way that it would be unintelligible in cases of unauthorized access or that individuals could not be identified, which would have considerably mitigated the risks to the rights and freedoms of individuals.

From all of the above, it is concluded that the technical and organizational measures implemented prior to the breach, regardless of whether it occurred, were not appropriate to ensure an adequate level of security relative to the risk posed by the processing of personal data, and this is irrespective of the specific attack suffered - which merely highlights these deficiencies once the risk has materialized - measures that, according to the state of the art at the time of the incident, already existed and were known, the costs of which were perfectly manageable for a company like Telefónica that, in addition, processes data on a large scale, and is therefore obliged to adopt appropriate technical and organizational security measures to address these risks.

Furthermore, in the complete notification of the breach, Telefónica stated that the breach could have been avoided by adopting additional measures, although it considered that the current measures were sufficient.

Therefore, in accordance with the available evidence, it is considered that the known facts constitute an infringement attributable to Telefónica for violation of Article 32 of the GDPR and that this infringement is independent of the attack suffered.

X Qualification of the infringement of Article 32 of the GDPR

The aforementioned infringement of Article 32 of the GDPR constitutes the commission of the infringements classified in Article 83.4 of the GDPR, which under the heading “General conditions for the imposition of administrative fines” provides:

“Violations of the following provisions shall be subject to administrative fines of up to 10,000,000 EUR or, in the case of an enterprise, an amount equivalent to up to 2% of the total annual global turnover of the previous financial year, opting for the higher amount:

a) the obligations of the controller and the processor under Articles 8, 11, 25 to 39, 42, and 43; (...)”

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

In this regard, the LOPDGDD, in its article 71 "Infringements," establishes that "Acts and behaviors referred to in paragraphs 4, 5, and 6 of article 83 of Regulation (EU) 2016/679, as well as those that are contrary to this organic law, constitute infringements."

For the purposes of the statute of limitations, article 73 "Infringements considered serious" of the LOPDGDD indicates:

"Based on what is established in article 83.4 of Regulation (EU) 2016/679, the following infringements are considered serious and will be subject to a two-year statute of limitations, which involve a substantial violation of the articles mentioned therein, particularly the following:

(...)

f) The failure to adopt those technical and organizational measures that are appropriate to ensure a level of security adequate to the risk of processing, as required by article 32.1 of Regulation (EU) 2016/679.

XI Sanction for the infringement of article 32 of the GDPR

For the purpose of deciding on the imposition of an administrative fine and its amount, it is necessary to grade the sanction to be imposed, in accordance with the following criteria established in article 83.2 of the GDPR:

As aggravating factors:

- Article 83.2.b) GDPR. Negligence in the infringement: negligence is observed since Telefónica did not have the appropriate technical and organizational measures to ensure a level of security adequate to the risk posed by the processing of personal data contained in an application that can be accessed through a portal from the internet. In this regard, it should be noted that Telefónica is a large telecommunications operator that continuously and on a large scale processes data, and therefore is required to exercise a greater level of diligence and implement adequate measures to ensure the security of the personal data it processes.

It is worth recalling, in this sense, the Judgment of the National Court of 17/10/2007 (rec. 63/2006), which regarding entities whose activity involves the continuous processing of customer data, indicates "...the Supreme Court has understood that there is imprudence whenever a legal duty of care is neglected, that is, when the infringer does not behave with the required diligence. And in assessing the degree of diligence, the professionalism or lack thereof of the subject must be especially weighed, and there is no doubt that, in the case now examined, when the activity of the appellant involves constant and abundant handling of personal data, it must be insisted on rigor and exquisite care to comply with the legal provisions in this regard."

Furthermore, it is considered appropriate to grade the sanction to be imposed according to the following criteria established in paragraph 2 of article 76 "Sanctions and corrective measures" of the LOPDGDD:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

As aggravating factors:

- Article 76.2.b) LOPDGDD. Linkage of the infringer's activity with the processing of personal data: The development of the business activity carried out by Telefónica involves continuous and large-scale processing of personal data, as it processes data from millions of people (customers, employees, etc.). Therefore, it is a large company accustomed to processing personal data.

The balance of the circumstances contemplated in article 83.2 of the GDPR and article 76.2 of the LOPDGDD, regarding the infringement committed by violating the provisions of article 32 of the GDPR, allows for the proposal of a sanction of €500,000 (five hundred thousand euros).

XII Measures

In the text of the resolution, the infringements committed and the facts that led to the violation of data protection regulations are established, from which it is clearly inferred what measures must be adopted, without prejudice to the fact that the type of procedures, mechanisms, or specific instruments for implementing them corresponds to the sanctioned party, as it is the data controller who fully knows its organization and must decide, based on proactive responsibility and a risk-based approach, how to comply with the GDPR and the LOPDGDD.

Therefore, in accordance with the applicable legislation and evaluated the criteria for grading the sanctions whose existence has been established, the Director of the Spanish Agency for Data Protection

RESOLVES

FIRST: TO IMPOSE on TELEFÓNICA DE ESPAÑA SAU, with NIF A82018474, for an infringement of article 5.1.f) of the GDPR and article 32 of the GDPR, classified in articles 83.4 and 83.5 of the GDPR, a fine of €500,000.00 and €800,000.00 (EIGHT HUNDRED THOUSAND and FIVE HUNDRED THOUSAND euros).

SECOND: TO NOTIFY this resolution to TELEFÓNICA DE ESPAÑA SAU.

THIRD: This resolution will be enforceable once the period for filing the optional appeal for reconsideration (one month from the day following the notification of this resolution) has expired without the interested party having exercised this right. The sanctioned party is warned that it must pay the imposed sanction once this resolution is enforceable, in accordance with the provisions of article 98.1.b) of the LPACAP, within the voluntary payment period established in article 68 of the General Collection Regulation, approved by Royal Decree 939/2005, of July 29, in relation to article 62 of Law 58/2003, of December 17, by making the payment, indicating the NIF of the sanctioned party and the procedure number that appears in the heading of this document, into the restricted account No. IBAN: ES00-0000-

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
128/128

0000-0000-0000-0000 (BIC/SWIFT Code: CAIXESBBXXX), opened in the name of the Spanish Agency for Data Protection at the banking entity CAIXABANK, S.A.

Otherwise, collection will proceed in the executive period.

Upon receiving the notification and once it is executive, if the date of executiveness falls between the 1st and the 15th of each month, inclusive, the deadline for making voluntary payment will be until the 20th of the following month or the next business day, and if it falls between the 16th and the last day of each month, inclusive, the payment deadline will be until the 5th of the second following month or the next business day.

In accordance with the provisions of Article 76.4 of the LOPDGDD and given that the amount of the imposed sanction exceeds one million euros, the information identifying the offender, the infringement committed, and the amount of the sanction will be published in the Official State Gazette.

In accordance with the provisions of Article 50 of the LOPDGDD, this Resolution will be made public once it has been notified to the interested parties.

Against this resolution, which concludes the administrative procedure in accordance with Article 48.6 of the LOPDGDD, and in accordance with the provisions of Article 123 of the LPACAP, the interested parties may optionally file a motion for reconsideration before the Director of the Spanish Agency for Data Protection within one month from the day following the notification of this resolution or directly file an administrative contentious appeal before the Administrative Contentious Chamber of the National Court, in accordance with the provisions of Article 25 and Section 5 of the fourth additional provision of Law 29/1998, of July 13, regulating the Administrative Contentious Jurisdiction, within two months from the day following the notification of

this act, as provided in Article 46.1 of the aforementioned Law.

Finally, it is noted that in accordance with the provisions of Article 90.3 a) of the LPACAP, the firm resolution in the administrative procedure may be provisionally suspended if the interested party expresses their intention to file an administrative contentious appeal. If this is the case, the interested party must formally communicate this fact by means of a written document addressed to the Spanish Agency for Data Protection, submitting it through the Electronic Registry of the Agency [<https://sedeagpd.gob.es/sede-electronica-web/>], or through any of the other registries provided for in Article 16.4 of the aforementioned Law 39/2015, of October 1. They must also provide the Agency with documentation that proves the effective filing of the administrative contentious appeal. If the Agency does not become aware of the filing of the administrative contentious appeal within two months from the day following the notification of this resolution, it will consider the provisional suspension to be terminated.

938-16012024

Mar España Martí

Director of the Spanish Agency for Data Protection

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es